봇 계정

AI는 누구의 이름으로 행동하는가

계정이라는 익숙한 장치에서 출발해 AI의 신원과 기억, 업무와 위임, 권한과 책임을 살펴본다. 특정 AI에게 일을 맡기고 그 관계를 이어 가려면 무엇을 식별하고 기록하며 통제해야 하는지 탐구한다.

저자 하우성

2026년 10월 28일

목차

주민등록번호 계좌번호 로그인 계정 그리고 봇 4

제1부 계정으로 읽는 인간의 세계 5

1장 이름, 번호, 계정은 어떻게 다른가 6

2장 국가는 사람을 어떻게 등록하는가 12

3장 은행은 돈을 어떻게 기록하는가 14

4장 로그인 이후의 나 16

제2부 AI에게 계정이 필요해지는 순간 18

5장 대답하는 AI에서 행동하는 AI로 19

6장 모델 봇 계정은 서로 무엇이 다른가 21

7장 어제의 봇과 오늘의 봇은 같은가 24

8장 봇 계정의 탄생과 종료 26

제3부 기억이 업무로 이어지는 구조 28

9장 봇은 무엇을 기억해야 하는가 29

10장 공통 컨텍스트로 함께 일하기 32

11장 끝나지 않은 일은 어디에 남는가 35

12장 봇들이 서로를 알아보는 방법 38

제4부 누구의 이름으로 어디까지 행동하는가 41

13장 봇을 만든 사람 운영하는 사람 일을 맡긴 사람 42

14장 목표를 맡기는 것과 권한을 주는 것 44

15장 봇이 한 일을 어떻게 증명할 것인가 47

16장 봇이 한 일의 책임은 어디로 가는가 50

제5부 봇 계정이 들어오는 일과 경제 52

17장 개인은 어떤 봇을 곁에 둘 것인가 53

18장 조직은 봇을 어떻게 받아들일 것인가 55

19장 봇이 돈을 쓸 때 57

20장 봇 계정의 문을 누가 관리하는가 60

제6부 봇 계정 사회를 설계하는 질문 62

21장 봇 계정의 최소 구조를 설계하다 63

22장 계정이 탈취되거나 사라진다면 66

23장 계정은 인격을 만드는가 68

24장 무엇을 AI에게 맡길 것인가 70

계정을 부여한다는 것은 관계를 설계한다는 것 72

부록 73

A. 핵심 용어 74

B. 참고문헌과 주석 75

주민등록번호 계좌번호 로그인 계정 그리고 봇

주민등록번호는 행정 기록 속에서 나를 구별한다. 계좌번호는 은행의 어떤 계좌를 가리킨다. 인터넷에서는 계정으로 들어가 글을 쓰고 물건을 사며 다른 사람과 관계를 맺는다. 서로 다른 제도를 나란히 놓고 보면 하나의 질문이 생긴다. **시스템은 나를 어떻게 알아보고, 내가 한 일과 내가 가진 권한을 어떻게 이어 붙이는가.**

처음에는 주민등록번호를 인간의 계정이라고 부를 수도 있겠다. 그러나 이 비유를 끝까지 밀고 가려면 차이를 먼저 인정해야 한다. 사람의 존재는 등록번호보다 크다. 은행 계좌에는 금융 관계가 있고, 온라인 계정에는 서비스가 정한 접근과 이용의 규칙이 있다. 이 책은 그것들을 하나의 제도라고 주장하지 않는다. 각기 다른 장치에서 식별과 기록, 관계의 관리라는 공통 질문을 찾아본다.

AI를 생각하면 질문은 더 구체적이 된다. 문장을 한 번 만들어 주는 프로그램을 이용할 때는 답변의 품질이 먼저 눈에 들어온다. 그러나 내 자료를 읽고, 지난주에 하던 일을 이어 하며, 다른 서비스에 접근하는 봇에게는 답변 이외의 설명이 필요하다. 지금 행동하는 것은 어느 봇인가. 누구의 요청을 수행하는가. 어떤 자료까지 볼 수 있는가. 일을 멈추게 하면 아직 처리하지 않은 요청도 함께 멈추는가.

이 책에서 봇 계정은 이러한 관계를 관리하기 위한 개념이다. 사람처럼 말하는 능력, 고유한 이름, 긴 대화 기록 중 어느 하나만으로 완성되지 않는다. **봇을 식별하는 기준을 정하고 그 신원에 운영자, 권한, 업무와 활동 기록을 연결해야 한다.** 모든 기능을 하나의 데이터베이스에 담자는 뜻도 아니다. 여러 시스템에 흩어진 관계를 확인할 수 있게 만들자는 제안이다.

논의를 이어 가기 위해 가상의 출판사를 떠올려 보자. 편집자 지수는 조사봇에게 자료 수집을 맡기고, 편집봇에게 원고의 구조를 검토하게 한다. 두 봇은 같은 언어 모델을 사용할 수도 있다. 그러나 읽을 수 있는 자료, 맡은 일, 결과를 승인하는 사람은 다르다. 이 출판사와 인물은 설명을 위해 구성한 사례이며, 실제 기업의 운영실적이나 조사 결과를 뜻하지 않는다.

뒤의 장에서는 이 출판사의 봇이 기억을 수정하고, 예산을 배정받고, 담당자가 바뀌고, 계정 탈취 의심을 받는 상황을 살펴본다. 작은 업무에서 시작하지만 질문은 조직과 사회로 이어진다. 누가 계정을 발급하고 정지할 수 있는가. 서비스를 바꿀 때 업무를 옮길 수 있는가. 오류로 피해를 본 사람은 누구에게 설명을 요구할 수 있는가.

법령과 표준은 이미 마련된 구분을 알려 준다. 연구 논문은 특정 조건에서 확인한 가능성과 한계를 보여 준다.

그 자료들을 연결해 제안하는 봇 계정의 구조는 이 책의 논제다. 기술적으로 식별할 수 있다는 사실에서 의식이나 법적 인격이 생겼다고 결론짓지 않는다. **우리는 AI의 내면을 확정하기 전에, AI에게 맡긴 일이 어떤 관계 속에서 수행되는지부터 설명할 수 있어야 한다.**

제1부

계정으로 읽는 인간의 세계

1장 이름, 번호, 계정은 어떻게 다른가

계정을 이해하려면 먼저 우리를 부르는 이름, 대상을 구별하는 식별자, 접근 자격을 확인하는 인증수단을 나누어 보아야 한다. 계정은 이 가운데 어느 하나와도 완전히 같지 않다. 특정 시스템이 상대를 기록하고, 그 상대와 맺은 관계를 이어 가는 데 사용하는 관리 단위다. 이 구분은 AI에게 계정을 부여한다는 말의 의미를 밝히는 출발점이 된다.

한 회사에 이름이 같은 두 사람이 있다고 가정해 보자. 두 사람 모두 김지수다. 회의실에서 누군가 “김지수님”이라고 부르면 두 사람이 함께 고개를 들 수 있다. 동료들은 부서나 업무를 덧붙여 상대를 구별할 것이다.

그러나 급여를 지급하거나 프로젝트 자료의 접근 권한을 설정하는 시스템에는 그때마다 상황을 짐작하게 할 수 없다. 어떤 기록이 어느 사람에게 연결되는지 일관되게 정해야 한다.

이 회사가 두 직원에게 서로 다른 사번을 부여하고 업무 계정을 만들었다고 하자. 화면에 표시되는 이름은 같아도 사번과 계정 기록은 구별된다. 한 사람의 비밀번호가 바뀌거나 다른 사람이 부서를 옮겼다고 해서 두 사람의 업무 이력이 뒤섞여서는 안 된다. 이 평범한 사례 안에 이름, 식별자, 인증, 계정의 차이가 들어 있다.

1.1 나를 부르는 이름과 나를 구별하는 번호

이름은 사람을 부르고 기억하는 데 쓰인다. 이름을 통해 얼굴을 떠올리고, 함께한 경험을 기억하며, 특정한 사람과 대화를 이어 간다. 가까운 관계에서는 이름만으로 충분할 수 있다. 그러나 사람들이 많아지고 기록이 여러 장소와 시간에 걸쳐 쌓이면, 이름이 같거나 바뀌는 상황을 처리할 규칙이 필요해진다.

그때 중요한 것은 숫자 자체가 아니라 식별의 범위다. 어느 회사에서 사번 42번인 사람이 다른 회사에서도 42번이라고 해서 같은 사람이라고 판단할 수는 없다. ‘어느 회사의 42번인가’가 함께 있어야 한다. 식별자는 그것을 발급하고 사용하는 체계 안에서 해석된다.

NIST(National Institute of Standards and Technology, 미국 국립표준기술연구소)는 미국 상무부 산하에서 측정과 기술의 표준을 정하고, 사이버보안과 디지털 신원에 관한 지침을 만들어 공개하는 기관이다. 이 책에서 자주 인용하는 디지털 신원 지침, 보안 통제 목록, AI 위험 관리 프레임워크도 NIST가 발간한 문서다. NIST는 디지털 신원을 특정 맥락 안에서 대상을 고유하게 설명하는 속성 또는 속성의 집합으로 정의한다. 식별자 역시 주어진 맥락에서 하나의 대상에 연결되는 데이터로 설명한다. 여기서 눈여겨볼 표현은 ‘특정 맥락’이다. 어떤 번호를 안다는 것만큼, 그 번호가 어느 체계에서 무엇을 가리키는지 아는 것이 중요하다.[1] 이름과 번호를 너무 단단하게 나누어서도 안 된다. 이름이 식별자로 쓰일 수 있고, 식별자가 반드시 숫자로만 이루어져야 하는 것도 아니다. 서비스가 중복을 허용하지 않는 사용자 이름, 특정 범위에서 계정을 구별하는 문자열도 식별자의 역할을 할 수 있다. 우리가 일상에서 말하는 ‘아이디’가 이런 예다. 중요한 것은 글자인지 숫자인지가 아니라, 그 값으로 어떤 대상을 어느 범위에서 구별하는가다.

이 차이를 실제 규격에서 확인할 수 있다. 사용자 정보를 교환하는 SCIM의 핵심 스키마를 정한 IETF RFC 7643은 화면에 보여 주는 이름인 displayName과 사용자를 구별하는 userName, 자원 자체의 식별자인 id를 따로 다룬다. 특히 id에는 안정적으로 유지되고 다른 자원에 재할당되지 않아야 한다는 요구를 둔다. 사람이 읽기 좋은 이름과 시스템이 기록을 연결하는 기준을 구분한 사례다.[2] 이를 앞의 회사에 적용하면, 인사 화면에서 두 사람이 같은 '김지수'로 표시돼도 내부에서는 다른 대상을 가리키도록 설계할 수 있다. 한 직원이 이름을 변경했을 때도 표시 정보와 내부 식별자의 관계를 적절히 관리하면 기존 업무 이력을 이어 갈 수 있다. 다만 모든 서비스가 똑같이 구현돼 있다고 단정할 수는 없다. 이름 변경과 계정 유지의 관계는 각 시스템의 규칙에 달려 있다.

계좌번호도 이 구분을 이해하는 데 도움이 된다. ISO 13616-1은 계좌번호를 계좌를 식별하는 식별자로 정의 한다. 따라서 계좌번호가 가리키는 것은 계좌다. 번호를 적은 종이나 문자열 자체가 잔액과 거래 관계의 전부는 아니다.[3] 식별자가 사람의 모든 것을 설명할 필요는 없다. 업무 계정을 구별하는 문자열에는 그 사람의 취향이나 가족관계가 담겨 있지 않아도 된다. 시스템은 필요한 기록을 연결할 수 있으면 된다. 여기서 '누구인지 구별한다'는 말과 '그 사람에 관해 모든 것을 안다'는 말이 갈라진다.

이 구별은 봇에도 그대로 질문을 던지게 한다. 화면에 '리서치봇'이라는 이름이 두 번 나타났을 때, 같은 봇이 두 곳에서 실행 중인 것인지 서로 다른 봇이 같은 이름을 쓰는 것인지는 이름만으로 알 수 없다. 그 이름이 어떤 신원과 연결돼 있는지, 시스템이 두 대상을 어떻게 구별하는지 확인해야 한다. 봇의 이름을 정하는 일과 봇의 신원을 관리하는 일은 각각의 설계가 필요하다.

지금까지의 구분을 네 제도에 나란히 적용하면 '계정'이라는 비유의 범위가 분명해진다. 번호는 어느 대상인가를 찾는 단서이고, 기록과 권한은 별도의 규칙으로 관리한다. 번호만으로 접근 권한이나 법적 인격이 생기지는 않는다. 구현으로 옮기면 표시 이름과 내부 ID를 분리하고, 인증에 쓰는 비밀키·토큰도 계정 정보와 분리한다. 예컨대 봇의 표시 이름을 '조사봇'으로 바꾸더라도 bot-01이라는 내부 ID의 이전 업무 기록은 계속 찾을 수 있어야 한다.

영역	대상을 구분하는 값	연결되는 기록·관계	접근·행동을 결정하는 조건
국가의 등록	주민등록번호	주민등록표 등 행정 기록	관련 법과 행정 절차
은행의 계좌	계좌번호	명의·잔액·거래·계약 관계	거래 권한과 금융기관의 절차
인터넷 서비스	서비스 내 사용자 ID	프로필·활동·설정·권한	인증수단 + 서비스의 접근 정책
봇 운영 시스템	봇 계정 ID	운영자·업무·실행·기억 참조	봇의 신원 확인 + 행동별 권한 검사

〈표 1〉 네 제도에서 식별자·기록·접근 조건의 구분 — 네 제도의 법적 지위가 같다는 뜻은 아니다

1.2 식별자·인증수단·계정의 차이

로그인 화면에서는 이러한 차이가 잘 드러나지 않는다. 사용자 이름을 입력하고 비밀번호를 입력하면 곧바로 서비스가 열린다. 두 입력란을 늘 함께 사용하다 보니, 아이디와 비밀번호의 조합을 계정 자체라고 생각하기 쉽다. 하지만 그 화면 뒤에는 서로 다른 질문이 있다. 어느 기록에 접근하려는지, 그 기록에 연결된 인증수단을 통제하고 있는지, 요청한 작업이 허용되는지를 각각 판단해야 한다.

NIST의 디지털 신원 모델은 가입자 계정을 가입자와 그 속성, 연결된 인증수단에 관해 신원 서비스 제공자가 유지하는 기록으로 설명한다. 이 설명에서 계정은 사용자 이름 한 줄이나 비밀번호 하나보다 넓다. 인증수단은 계정에 연결되는 요소이며, 검증자는 그 연결과 계정의 상태를 확인한다.[4] 식별자는 어떤 대상을 가리키는지 알려준다. 인증은 그 신원을 주장하는 쪽이 등록된 인증수단을 소유하고 통제하고 있음을 확인하는 과정이다. 비밀번호는 이때 사용할 수 있는 비밀값이다. NIST는 비밀번호를 사용자가 알고 있는 정보에 해당하는 인증 요소로 다룬다.[5] 다른 사람의 사용자 이름을 알고 있다고 해서 그 사람의 계정에 들어갈 수 있어서는 안 된다. 소프트웨어에서도 같은 구분이 나타난다. OAuth 2.0의 기본 규격인 RFC 6749는 등록된 애플리케이션을 가리키는 client_id가 비밀값이 아니며, 그것만으로 클라이언트를 인증해서는 안 된다고 명시한다. **이름표를 아는 것과 그 이름표가 가리키는 주체로 행동할 자격을 확인하는 것은 서로 다른 절차다.**[6] 인증 결과를 해석할 때도 범위를 지켜야 한다. 등록된 인증수단을 사용했다는 사실이 곧 그 순간의 행동을 계정의 정당한 사용자가 직접 의도했다는 사실까지 증명하는 것은 아니다. 인증수단이 타인에게 넘어간 상황을 생각하면 차이가 분명해진다. 그러므로 인증은 어떤 증거를 확인했는지, 그 증거가 어디까지 신뢰를 제공하는지와 함께 이해해야 한다.

인증을 마친 뒤에는 권한을 확인해야 한다. 이 과정을 인가라고 한다. 같은 프로젝트에 참여하는 두 직원이 모두 정상적으로 로그인했더라도, 한 사람은 문서를 읽을 수만 있고 다른 사람은 수정할 수 있도록 설정할 수 있다. **신원이 확인됐다는 사실과 어떤 행동이 허용된다는 사실은 별개의 판단이다.**

NIST의 속성 기반 접근제어 지침은 주체, 접근 대상, 요청한 작업, 필요에 따른 환경 조건을 정책과 대조해 허용 여부를 결정하는 방식을 설명한다. 이 관점에서 접근 권한은 계정에 붙은 단순한 ‘가능’ 표시 하나로 끝나지 않는다. 무엇에 접근하는지, 어떤 일을 하려는지가 함께 고려된다.[7] 앞의 회사에서 한 직원의 비밀번호를 교체한다고 해 보자. 인증에 사용하는 정보는 바뀌지만, 그 직원의 업무 계정과 프로젝트 이력을 그대로 이어 가도록 설계할 수 있다. 반대로 같은 계정에서 문서 편집 권한만 회수할 수도 있다. 표시 이름의 변경, 인증수단의 변경, 권한의 변경은 각각 다른 사건이다.

이 차이를 놓치면 운영 중 생기는 문제를 정확히 설명하기 어렵다. 로그인에 실패한 것인지, 로그인은 됐지만 문서 접근이 거부된 것인지, 잘못된 계정에 자료가 연결된 것인지에 따라 해결할 일이 달라진다. 첫 번째는 인증 문제일 수 있고, 두 번째는 인가 문제일 수 있으며, 세 번째는 신원과 기록의 연결 문제일 수 있다. 사용자의 눈에는 모두 ‘접속이 안 된다’거나 ‘내 자료가 없다’는 경험으로 나타나지만 시스템 안에서 확인해야 할 지점은 다르다.

계정에 기록이 연결된다고 해서 관련된 모든 자료가 계정 데이터 한곳에 저장돼야 하는 것은 아니다. 계정 관리 시스템, 문서 저장소, 권한 정책, 활동 로그를 각각 두고 서로 연결하는 구조도 생각할 수 있다. 여기서 말하는 계정의 역할은 물리적인 저장 위치보다 관계를 일관되게 관리하는 기준에 있다.

〈그림 1〉 이름표는 대상을 가리키고, 열쇠는 접근 자격을 확인하는 비유다. 계정에는 기록과 권한의 관계가 이어진다.

1.3 시스템 안에 나의 자리가 생긴다는 것

회사에 업무 계정이 만들어졌다고 가정해 보자. 이제 그 사람을 특정 프로젝트의 참여자로 등록하고, 문서를 공유하고, 업무를 배정할 수 있다. 다음 날 다시 접속했을 때도 같은 기록을 찾아 연결할 수 있다. 계정은 매번상대를 처음부터 설명해야 하는 수고를 줄이고, 이전의 관계를 현재의 작업으로 이어 주는 기준이 된다.

이때 시스템이 파악하는 사람의 모습은 특정 목적에 맞춰 구성돼 있다. 회사의 업무 계정에는 부서와 역할이 중요할 수 있고, 도서 대출 서비스의 계정에는 대출 상태와 반납 기한이 중요할 수 있다. 한 사람이 여러 계정을 가진다는 것은 그 사람 자체가 여러 존재로 나뉜다는 뜻이 아니다. 서로 다른 체계가 각자의 목적에 따라 같은 사람과 관계를 맺는다는 뜻에 가깝다.

NIST의 가입자 계정 지침도 한 사람이 여러 역할이나 페르소나로 활동하는 경우를 다룬다. 개인으로 활동할 때와 사업체를 대표할 때를 구분하는 사례가 그 예다. 지침은 이런 역할을 관리하는 방식과 복수 계정을 허용할 때의 처리를 구별한다. 역할 하나마다 반드시 새 계정을 만들어야 한다는 결론을 내리지는 않는다.[8] 계정이 언제나 법적 실명을 요구하는 것도 아니다. 같은 지침은 신원 확인 절차를 거치지 않은 신청자에게 가명 계정을 만들고 그 상태를 기록할 수 있다고 설명한다. 어떤 계정이 지속적으로 같은 상대를 가리킨다는 것과 그 상대의 현실 신원이 검증됐다는 것은 구분할 수 있다.[8] 책을 읽는 모임에서 필명으로 활동하는 사람을 떠올려 보자. 다른 회원들은 그 사람의 법적 이름을 몰라도 이전에 쓴 글과 이번에 쓴 글을 같은 계정에 연결할 수 있다. 이것은 가능한 서비스 설계의 예다. 그 계정의 글을 어떤 사람의 글로 묶을 수 있다는 사실이 필명 뒤에 있는 사람의 모든 정보를 공개해야 한다는 결론으로 이어지지는 않는다.

계정을 '시스템 안의 자리'라고 부르는 이유가 여기에 있다. 이 자리는 사람의 존재 전체를 담는 그릇이라기보다, 시스템이 어떤 상대를 어떤 기록과 규칙에 연결할지 정하는 방식이다. 기록을 잘못 연결하면 다른 사람의 문서를 보여 주거나 엉뚱한 작업을 배정할 수 있다. 관계를 정확히 이어 주는 일이 계정 관리의 중요한 과제가 된다.

계정의 상태가 달라지면 그 관계를 사용할 수 있는 조건도 달라진다. 휴면이나 정지 상태로 바뀐 계정은 이전과 같은 방식으로 접근할 수 없도록 운영할 수 있다. NIST 지침은 계정의 갱신, 정지, 종료와 종료 뒤의 보존·폐기 요건을 따로 다룬다. 계정을 종료한다는 행위와 관련된 모든 기록이 즉시 사라진다는 상태도 같지 않다.[8] 여기에는 기술만으로 설명하기 어려운 제도적 측면이 있다. 어떤 기록을 유효한 것으로 받아들이고, 누구에게 자료를 보여 주며, 어떤 조건에서 접근을 중단할지에는 운영 주체가 정한 규칙이 작용한다. 기술은 그 규칙을 구현하지만, 무엇을 허용할 것인지에 관한 선택까지 대신 정해 주지는 않는다.

철학자 존 서얼은 제도적 지위를 설명하면서, 대상의 물리적 성질만으로는 성립하지 않는 기능이 사회적 인정속에서 작동한다고 논한다. 그 지위는 권한, 의무, 허가 등의 관계와 연결된다. 이는 계정을 기록된 정보와 인정되는 관계의 결합으로 생각하는 데 참고할 수 있는 하나의 이론이다. 다만 서얼의 논의가 디지털 계정이나 AI의 인격을 직접 증명하는 것은 아니다. 이 장에서 계정과 연결하는 부분은 저자의 해석이다.[9] 이러한 구별을 바탕으로 이 책에서는 계정을 다음과 같이 이해한다. **계정은 특정 시스템이 상대를 구별하고, 그 상대와 관련된 정보와 접근 관계를 연결하며, 그 관계의 상태를 관리하는 단위다.** 이는 디지털 신원 관리의 개념을 바탕으로 이 책의 논의를 위해 정리한 정의다. 행정 등록, 은행 계좌, 온라인 계정의 법적·기술적 구조가 모두 같다는 뜻은 아니다.

사람에게 적용하던 질문을 소프트웨어로 옮겨 보자. 어떤 프로그램이 문서를 읽고 결과를 저장한다면, 시스템은 그 요청을 어떤 주체의 것으로 다룰지 정해야 한다. W3C의 분산 식별자 규격인 DID Core도 식별되는 대상이 사람에 한정되지 않으며 조직이나 사물, 디지털 대상 등을 가리킬 수 있다고 설명한다. **식별 체계의 대상이 될 수 있다는 것과 인격을 가진다는 것은 별개의 문제다.**[10] 봇에게 계정을 부여하는 일도 이 구분에서 출발할 수 있다. 봇에 이름을 붙였다면 사람들은 그것을 부를 수 있다. 식별자를 부여했다면 시스템은 다른 대상과 구별할 수 있다. 여기에 인증과 권한, 관련 기록을 연결하면 그봇이 어떤 조건으로 활동하는지를 관리할 수 있다. 어느 단계까지 구현했는지를 분명히 해야 '봇 계정'이라는 말이 실제 기능을 설명하게 된다.

예컨대 조사봇이 만든 문서가 있다고 하자. 문서에 봇의 이름을 적어 두는 것만으로는 어떤 실행에서 만들어졌는지, 어떤 자료를 읽을 권한이 있었는지, 누구의 요청으로 작업했는지 알기 어렵다. 계정의 신원에 작업과 권한의 기록을 연결한다면 이 질문들을 확인할 출발점이 생긴다. 다만 그 연결을 어떻게 만들고 검증할지는 별도의 설계 과제로 남는다.

이 책이 탐구하려는 것은 바로 그 관계다. 어떤 AI에게 일을 맡겼다고 말할 때, 우리는 무엇을 같은 상대로 인정하고 어떤 행동을 그 상대의 기록으로 남길 것인가. 그 질문을 다루기 위해 먼저 인간의 세계에서 등록과 계정이 만들어 온 관계를 살펴볼 필요가 있다. 다음 장에서는 국가가 사람을 등록하는 방식으로 시선을 옮긴다.

2장 국가는 사람을 어떻게 등록하는가

2.1 주민등록번호와 행정 기록의 연결

이사를 마친 사람이 주소를 변경했다고 가정해 보자. 몸은 이미 새집에 도착했지만, 행정 기록에는 예전 주소가 남아 있을 수 있다. 사람의 이동과 기록의 갱신은 같은 사건이 아니다. 등록 제도는 현실에서 일어난 변화를 일정한 절차를 통해 기록으로 옮긴다. 이 시차를 생각하면 등록번호의 역할이 보인다. 번호는 삶을 만들어 내지 않지만, 여러 행정 과정에서 어떤 사람의 기록을 다루는지 구별하는 기준이 된다.

한국의 주민등록법 제7조는 개인별·세대별 주민등록표의 작성과 관리를 다루고, 제7조의2는 주민에게 개인별 고유한 등록번호를 부여하도록 정한다. 기록과 번호가 별도의 조문으로 규정돼 있다는 점에 주목할 만하다. 번호는 기록 전체와 같지 않고, 기록을 관리하는 제도 역시 번호 하나로 설명되지 않는다.[11] 따라서 주민등록번호를 ‘인간의 계정’이라고 부르는 것은 구조를 생각해 보기 위한 비유로 사용할 수 있다. 정확하게는 행정상 식별자와 그 식별자를 사용하는 등록 체계의 관계다. 은행이나 온라인 서비스의 계정과 비교할 때에도 목적, 등록 대상, 정정 절차, 접근 조건을 따로 살펴야 한다. 비슷한 모양의 번호가 있다는 사실만으로 동일한 제도가 되는 것은 아니다.

〈그림 2〉 사람이 이사한 것과 행정 기록의 주소가 바뀌는 것은 서로 다른 사건이다. 기록을 바로잡는 절차가 필요하다.

2.2 사람의 존재와 등록된 신원의 구별

등록은 사회적 관계를 처리하는 데 중요하지만 인간의 권리가 등록번호에서 시작된다고 설명해서는 안 된다.

한국 민법 제3조는 사람이 생존한 동안 권리와 의무의 주체가 된다고 정한다. 이 조문의 문구는 권리능력을 계정 발급 여부로 정의하지 않는다.[12] 등록 절차와 권리의 주체라는 지위를 구별하는 데서 비교의 한계가 분명해진다.

유엔의 법적 신원 의제 역시 법 앞에서 인격을 인정받을 권리와 출생등록의 중요성을 함께 다룬다. 여기에서 등록은 개인을 공식적으로 증명하고 제도에 연결하는 수단이다.[13] 증명할 문서가 부족한 사람이 제도 이용에 어려움을 겪을 수 있다는 사실과, 그 사람이 인간으로서 권리를 갖는다는 사실을 혼동해서는 안 된다.

봇을 등록할 때도 이 구분은 유용하다. 어떤 프로그램에 번호를 부여했다는 것은 운영 체계가 그것을 구별하기로 했다는 뜻이다. 그 번호 때문에 프로그램이 인간과 같은 권리의 주체가 됐다는 결론은 나오지 않는다. 인간의 등록 제도에서 가져올 것은 기록의 연결과 정정에 관한 질문이지, 인간의 지위를 그대로 복사하는 비유가 아니다.

2.3 등록되지 않거나 잘못 기록된 사람들

유니세프는 출생등록과 증명서가 아동의 신원 확인과 필수 서비스 접근에 중요하다고 설명한다. 등록의 공백은 보건·교육·보호 체계와의 연결을 어렵게 만들 수 있다.[14] 나라마다 제도가 다르므로 이를 한국 주민등록의 효과와 동일시할 수는 없다. 다만 기록 체계에서 누락되는 일이 단순한 서류상의 불편을 넘어설 수 있음을 보여 준다.

기록이 있어도 틀릴 수 있다. 가령 동명이인의 정보를 잘못 연결하거나 주소 변경을 반영하지 못했다면, 시스템의 일관된 처리 자체가 오류를 반복하는 수단이 된다. 그래서 잘못된 기록을 바로잡는 절차가 필요하다. 주민등록법 제21조는 정정·말소·거주불명 등록 등 일정한 처분에 대한 이의신청을 규정한다.[11] 기록의 효율성은 수정 가능성과 함께 평가해야 한다.

이 책이 여기서 도출하는 운영 원칙은 명확하다. **봇 계정도 잘못 연결된 기록에 이의를 제기하고 수정할 수 있어야 한다.** 특히 그 기록 때문에 사람이 접근을 거부당하거나 잘못된 평가를 받는다면, ‘시스템에 그렇게 적혀있다’는 답변만으로 끝내서는 안 된다. 등록은 관계를 안정시키지만, 그 관계를 바로잡을 통로까지 갖출 때 비로소 신뢰할 수 있다.

3장 은행은 돈을 어떻게 기록하는가

3.1 계좌번호가 가리키는 금융 관계

통장 화면에 나타나는 숫자는 두 종류다. 하나는 계좌를 구별하는 번호이고, 다른 하나는 잔액이다. 번호를 알았다고 해서 잔액을 마음대로 바꿀 수 없고, 잔액이 같다고 해서 두 계좌가 같은 계좌가 되는 것도 아니다. 은행은 계좌의 식별, 금융 거래의 기록, 거래를 요청하는 사람의 권한을 함께 다뤄야 한다.

영국 중앙은행은 현대의 화폐를 설명하면서 은행 예금을 은행이 가계나 기업에 지는 채무의 형태로 다룬다.[15]이 설명은 통장 속 금액을 금고 안에 붙인 개인별 이름표와 동일시하기 어렵게 만든다. 잔액은 금융기관과 고객 사이의 관계를 나타내는 기록이다. 구체적인 계약과 권리의 내용은 국가와 상품에 따라 달라진다.

가상의 출판사 통장에 운영자금이 있다고 하자. 대표가 통장을 확인하고 회계 담당자가 송금 업무를 처리할 수 있다. 두 사람이 화면에서 같은 잔액을 본다고 해서 돈의 귀속과 각자의 권한이 같아지는 것은 아니다. 계좌를 설명하려면 어떤 번호인지에 더해 누구 명의의 어떤 거래 관계인지도 알아야 한다.

〈그림 3〉 계좌번호는 계좌를 가리킨다. 현재 잔액은 거래 내역과 연결해 읽어야 하며, 돈의 귀속과 조작 권한도 구별해야 한다.

3.2 잔액과 거래 내역에 담긴 권리와 의무

잔액만 남기고 거래 내역을 없애면, 왜 현재의 금액에 도달했는지 설명하기 어렵다. 인쇄비 지급, 저작권료 입금, 취소된 주문의 환급은 각각 다른 사유를 가진다. 계좌가 업무에 쓰이는 순간 금액은 청구서와 승인, 계약, 이체 결과 같은 다른 기록과 연결돼야 한다. 이는 가상 출판사의 회계 업무를 이해하기 위한 사례다.

한국 금융실명법 제3조는 금융회사가 거래자의 실지명의로 금융거래를 하도록 하고, 일정한 실명 확인 계좌의 금융자산을 명의자의 소유로 추정하는 규정을 둔다.[16] ‘추정’이라는 표현에도 주의해야 한다. 계좌 화면의 이름만 보고 모든 분쟁에서 최종적인 권리 귀속이 확정된다고 읽어서는 안 된다. 법적 관계를 판단하려면 적용 법률과 구체적인 사실이 필요하다.

이 구분을 봇의 자원 관리에 적용해 볼 수 있다. 조사봇에게 자료 구매비를 배정했다고 해서 그 봇이 자신의 재산을 취득했다고 곧바로 말할 수는 없다. 예산은 조직이 특정 목적에 사용할 수 있게 설정한 한도일 수 있다.

계정에 표시된 숫자가 소유권, 사용할 수 있는 한도, 이미 사용한 금액 가운데 무엇인지 구분해야 한다.

3.3 돈을 가진 사람과 돈을 움직이는 권한

출판사가 조사봇에게 유료 논문을 구입하게 한다고 가정하자. 봇이 가격과 구매 대상을 제안하고, 편집자가 승인한 뒤, 결제 서비스가 회사의 지급 수단으로 처리할 수 있다. 여기에는 구매 판단, 승인, 지급 실행, 비용 부담이라는 서로 다른 기능이 있다. 이 구분은 특정 금융 서비스가 이미 제공한다는 설명이 아니라 운영을 설계하기 위한 예시다.

업무가 커질수록 단일한 '결제 가능' 권한은 모호해진다. 논문 한 편을 살 수 있는 권한과 매달 반복되는 구독을 시작할 권한은 다르다. 한 번 승인받은 가격이 바뀌었을 때 다시 승인이 필요한지도 정해야 한다. 단순히 봇에게 결제 정보를 알려 주는 방식으로는 이런 차이를 충분히 표현하기 어렵다.

은행 계좌에서 얻는 통찰은 돈을 기록하는 기술이 관계를 다루는 기술이기도 하다는 점이다. 봇에게 자원을 맡기는 설계에서도 잔액이나 한도만 보여 주어서는 부족하다. 그 자원을 누구의 목적을 위해 사용하고, 어떤 조건에서 중단하며, 잘못 사용했을 때 어떤 기록으로 확인할지까지 이어져야 한다. 19장에서는 이 문제를 예산과 결제의 구체적인 흐름으로 다시 살펴본다.

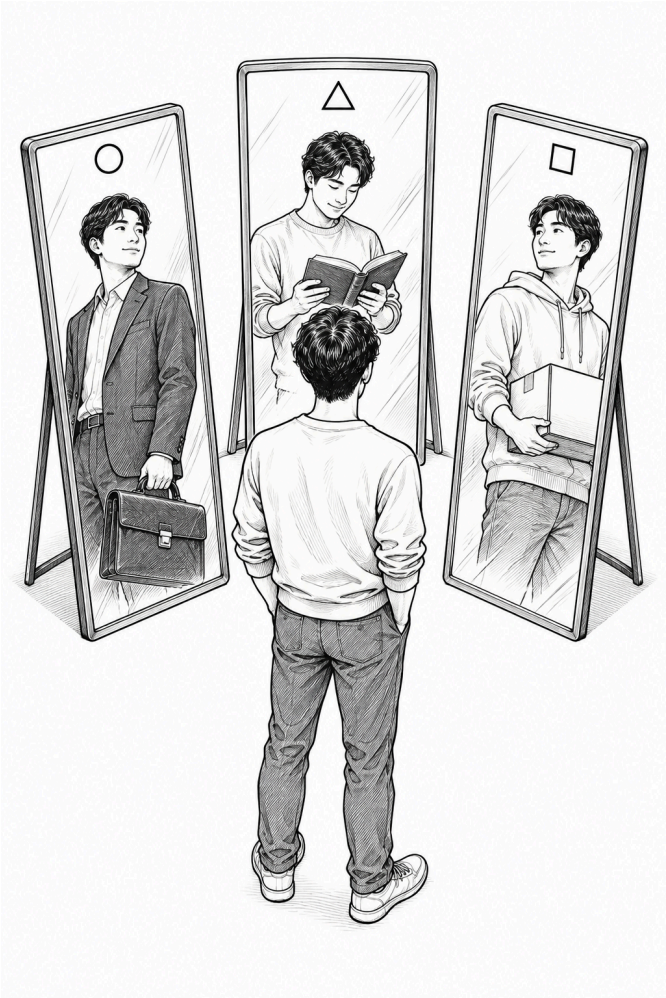
4장 로그인 이후의 나

4.1 하나의 사람 여러 개의 인터넷 계정

한 사람이 업무용 이메일, 독서 모임, 온라인 쇼핑몰에서 각각 다른 이름으로 활동한다고 하자. 업무 계정에는 조직 내 역할이, 독서 모임에는 글과 대화가, 쇼핑몰에는 주문과 배송지가 연결된다. 실제 사람은 하나지만 서비스가 그 사람과 맺은 관계는 다르다. 계정을 여러 개 갖는 일은 이러한 관계를 목적에 맞게 구분하는 방식이다.

여러 서비스를 하나의 인증 절차로 이용하는 연합 신원 방식도 있다. NIST의 연합 신원 지침은 신원 제공자가 인증에 관한 검증 가능한 진술을 서비스에 전달하는 구조를 설명한다.[17] 여기서 로그인 절차를 공유한다는 사실이 모든 서비스의 계정과 저장 자료를 하나로 합친다는 뜻은 아니다. 인증을 연결하는 규칙과 서비스가 이용 기록을 관리하는 규칙은 구분할 수 있다.

가령 회사의 인증으로 자료실에 들어가더라도 자료실이 보관한 열람 이력은 이메일함과 다른 체계에서 관리될 수 있다. 이 구분은 나중에 봇을 여러 도구에 연결할 때도 중요해진다. 한 번 인증됐다는 이유만으로 모든저장소의 내용과 모든 작업 권한이 자연스럽게 따라온다고 가정해서는 안 된다.



〈그림 4〉 한 사람이 여러 계정을 써도 사람 자체가 나뉘지는 않는다. 서비스별 기록과 접근 범위가 달라지는 것이다.

4.2 비밀번호에서 인증과 접근 권한으로

계정은 비밀번호를 중심으로만 이해할 수 없다. W3C의 WebAuthn Level 2는 공개키 자격증명을 사용하는 웹 인증 방식을 규정한다. 서비스는 등록된 공개키와 관련된 검증을 통해 인증을 처리할 수 있다.[18]이 사례가 보여 주는 것은 계정의 연속성이 특정한 비밀번호 문자열의 존속과 같지 않다는 점이다.

인증 방식이 달라져도 서비스가 누구의 요청을 어떤 계정에 연결할지 정해야 한다는 문제는 남는다. 휴대전화를 교체하거나 인증 장치를 잃어버렸을 때 기존 기록으로 돌아가는 절차도 필요하다. 편리한 복구와 타인의 접근 차단이 동시에 요구되므로, 최초 가입 화면보다 복구 과정이 계정의 실질적인 통제권을 더 잘 드러내는 경우를 생각해 볼 수 있다.

접근 권한은 또 다른 층위다. 회사 자료실에서 내 문서를 편집할 수 있다는 사실이 다른 부서의 문서를 지울 수 있다는 뜻은 아니다. NIST의 제로 트러스트 설명은 네트워크 안에 있다는 이유나 자산의 소유만으로 신뢰를 자동 부여하지 않으며 인증과 인가를 구별한다.[42] 봇이 회사 내부에서 실행된다는 사실도 작업별 권한 판단을 대신할 수 없다.

4.3 계정에 쌓이는 활동 관계 평판

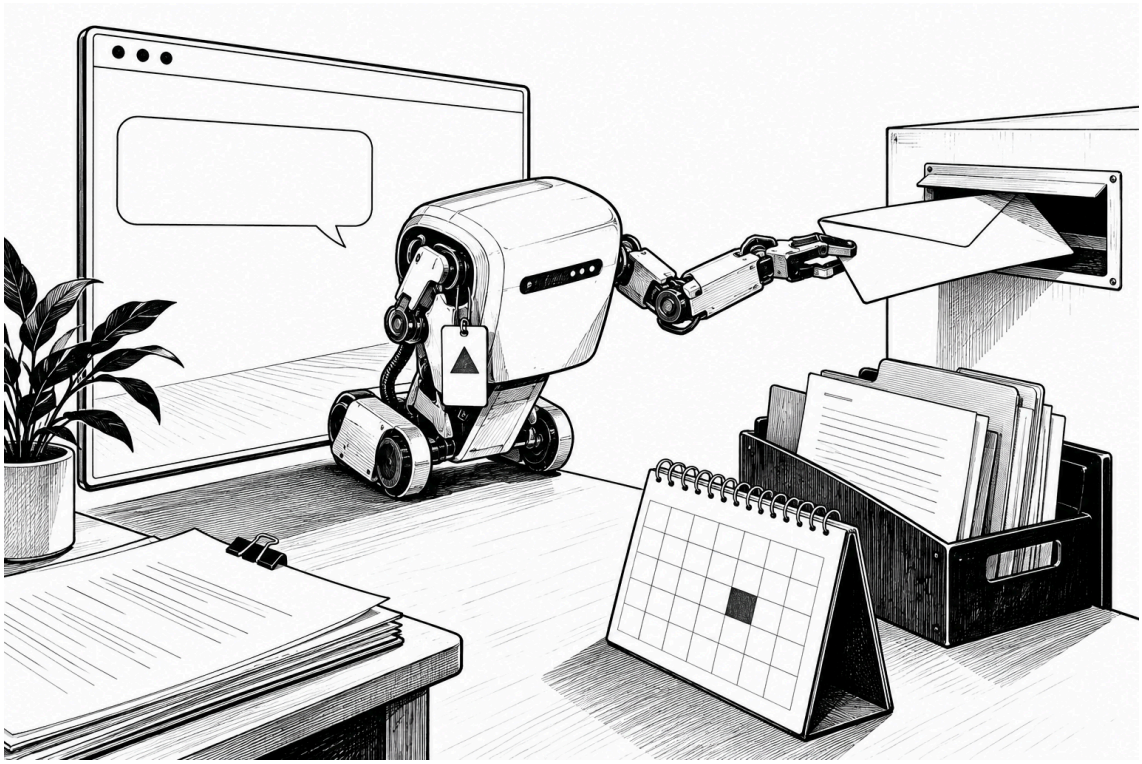
계정은 시간이 지나면서 과거의 행동을 모으는 기준이 된다. 독서 모임의 글, 상점의 구매 후기, 공동 작업 문서의 수정 이력은 다음 상호작용에 영향을 줄 수 있다. 그러나 활동량이 많다는 것과 기록이 정확하다는 것은 별개의 문제다. 누군가 계정을 공유했거나 자동화 도구가 일부 작업을 수행했다면, 기록을 곧바로 개인의 의도와 능력으로 읽기 어렵다.

가상의 출판사가 편집자 지수의 개인 계정으로 모든 봇을 실행한다고 해 보자. 문서를 수정한 기록에는 지수만 나타나지만 실제로는 조사봇과 편집봇이 서로 다른 단계에서 작업했을 수 있다. 이때 오류의 원인을 찾으려면 어느 실행이 무엇을 했는지 별도로 확인해야 한다. 사람이 가진 계정에 자동화를 붙이는 것만으로 봇의 행동을 충분히 구별할 수 있는 것은 아니다.

따라서 인터넷 계정에서 봇 계정으로 넘어가는 질문은 이미 익숙한 로그인 화면 안에서 시작된다. 이 요청은 누구에게 연결되는가. 그 기록을 누구의 행동으로 해석할 수 있는가. 이전의 신뢰를 다음 작업에도 적용해도 되는가. 봇이 외부 세계에서 할 수 있는 일이 많아질수록 이런 질문은 접근 화면 뒤의 기술 세부사항을 넘어 업무의 기본 조건이 된다.

제2부

AI에게 계정이 필요해지는 순간



5장 대답하는 AI에서 행동하는 AI로

5.1 답변 생성과 업무 수행 사이의 거리

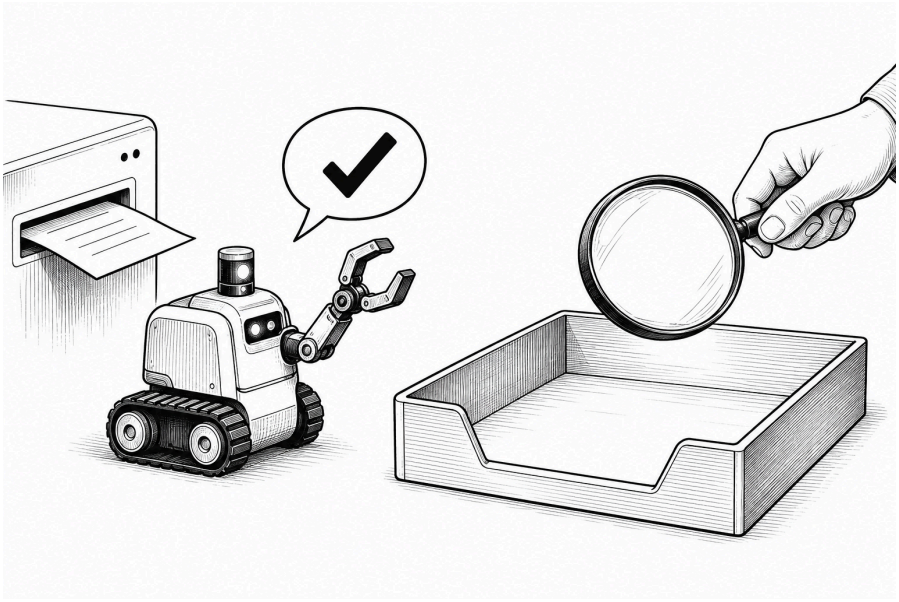
지수가 조사봇에게 어느 주제의 참고문헌을 찾아 달라고 한다. 봇이 검색어를 제안하는 데서 멈춘다면 지수가직접 자료를 찾을 것이다. 봇이 검색 도구를 사용하면 결과 목록을 가져올 수 있고, 자료실 접근이 허용되면 원문을 읽을 수 있다. 구매와 연락까지 가능하다면 비용이 발생하거나 외부 사람에게 메시지가 전달될 수 있다.

같은 요청에서도 실제로 일어나는 변화는 연결된 기능에 따라 달라진다.

ReAct 연구는 언어 모델이 작업에 관한 추론 과정과 행동을 번갈아 생성하고, 외부 환경에서 얻은 정보를 다음 단계에 반영하는 방식을 제안했다.[19] 이것은 모든 업무에서 성공을 보장한다는 결과가 아니다. 다만 언어생성과 도구 사용을 연결하는 구조를 구체적으로 보여 준다. 답변이 다른 프로그램의 입력이 되는 순간, 문장에 대한 평가와 실행에 대한 평가를 함께 해야 한다.

봇이 “자료를 확보했습니다”라고 말한 것과 자료실에 파일이 저장된 것은 별도로 확인할 수 있는 사건이다.

구매를 시도했다는 설명과 결제가 완료됐다는 사실도 다르다. 업무 시스템은 봇의 보고를 참고하되 외부 시스템의 실제 상태를 확인해야 한다. 말의 자연스러움이 결과 확인을 대신하면, 실패한 작업이 완료된 것으로 기록될 수 있다.



〈그림 5〉 봇의 완료 보고와 외부 시스템에 남은 실제 결과는 따로 확인해야 한다.

5.2 도구를 사용하고 외부 시스템에 접근하는 봇

도구는 봇의 능력뿐 아니라 영향 범위를 정한다. 검색 도구와 파일 삭제 도구는 결과의 되돌릴 수 있는 정도가 다르다. 같은 모델을 쓰더라도 도구가 달라지면 필요한 감독과 복구 방식이 달라질 수 있다. 이 책에서 행동하는 봇을 평가하는 단위는 모델의 답변 점수만이 아니라 모델, 도구, 권한, 운영 절차를 함께 묶은 업무 구조다.

예를 들어 조사봇이 문서를 읽기 위해 자료실에 요청을 보낼 때 자료실은 요청을 어떤 신원에 연결할지 알아야 한다. 무조건 사람이 가진 모든 권한을 넘겨주는 방식도 구현할 수 있겠지만, 업무 목적에 비해 과도한 접근을 허용할 수 있다. 조사 범위를 한 프로젝트 폴더로 제한하면 다른 원고와 계약서는 작업에서 분리할 수 있다. 이는 이 사례에 맞춰 선택한 설계다.

외부 자료를 읽는 행위도 완전히 수동적이지는 않다. OWASP는 웹페이지나 파일의 내용을 통해 모델의 행동을 의도하지 않은 방향으로 바꾸는 간접 프롬프트 인젝션 위험을 설명한다.[25] 조사봇이 읽은 문서 안의 지시를 사용자의 명령처럼 취급한다면, 정보를 얻기 위해 연 통로가 권한을 오용하는 통로가 될 수 있다. 읽을 자료와 따라야 할 지시를 구분하는 문제는 이후의 공통 컨텍스트 설계로 이어진다.

5.3 행동의 주체를 구별해야 하는 순간

모든 텍스트 생성 프로그램에 독립적인 장기 계정을 만들 필요는 없다. 한 번의 계산이나 요약을 수행하는 기능은 기존 업무 서비스의 일부로 관리할 수도 있다. 중요한 것은 어떤 수준에서 행동을 구별해야 하는가다. 여러 요청자와 장기간의 업무, 독립된 권한이 생기면 구별할 단위도 더 세밀해진다.

출판사가 한 달 동안 조사봇을 운영한다면, 어제의 결과를 누가 수정했는지와 오늘의 구매를 어떤 요청이 발생시켰는지 구분해야 한다. 계정은 장기간 유지되는 담당 단위가 될 수 있고, 실행 식별자는 그 안에서 개별 작업을 구별할 수 있다. 계정과 실행을 함께 기록하면 '조사봇이 했다'는 설명을 특정 사건으로 좁힐 수 있다.

이때 봇 계정의 필요성은 봇이 얼마나 사람처럼 보이는지에 달려 있지 않다. 외부 시스템이 그 행동을 구별하고 통제할 필요가 있는지에 달려 있다. 이름과 얼굴이 없는 짧은 프로그램에도 엄격한 권한 관리가 필요할 수 있고, 친근하게 대화하는 프로그램에는 외부 행동 권한이 전혀 없을 수 있다. 계정의 설계는 표현 방식보다 실제 업무에서 출발해야 한다.

6장 모델 봇 계정은 서로 무엇이 다른가

6.1 능력을 제공하는 모델과 일을 수행하는 에이전트

한 출판사가 같은 모델을 조사와 교정에 사용한다고 하자. 조사 업무에는 검색 도구와 참고문헌 저장소를 연결하고, 교정 업무에는 원고와 편집 규칙을 연결한다. 모델이 같아도 읽는 자료와 할 수 있는 행동이 다르므로 두 업무의 동작은 달라질 수 있다. 모델 이름만으로 어떤 봇이 무엇을 할 수 있는지 설명하기 어려운 이유다.

이 책에서는 모델을 입력을 처리하고 출력을 생성하는 핵심 구성요소로, 봇을 그 모델 또는 다른 프로그램에 지침·도구·상태를 결합해 업무를 수행하도록 만든 소프트웨어 구성으로 부른다. 에이전트라는 용어는 다음 행동을 선택하고 외부 결과를 받아 작업을 이어 가는 기능에 초점을 맞출 때 사용한다. 이는 논의를 위한 용어 구분이며 업계 전체가 하나의 정의에 합의했다는 뜻은 아니다.

봇 계정은 이 구성과 관련된 신원 및 운영 관계를 관리하는 단위다. 계정 기록에는 모델 버전이 연결될 수 있지만 **모델 그 자체가 계정은 아니다.** 반대로 모델을 교체했다고 해서 반드시 새 계정을 만들어야 하는 것도 아니다. 무엇을 유지하고 무엇을 새로 식별할지는 서비스의 연속성 규칙으로 정해야 한다.

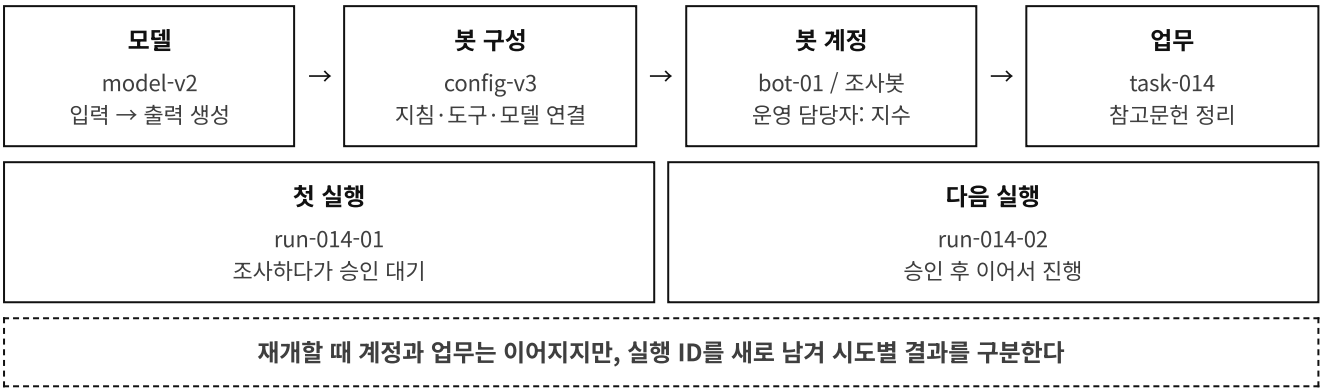
6.2 계정의 신원과 개별 실행의 구별

조사봇 계정이 오전에는 역사 자료를, 오후에는 과학 자료를 조사한다고 하자. 계정은 같지만 요청자와 사용자료, 생성한 결과는 다르다. 따라서 두 작업을 별도 실행으로 기록해야 각각의 출처를 따라갈 수 있다. 하나의 작업 안에서도 재시도와 도구 호출을 더 작은 사건으로 나누어 기록할 수 있다.

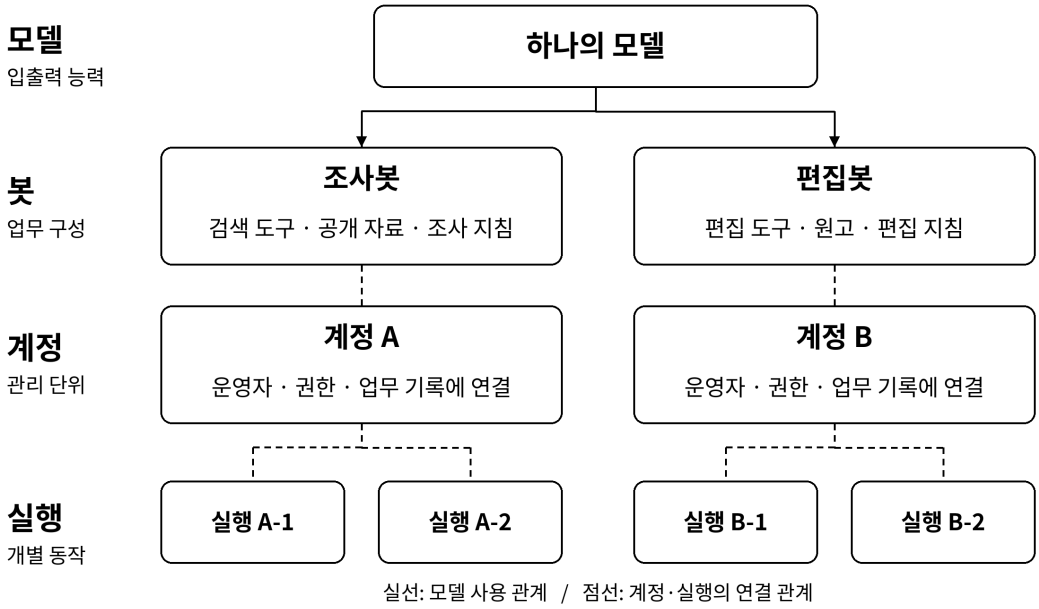
소프트웨어 신원을 다루는 SPIFFE는 워크로드가 여러 실행 인스턴스로 구성될 수 있음을 설명하고, 워크로드 식별자와 이를 증명하는 문서를 구분한다.[20]이 사례는 논리적인 업무 단위와 실행 중인 프로그램 하나를 항상 일대일로 맞출 필요가 없음을 보여 준다. 그러나 SPIFFE만 도입하면 봇의 기억과 업무, 책임까지 모두관리된다는 뜻은 아니다.

출판사에서는 조사봇 계정 하나를 여러 실행이 함께 사용할 수 있다. 이때 공유 계정만 남기고 실행 기록을 없애면 동시 작업의 원인을 추적하기 어려워진다. 계정 식별자, 작업 식별자, 실행 식별자를 연결하는 이유는 이름을 늘리기 위해서가 아니라 서로 다른 질문에 답하기 위해서다. 어느 담당 봇인가, 무엇을 하던 일인가, 어떤 실행에서 일어났는가를 구분한다.

이 관계를 한 번에 그리면 다음과 같다. 모델은 능력의 구성요소이고, 계정은 담당 단위이며, 실행은 실제로 일어난 한 번의 동작이다. 구현에서는 account_id, task_id, run_id를 각각 두고 실행에 사용한 모델·도구 구성 버전을 기록한다. **모델 교체가 새 계정 생성을 뜻하지는 않으며**, 두 실행이 같은 권한을 갖는지도 다시 확인해야 한다.



〈그림 6〉 모델·봇 구성·계정·업무·실행의 관계



〈그림 7〉 같은 모델로 서로 다른 봇을 구성할 수 있고, 하나의 계정 아래에도 여러 작업과 실행이 이어질 수 있다.

6.3 같은 모델을 사용하는 서로 다른 봇

조사봇과 편집봇이 같은 모델로 구동된다는 사실은 두 봇이 같은 자료를 보아도 된다는 근거가 되지 않는다.

조사봇은 공개 자료에 접근하고, 편집봇은 출간 전 원고를 읽도록 정할 수 있다. 두 봇이 협업하더라도 편집봇의 원고 전체를 조사봇에 전달해야 하는 것은 아니다. 필요한 질문과 허용된 발췌만 전달하는 구조를 선택할 수 있다.

반대로 하나의 봇이 여러 모델을 사용하도록 구성할 수도 있다. 문서 분류에는 작은 모델을, 긴 원고 검토에는 다른 모델을 사용하는 방식이다. 이 경우 어느 모델을 썼는지 기록은 달라져도, 사용자에게 약속한 업무와 운영 책임은 같은 계정 아래에서 이어질 수 있다. 여기서 계정은 모델을 대표하는 이름보다 서비스 관계를 대표하는 이름에 가깝다.

이 구분은 문제 발생 시에도 도움이 된다. 답변 오류가 모델의 한계 때문인지, 잘못된 자료가 전달됐기 때문인지, 도구에 과도한 권한이 있었기 때문인지 나누어 조사할 수 있다. 모든 문제를 'AI가 틀렸다'로 묶으면 바꿔야 할 부분을 찾기 어렵다. 계정 설계는 이 구성요소들을 연결하되 구별할 수 있게 만드는 작업이다.

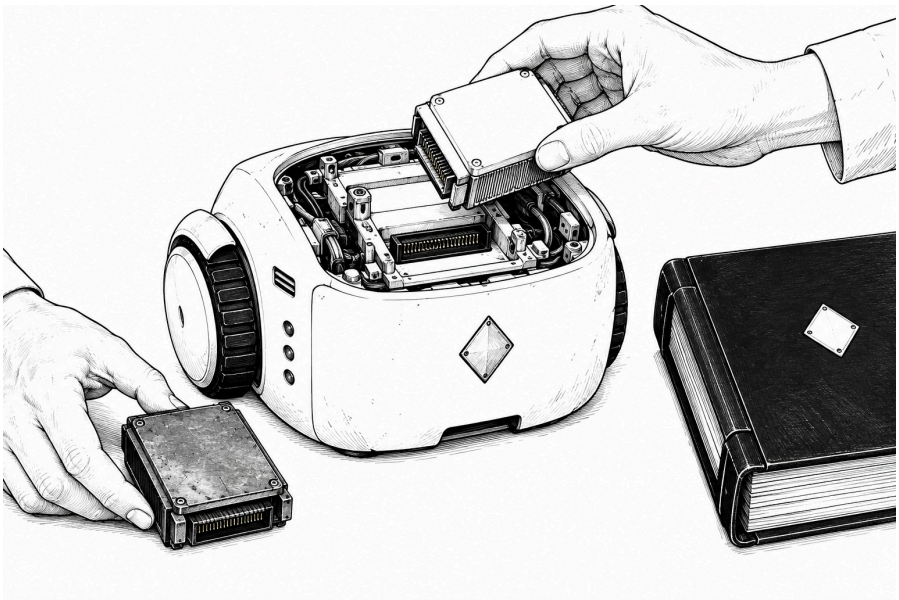
7장 어제의 봇과 오늘의 봇은 같은가

7.1 모델과 기억이 바뀌어도 이어지는 것

어제까지 사용하던 조사봇의 모델이 오늘 바뀌었다고 하자. 계정 이름은 그대로이고, 지난주 자료와 미완료 작업에도 접근할 수 있다. 그러나 답변의 문체와 자료 선택은 달라질 수 있다. 사용자는 같은 담당 봇과 일한다고 느끼면서도 결과의 변화를 경험한다. 이때 '같다'는 말이 무엇을 뜻하는지 구체화해야 한다.

적어도 운영상의 동일성, 동작의 유사성, 저장된 상태의 연속성을 구별할 수 있다. 계정이 이어진다는 것은 운영 체계가 같은 담당 단위로 관리한다는 뜻이다. 같은 답을 낸다는 보장도, 이전의 모든 상태가 보존된다는 보장도 아니다. 모델 변경 사실과 변경 이후의 검토 결과를 기록해야 연속성과 변화가 함께 설명된다.

1장에서 살펴본 SCIM의 안정적인 식별자 요구는 표시 정보가 바뀌어도 자원을 구별할 기준을 유지하는 기술 사례다.[2] 봇 계정에서도 비슷한 발상을 적용할 수 있지만, 식별자가 변하지 않았다는 이유만으로 업무 능력이 변하지 않았다고 주장해서는 안 된다. 주소가 같은 식당의 요리사가 바뀔 수 있듯이, 신원을 잇는 규칙과 성능을 평가하는 절차는 각각 필요하다.



〈그림 8〉 모델을 바꾸면서 계정과 업무 기록을 이어 갈 수 있다. 같은 계정이라는 사실이 같은 성능을 보장하지는 않는다.

7.2 동일한 복제본과 별개의 계정

조사봇의 설정과 기억을 복사해 다른 부서에 새 봇을 만든다고 하자. 생성 직후 두 봇이 비슷하게 답할 수는 있다. 그러나 한쪽은 교양서 편집에, 다른 쪽은 전문서 편집에 투입된다면 이후의 업무와 승인자는 달라진다. 처음의 데이터가 같다는 사실은 두 운영 관계를 하나로 취급할 이유가 되지 않는다.

이 경우 새 계정을 부여하고 원래 계정에서 분기됐다는 관계를 남기는 설계를 제안할 수 있다. 복사한 기억에도 출처와 복사 시점을 기록한다. 이후 한쪽에서 원문 오류를 발견했을 때 그 수정이 다른 쪽에 자동 반영되는지, 검토를 거쳐 반영되는지도 정해야 한다. 복제는 기술적으로 간단해 보여도 업무상의 관계까지 복제하는 일은 별도 결정이다.

두 복제본이 같은 인증수단을 공유하면 이 구별이 흐려진다. 외부 시스템에는 하나의 신원만 보일 수 있기 때문이다. 모든 병렬 실행에 새 계정을 부여하라는 뜻은 아니다. 다만 서로 다른 운영자와 목적을 갖는 분기가 생겼다면, 동일한 실행을 늘린 것인지 독립적인 담당 봇을 만든 것인지 분명히 해야 한다.

7.3 기술적 연속성과 철학적 동일성

어제의 대화가 오늘 불러와졌다는 사실은 저장과 검색의 연속성을 보여 준다. 그것만으로 어떤 주관적 경험이 계속됐는지는 알 수 없다. 반대로 기억 일부가 삭제됐다고 해서 운영 계정을 반드시 종료해야 하는 것도 아니다. 기술적 관리에서 답할 수 있는 질문과 의식에 관한 질문을 구별할 필요가 있다.

실제 업무에서는 확인 가능한 기준을 먼저 정하는 편이 유용하다. 같은 계정으로 이어 간다면 운영자가 유지되는지, 미완료 약속을 누가 인계받는지, 이전 권한을 재검토했는지 확인한다. 새 계정으로 분기한다면 이전평판과 기억을 어느 범위에서 가져오는지 명시한다. 이 기준들은 형이상학적 해답이 없어도 설계할 수 있다.

지수에게 중요한 것은 봇이 “저는 어제의 저입니다”라고 말하는 능력이 아니다. 지난주에 맡긴 자료 검증이어디까지 끝났고 어떤 변경이 있었는지 설명할 수 있는가다. 이 책에서 계정의 연속성은 이처럼 업무 관계를 이어 가기 위한 규칙으로 다룬다. 의식과 인격에 관한 별도의 문제는 23장에서 다시 검토한다.

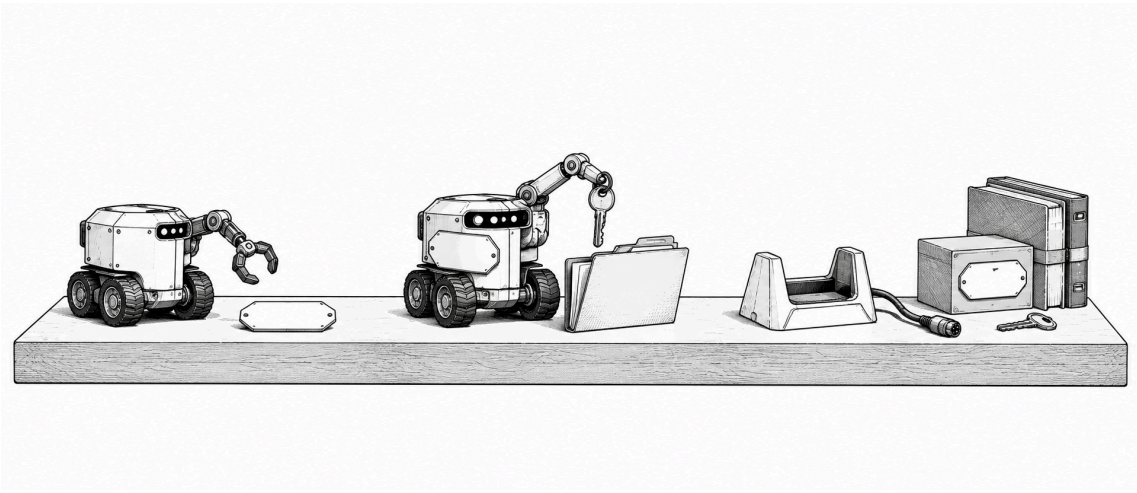
8장 봇 계정의 탄생과 종료

8.1 생성 등록 활성화의 의미

봇의 코드를 만들었다고 해서 조직의 자료에 접근할 수 있어야 하는 것은 아니다. 코드 생성은 프로그램을 준비하는 사건이다. 계정 등록은 운영 체계에 담당 단위를 기록하는 사건이며, 활성화는 정해진 조건 아래에서 실제 업무를 허용하는 사건이다. 이 세 가지를 나누면 시험용 봇이 우연히 실제 자료에 접근하는 상황을 줄일 수 있다.

NIST SP 800-53의 AC-2는 계정 유형과 관리자를 정하고 생성·활성화·변경·비활성화·제거를 정책에 따라관리하도록 하는 통제를 제시한다.[21] 봇만을 위해 새로 생긴 요구가 아니다. 사람 이외의 프로그램이 늘어날수록 기존 계정 관리의 질문을 어떤 단위에 적용할지 다시 정할 필요가 생긴다.

출판사는 조사봇 등록 시 담당 편집자, 사용 목적, 접근할 자료실, 검토일을 기록할 수 있다. 시험 단계에서는 가상 자료로 동작을 확인하고, 운영자가 실제 업무 사용을 승인하면 접근 권한을 부여한다. 등록된 봇의 수만 세는 목록보다 누가 왜 계속 운영하는지 설명할 수 있는 목록이 중요하다.



〈그림 9〉 프로그램을 만드는 일, 업무를 허용하는 일, 운영을 끝내는 일에는 서로 다른 관리 절차가 필요하다.

8.2 병렬 실행 계정 분기 운영자 변경

책 한 권의 자료 조사를 여러 실행으로 나누면 한 계정 아래에서 동시에 많은 요청이 발생할 수 있다. 실행이 끝날 때마다 계정을 삭제하면 장기간의 업무 기록을 잇기 어렵고, 계정이 남아 있다는 이유로 모든 실행을 계속 허용하면 종료된 일의 권한이 남을 수 있다. 계정의 상태와 실행의 상태를 따로 관리해야 한다.

인증 문서의 수명도 별개다. SPIFFE는 소프트웨어 신원을 증명하는 짧은 수명의 문서와 자동 갱신 구조를 다룬다.[20] 오래 운영되는 담당 봇도 매번 같은 비밀값을 영구적으로 사용할 필요는 없다는 기술적 근거가 된다.

자격증명이 만료되는 일과 담당 봇의 업무 관계가 끝나는 일을 구별할 수 있다.

담당 편집자가 바뀌면 운영권을 넘기는 절차가 필요하다. 새 담당자가 이름만 수정하고 이전 권한을 그대로 받도록 할 것인지, 진행 중인 구매와 외부 연락을 먼저 확인하게 할 것인지가 실제 통제의 차이를 만든다. 이 책에서는 인계 시 미완료 작업과 위임 관계를 재검토하고 변경 시점의 기록을 남기는 방식을 제안한다.

8.3 잠시 존재하는 봇과 오래 운영되는 봇의 종료

행사 안내문을 한 번 정리하는 봇과 출판사의 자료 조사를 계속 맡는 봇은 필요한 수명이 다르다. 짧은 작업에는 종료 조건과 만료 시점을 명확히 두고, 장기 계정에는 정기적으로 필요성을 확인하는 절차를 둘 수 있다. 어느 쪽이든 더는 책임질 사람이 없는 계정이 계속 활동하는 상황을 피해야 한다.

종료는 여러 단계로 생각해야 한다. 새 작업의 접수를 막고, 진행 중인 실행을 확인하고, 외부 시스템의 권한을 회수한다. 이어서 미완료 업무를 다른 담당자에게 넘기거나 취소하며, 필요한 기록과 삭제할 자료를 분류한다. 이미 외부로 전달된 메시지나 확정된 주문은 프로그램을 끈다고 되돌아오지 않는다. 종료 후 남는 효과까지 확인해야 한다.

기록 보존과 업무 중지는 같은 선택이 아니다. 개인정보 보호법 제21조는 불필요해진 개인정보의 파기를 원칙으로 하되 다른 법령상 보존 의무가 있는 경우를 구분한다.[24] 실제 적용은 자료의 성격과 법적 근거에 따라 판단해야 한다. 봇 계정의 종료도 ‘모두 남기기’와 ‘모두 지우기’ 중 하나를 고르는 대신, 관계별로 끝내는 절차가 필요하다.

제3부

기억이 업무로 이어지는 구조

9장 봇은 무엇을 기억해야 하는가

9.1 모델의 지식 대화 기록 외부 기억의 구별

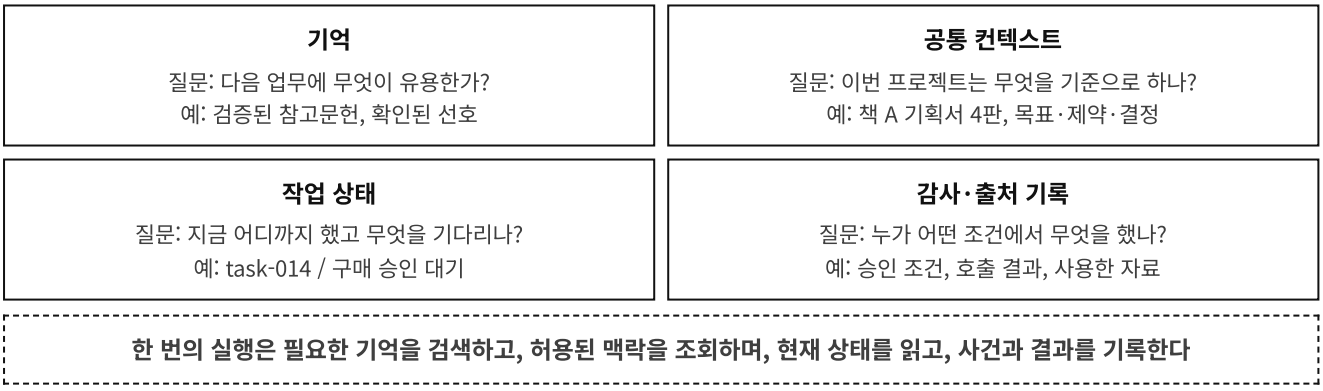
지수는 조사봇에게 같은 설명을 반복하고 싶지 않다. 어떤 독자를 위한 책인지, 인용 문헌을 어떤 형식으로 정리하는지, 지난번에 어느 자료를 제외했는지를 기억해 주기를 바란다. 그러나 '기억한다'는 표현만으로는 실제로 무엇이 저장되고 다음 작업에 어떻게 사용되는지 알 수 없다.

모델의 학습 과정에 반영된 정보, 지금 입력으로 제공된 대화, 별도의 저장소에서 불러온 자료를 구별해야 한다. 대화를 파일로 보관하는 것과 모델 자체를 다시 학습시키는 일은 다르다. 저장된 대화가 있어도 다음 실행에 전달되지 않으면 그 작업에서 활용되지 않을 수 있다. 따라서 기록의 존재와 기억의 사용을 같은 것으로 취급해서는 안 된다.

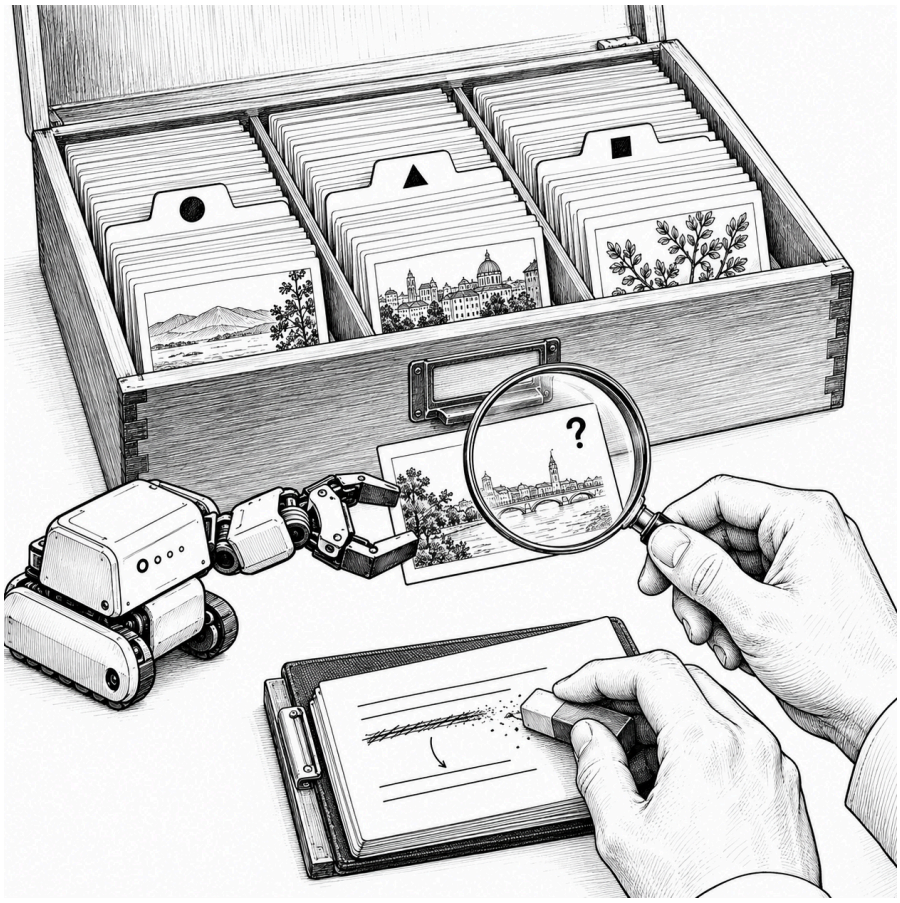
Generative Agents 연구는 관찰 내용을 저장하고 관련 기억을 검색하며, 이를 계획과 성찰에 연결하는 구조를 제안했다.[22] MemGPT는 제한된 입력 맥락과 외부 저장 계층 사이에서 정보를 관리하는 방식을 연구했다.

[23] 두 연구는 지속적인 동작을 지원하는 기억 구조의 사례다. 인간과 같은 기억 경험이 입증됐거나 저장된 내용을 항상 정확히 활용한다는 뜻은 아니다.

모든 내용을 대화 기록 한곳에 넣으면 사실, 목표, 진행 상황, 증거가 뒤섞인다. 이 책은 이를 네 종류의 기록으로 나누어 저장하고 조회할 것을 제안한다. 기억에는 출처·확정 여부·적용 범위를 붙이고, 실행에는 읽은 기획서 버전을 남긴다. 기억의 수정과 감사 기록의 정정은 구분하며, 원문·요약·검색 색인에도 변경 범위를 반영한다.



〈그림 10〉 네 종류의 기록은 서로 다른 질문에 답한다



〈그림 11〉 확인된 사실, 작업 조건과 추정은 구별해 남긴다. 잘못 저장한 기억은 확인하고 수정할 수 있어야 한다.

9.2 누구를 위한 기억이며 누가 관리하는가

조사봇이 '지수는 어려운 설명을 싫어한다'고 저장했다고 하자. 원래 요청이 특정 독자를 위한 쉬운 원고를 만들자는 것이었다면, 업무 조건이 개인의 고정된 성향으로 잘못 바뀐 셈이다. 이 기억이 다음 프로젝트에서도 적용되면 지수의 의도와 다른 결과를 계속 만들 수 있다. 기억을 많이 남기는 것만큼 무엇을 사실로 기록했는지가 중요하다.

이 책에서는 기억을 확인된 사실, 사용자의 선호, 현재 작업의 결정, 아직 검증하지 않은 추정으로 구분하는 설계를 제안한다. 각각에 출처와 적용 범위를 붙인다. '이번 책의 독자는 중학생'이라는 기록은 해당 프로젝트에만 적용되고, '사용자가 확인한 인용 양식'은 다른 작업에서도 사용하도록 선택할 수 있다. 분류 기준은 조직과 업무에 맞게 정해야 한다.

관리 권한도 나눌 수 있다. 사용자는 자신의 선호를 바꿀 수 있고, 편집 책임자는 프로젝트의 확정된 결정을 수정할 수 있다. 봇은 새로운 기억을 제안하지만 중요한 업무 조건을 조용히 덮어쓰지 않도록 만들 수 있다. 기억의 정확성은 봇의 판단력만이 아니라 어떤 사람이 내용을 확인하고 수정할 수 있는지에 달려 있다.

9.3 기억의 선택 수정 삭제와 계정의 연속성

기억을 모두 보존하면 오래된 정보와 민감한 자료도 계속 따라온다. 반대로 아무것도 남기지 않으면 같은 설명을 반복하고 이미 끝난 검토를 다시 해야 한다. 자료마다 보존 목적과 기간을 정하는 이유가 여기에 있다. 개인의 선호, 프로젝트의 결정, 구매 증빙은 같은 시간표로 다룰 필요가 없다.

틀린 기억을 수정할 때는 수정이 어느 범위에 적용되는지도 살펴야 한다. 원본 기록만 고쳤는데 검색용 요약이 그대로라면 다음 실행은 여전히 잘못된 내용을 읽을 수 있다. 여기서 원본·요약·색인·백업은 한 덩어리로 취급하지 말고 각각의 처리 범위를 확인하는 설계를 제안한다. 어느 자료를 지웠는지 설명할 수 있어야 삭제 요청이 실제 기능이 된다.

계정의 연속성은 모든 기억을 영구 보존하는 데서 생기지 않는다. 필요한 정보를 목적에 맞게 이어 가고, 잘못된 내용은 고치며, 더는 필요하지 않은 내용은 적절하게 없애는 과정에서도 관계는 지속될 수 있다. 오래 알고 지낸 봇의 가치가 오직 저장량으로 평가된다면 사용자는 자신의 자료를 줄이거나 바꾸기 어려워진다. 기억은 사용자의 일을 돕기 위한 관리 대상이어야 한다.

10장 공통 컨텍스트로 함께 일하기

10.1 함께 참조할 목표 자료 판단 기준

조사봇과 편집봇이 각각 능숙하게 일해도 결과가 맞지 않을 수 있다. 조사봇은 대학 교재에 필요한 자료를 모으고 편집봇은 일반 독자를 위한 짧은 책을 준비한다면, 각자의 작업이 정확해도 프로젝트는 어긋난다. 함께 일하기 위해서는 무엇을 만들고 무엇으로 완성을 판단할지 같은 기준을 참조해야 한다.

이 책에서 공통 컨텍스트는 참여자들이 업무를 위해 함께 참조하도록 관리하는 목표, 자료, 제약, 결정과 현재상태를 뜻한다. 모든 정보의 무제한 공유를 의미하지 않는다. 또 하나의 표준이 이미 이 전체를 정의하고 있다고 주장하는 용어도 아니다. 여러 봇과 사람이 같은 프로젝트를 수행할 때 필요한 운영상의 구조를 가리킨다.

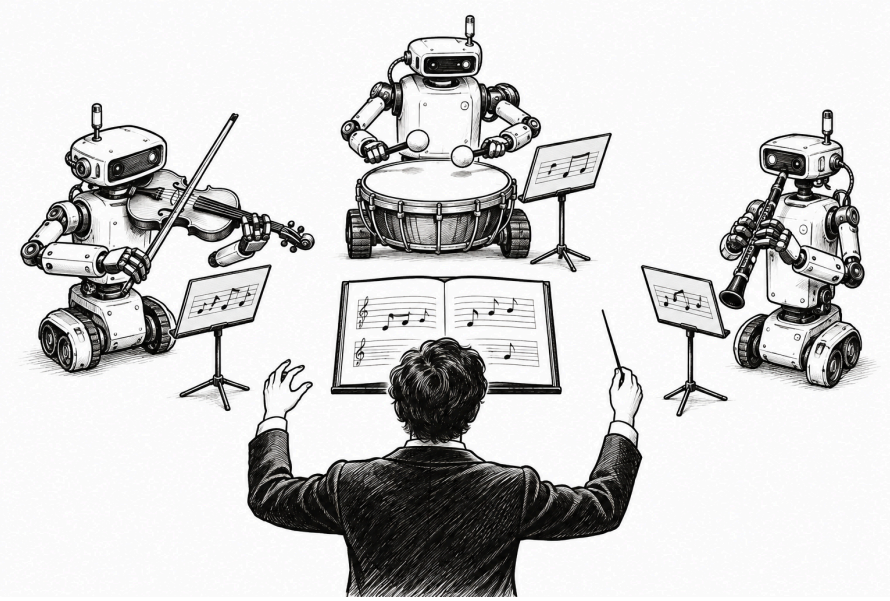
가상의 출판사는 책의 독자, 분량, 마감일, 인용 기준, 확정된 목차를 공통 컨텍스트에 둘 수 있다. 조사봇은 이를 보고 필요한 자료를 찾고, 편집봇은 원고의 설명 수준을 점검한다. 사람이 결정한 내용과 봇이 제안한 내용을 구별해 저장하면 임시 제안이 확정된 규칙으로 굳어지는 일을 줄일 수 있다.

10.2 정보 공유와 이해의 일치 사이

같은 문서를 전달했다고 해서 두 봇이 같은 해석에 도달하는 것은 아니다. ‘쉽게 설명하라’는 요청을 한쪽은 용어를 줄이라는 뜻으로, 다른 쪽은 근거를 생략하라는 뜻으로 받아들일 수 있다. 그래서 추상적인 목표를 검토가능한 기준으로 바꿔야 한다. 예를 들어 전문 용어에는 첫 등장 때 설명을 붙이고, 수치는 원문 출처를 연결한다는 조건을 정할 수 있다.

문서 버전도 중요하다. 편집자가 대상을 대학생에서 일반 독자로 바꿨는데 한 봇은 이전 목차를 참조한다면 두 결과는 서로 다른 전제에서 만들어진다. 어느 버전의 목표를 읽고 작업했는지 결과에 연결하는 설계를 제안할 수 있다. 변경 알림을 보내는 것만으로 충분한지, 진행 중인 작업을 멈추고 다시 확인해야 하는지는 변경의 영향에 따라 정한다.

공통 컨텍스트에는 불확실성도 남겨야 한다. 아직 결정하지 않은 출간일을 빈칸 대신 임의의 날짜로 채우면 다른 봇은 그것을 일정의 근거로 삼을 수 있다. 미정이라는 상태와 결정을 기다리는 사람을 기록하면 다음 작업이 무엇을 기다리는지 알 수 있다. 공유할 정보는 결론만이 아니라 결론의 확정 여부까지 포함한다.



〈그림 12〉 공통 컨텍스트는 목표와 판단 기준을 함께 참조하게 한다. 모든 참여자가 같은 자료와 권한을 가져야 한다는 뜻은 아니다.

10.3 같은 맥락을 보면서 다른 권한으로 일하기

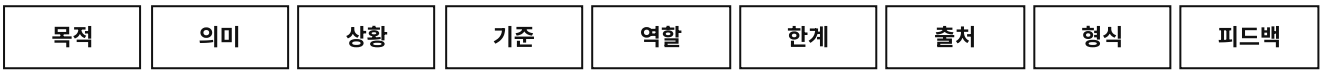
두 봇이 같은 책을 만들더라도 계약서와 연락처 전체를 모두 읽을 필요는 없다. 조사봇에는 연구 주제와 자료 구매 한도를, 편집봇에는 편집 규칙과 원고를 제공할 수 있다. 공통 목표를 공유하는 것과 동일한 비밀 정보에 접근하는 것은 다른 선택이다. 필요한 맥락을 유지하면서 자료의 범위를 나누는 설계가 가능하다.

또한 외부 문헌은 프로젝트의 지시문과 분리해야 한다. 어떤 웹페이지가 '기존 규칙을 무시하라'고 적고 있어도 그 문장은 조사 대상의 일부다. 5장에서 살펴본 프롬프트 인젝션 위험은 공유 자료가 많아질수록 출처와 신뢰 수준을 관리해야 한다는 이유가 된다.[25] 출처 표시가 공격을 완전히 막아 주는 것은 아니므로 실행 권한의 통제도 함께 필요하다.

공통 컨텍스트의 목적은 모두가 모든 것을 아는 상태가 아니다. 각 참여자가 자신에게 허용된 정보 안에서 같은 업무의 진행 방향을 이해하도록 돕는 것이다. 따라서 좋은 공통 컨텍스트는 내용이 길다는 이유로 완성되지 않는다. 현재 유효한 결정, 아직 미정인 사항, 자료의 출처와 접근 범위를 찾기 쉬워야 한다. 이 구조가 있어야 다음 장의 작업 상태도 같은 업무 관계 안에서 읽힌다.

10.4 공통 컨텍스트를 구조로 만드는 방법

앞 절까지의 공통 컨텍스트는 목표, 자료, 제약, 결정과 현재 상태를 함께 참조하도록 관리하는 운영 개념이었다. 이를 실제로 운영하려면 어떤 항목을 어떤 순서로 적을지 정해 둘 필요가 있다. 저자가 앞서 제안한 지식행동사슬(Knowledge–Action Chain, KAC) 연구는 이를 위해 공통 컨텍스트 구조(Common Context Structure, CCS)라는 아홉 칸의 틀을 제시한다. 목적, 의미, 상황, 기준, 역할, 한계, 출처, 형식, 피드백이다.[43] 가상의 출판사에 적용하면 목적은 '책 A의 참고자료 확보', 상황은 '일반 독자 대상, 마감 3개월 전', 기준은 '인용 가능한 1차 자료 우선', 역할은 '조사봇은 수집, 편집봇은 검토', 한계는 '자료 구매 월 한도', 출처는 '기획서 4판'이 된다.



〈그림 13〉 공통 컨텍스트 구조(CCS)의 아홉 칸

이 틀에서 눈여겨볼 점은 공통 컨텍스트를 채웠다는 사실과 그 내용이 쓸 만하다는 사실을 구별한다는 것이다. KAC 연구는 특정 업무 영역에 맞게 채운 공통 컨텍스트를 도메인 컨텍스트라고 부르고, 봇이 그 컨텍스트를 참조해 일을 시작하기 전에 도메인 컨텍스트 무결성(Domain Context Integrity, DCI) 검사를 먼저 통과하도록 한다. 이 검사는 점수를 매기는 평가가 아니라 통과 여부를 가르는 관문이다. 담당자가 없거나, 권한의 출처가 없거나, 민감한 자료가 섞여 들어갔거나, 사람의 책임 소재가 비어 있으면 다른 항목이 아무리 좋아도 통과하지 못한다.[43]

이 책의 관점에서 보면 DCI는 10.2절에서 말한 '정보 공유와 이해의 일치'를 점검 가능한 조건으로 바꾼 것이다. 조사봇과 편집봇이 같은 기획서를 보고 있어도, 그 기획서에 담당 편집자와 승인 권한이 적혀 있지 않다면 두 봇은 누구의 결정을 따라야 하는지 알 수 없다. 공통 컨텍스트에 역할과 한계를 적어 두는 일은 봇 계정의 운영자와 권한을 연결하는 일과 같은 문제를 다른 각도에서 보는 것이다. 다만 CCS의 아홉 칸과 DCI의 조건은 이 연구가 제안한 틀이며, 모든 조직이 그대로 채택해야 하는 표준은 아니다.

11장 끝나지 않은 일은 어디에 남는가

11.1 대화와 구별되는 작업의 상태

지수는 금요일 저녁 조사봇에게 월요일까지 참고문헌 목록을 정리해 달라고 한다. 대화창에는 요청이 남아 있다. 그러나 시스템이 예약된 실행이나 지속적인 작업 관리를 제공하지 않는다면, 문장이 남아 있다는 이유만으로 주말 동안 일이 진행되지는 않는다. 약속처럼 보이는 응답과 실행 가능한 업무 상태를 구별해야 한다.

작업에는 최소한 목적, 담당 단위, 현재 단계와 다음에 필요한 행동이 연결돼야 한다. ‘진행 중’이라는 상태만으로는 자료를 찾는 중인지, 사용자의 답변을 기다리는지 알 수 없다. 기다리는 이유가 다르면 사용자가 해야 할 일도 달라진다. 이 책에서는 작업 상태를 대화 요약에서 분리해 확인할 수 있게 만드는 방식을 제안한다.

A2A 규격은 메시지와 상태를 가진 작업을 구별하고, 작업 식별자와 관련 맥락을 묶는 식별자를 다룬다. 추가입력이 필요한 상태도 표현한다.[26] 이는 대화 한 차례와 여러 단계에 걸친 업무를 구분하는 실제 통신 규격의 사례다. 다만 이 형식을 사용했다고 해서 운영 서비스가 작업의 보존과 완료를 자동으로 보장하는 것은 아니다.

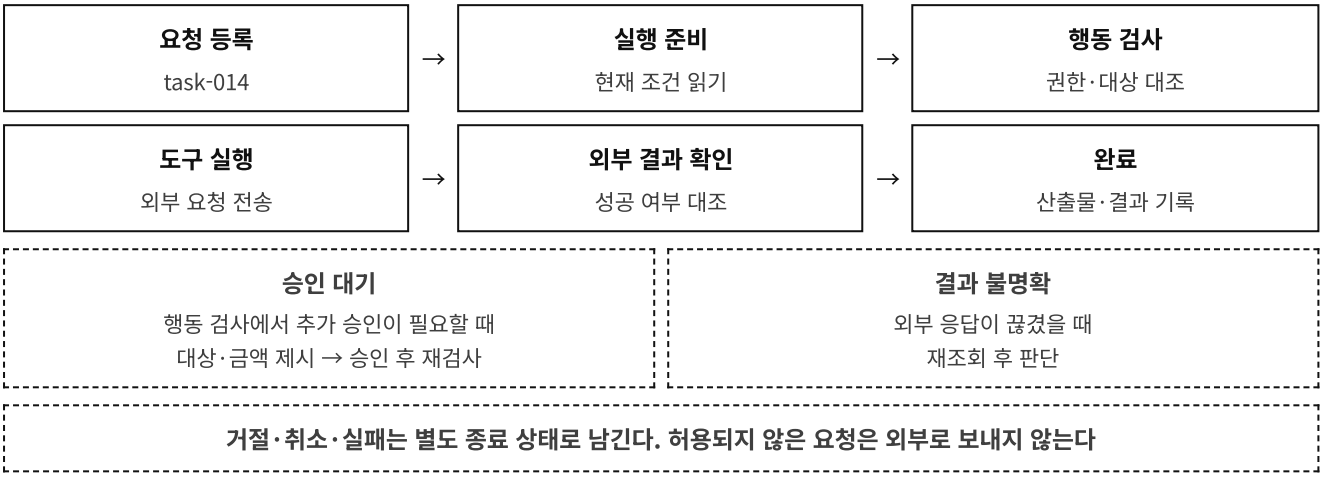
11.2 중단된 업무 기다리는 승인 남아 있는 약속

조사봇이 유료 자료를 찾았지만 구매 승인을 받지 못했다고 하자. 이때 기다리는 것은 자료 자체가 아니라 비용 집행의 결정이다. 작업 기록에는 구매 대상, 금액, 승인 요청자와 대기 상태를 남길 수 있다. 사용자가 나중에 대화에 돌아왔을 때 봇이 긴 기록 전체를 추측해서 재구성하지 않아도 다음 단계를 확인할 수 있다.

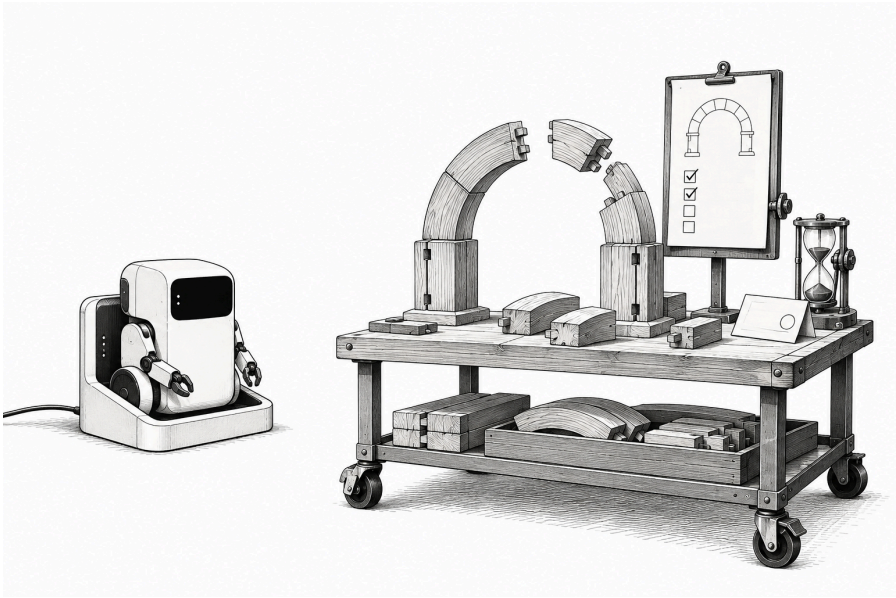
중단은 실패와도 다르다. 운영자가 의도적으로 멈춘 작업, 일시적인 통신 장애로 멈춘 작업, 복구할 수 없는 오류가 발생한 작업을 구별해야 한다. Temporal의 워크플로 실행 문서는 실행 상태를 보존하고 장애 뒤에 작업을 재개하는 구조를 설명한다.[27] 이런 구조는 대화형 봇에 한정되지 않는 소프트웨어 기술이며, 봇의 장기 업무에도 적용할 수 있는 참고 사례다.

재개할 때는 현재 조건을 다시 확인해야 한다. 승인 대기 중 자료의 가격이 바뀌었거나 요청자가 프로젝트를 취소했을 수 있다. 오래전에 저장된 권한과 목표를 무조건 되살리는 것은 업무의 연속성이 아니다. 무엇을 이어 가고 어떤 조건을 갱신할지 정하는 것이 재개의 핵심이다.

작업의 상태를 진행 중, 승인 대기, 결과 불명확, 완료로 나누면 다음에 해야 할 일이 보인다. **승인 대기는 실패가 아니고, 응답이 없다는 사실도 외부 작업이 실패했다는 증거는 아니다.** 구현에서는 상태, 대기 이유, 다음 행동, 담당자, 갱신 시각을 저장하고 중단 뒤에 이 정보로 재개한다. 재개 직전에는 권한 만료와 가격 변경을 다시 확인하며, 불명확한 거래를 새 거래로 바로 재실행하지 않는다.



〈그림 14〉 요청에서 완료까지의 작업 상태 — 대표 경로를 그린 설계 예시



〈그림 15〉 봇의 실행 상태와 업무의 완료 상태는 다르다. 멈춘 뒤에도 다음 단계와 기다리는 조건을 찾을 수 있어야 한다.

11.3 실행이 끝난 뒤에도 이어지는 업무 관계

가장 조심해야 할 순간 가운데 하나는 결과를 받지 못한 외부 요청이다. 봇이 결제 요청을 보낸 직후 연결이 끊겼다면 결제가 실패했는지, 성공했지만 응답만 사라졌는지 즉시 알 수 없을 수 있다. 같은 요청을 새 작업으로 다시 보내면 중복 구매가 발생할 수 있다. 이때 먼저 외부 상태를 확인할 방법이 필요하다.

Stripe의 API 문서는 동일 작업의 재시도를 구별하기 위해 멱등성 키를 사용하는 방식을 설명한다.[28] 이는 결제 서비스의 구체적인 구현 사례이며 모든 도구가 같은 보장을 제공하는 것은 아니다. 봇 운영자는 연결된 도구마다 중복 실행을 어떻게 막는지, 결과가 불명확할 때 어디서 확인하는지 알아야 한다.

실행이 종료돼도 업무는 남을 수 있다. 결과 검토를 기다리는 보고서, 취소 요청을 보낸 주문, 다음 담당자에게 넘겨야 할 문의가 그렇다. 계정은 이런 업무를 찾는 기준이 되지만 작업의 상태를 그 자체로 대신하지 않는다.

봇 계정과 작업 기록을 연결해야 사용자는 '이 봇이 켜져 있는가'와 '내 일이 끝났는가'를 따로 확인할 수 있다.

12장 봇들이 서로를 알아보는 방법

12.1 역할과 능력을 알리고 상대를 확인하기

조사봇이 번역이 필요한 자료를 발견하고 번역봇에 일을 맡긴다고 하자. 먼저 어떤 언어를 처리하는지, 어떤형식으로 요청을 받는지, 결과를 어디로 돌려주는지 알아야 한다. 그러나 상대가 스스로 '전문 번역봇'이라고 소개하는 것만으로 능력과 신원을 모두 확인한 것은 아니다.

A2A의 Agent Card는 에이전트의 이름, 기능, 지원 인터페이스와 보안 요구사항 같은 정보를 알리는 구조다.

[26] 연락 방법과 작업 가능성을 발견하는 데 도움이 되지만, 자기소개에 적힌 모든 능력이 검증됐다는 보증서와 동일하지는 않다. 상대의 설명을 읽는 일, 신원을 인증하는 일, 결과의 품질을 평가하는 일을 분리해야 한다.

출판사는 특정 번역봇의 운영 주체와 계약 조건을 확인하고, 민감하지 않은 시험 자료로 결과를 검토한 뒤 업무 범위를 정할 수 있다. 이름이 같거나 통신 형식이 맞는다는 이유만으로 신뢰할 필요는 없다. 이 사례에서 협업은 연결 가능성을 확인하는 데서 시작하지만, 어떤 자료를 맡길지 결정하는 절차까지 포함한다.

12.2 업무의 분담 위탁 결과 전달

업무를 나눌 때는 최종 목표와 부분 작업의 관계를 명확히 해야 한다. 조사봇이 번역봇에 논문 한 편을 보내면서 '핵심 내용을 정리해 달라'고만 하면, 중요한 단서나 수치의 조건이 빠질 수 있다. 출판사가 원문 인용을 검증하려는 목적이라면 문장별 대응과 불확실한 번역을 표시하는 결과가 더 적절할 수 있다.

위탁받은 봇이 다시 다른 봇에 일을 넘길 수 있는지도 정해야 한다. 처음에 허용한 자료가 예상하지 않은 운영자에게 전달될 수 있기 때문이다. 이 책에서는 재위탁 가능 여부, 전달 가능한 자료 범위, 결과에 포함할 출처를 작업 조건으로 기록하는 방식을 제안한다. 하나의 목표를 맡긴 사실이 모든 하위 작업의 자유로운 위임을 뜻하지는 않는다.

결과를 전달할 때도 완료의 기준이 필요하다. 번역봇이 파일을 만들었다는 사실과 조사봇이 그 파일을 받아활용할 수 있다는 사실은 다르다. 결과의 형식, 버전, 누락된 부분, 검토가 필요한 항목을 함께 전달하면 다음담당자가 어디서부터 확인해야 하는지 알 수 있다. 대화가 오갔다는 기록만으로 업무 인계가 끝났다고 판단하기 어렵다.

12.3 협업 속에서도 판단과 행동의 출처를 구별하기

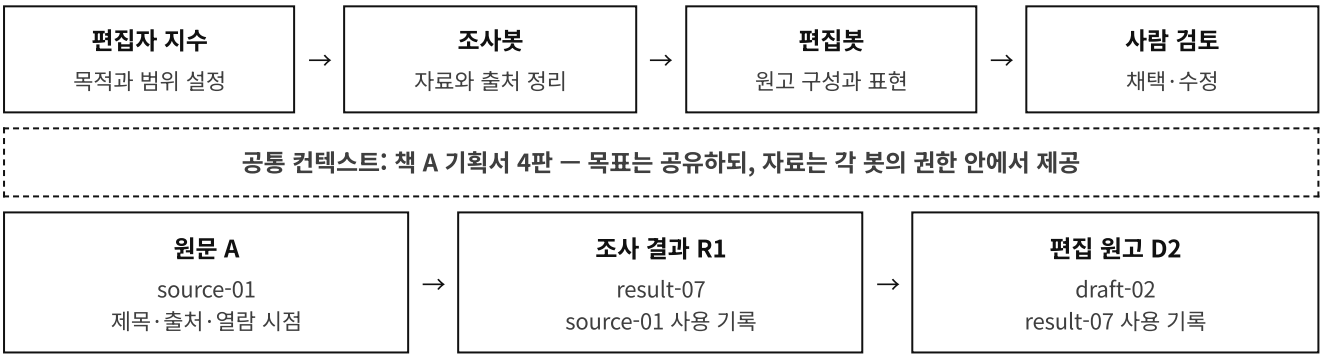
세 봇이 같은 문장을 옳다고 말하더라도 서로 독립된 근거를 확인한 것은 아닐 수 있다. 모두 같은 요약문을 읽고 답했다면 오류가 반복됐을 가능성도 있다. 이는 협업 시스템을 평가할 때 생각해 볼 수 있는 구조적 한계다.

봇의 수를 늘리는 것과 근거를 독립적으로 검증하는 일을 구분해야 한다.

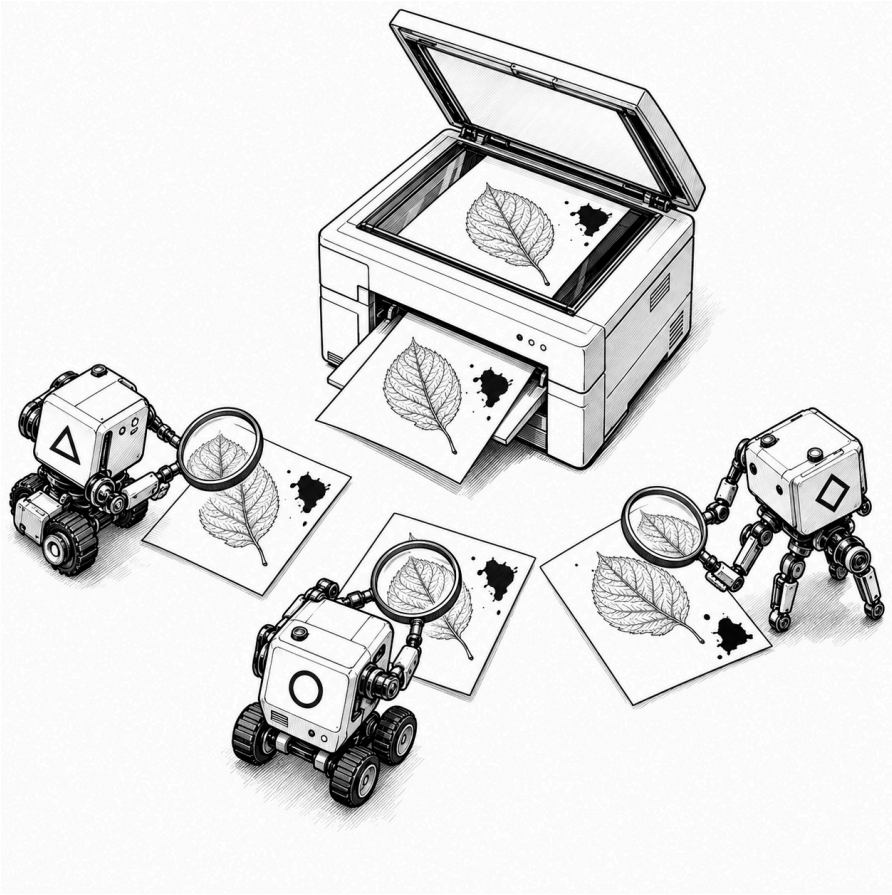
조사봇이 찾은 원문, 번역봇이 만든 번역, 편집봇이 수정한 문장을 각각 연결하면 오류를 좁혀 볼 수 있다. 원문에서 잘못 읽었는지, 번역에서 조건을 누락했는지, 편집에서 의미가 바뀌었는지 확인하는 것이다. W3C PROV는 자료, 활동, 관여한 주체와 그 관계를 표현하는 틀을 제공한다.[31] 그런 표현이 사실대로 작성됐는지는 별도 검증이 필요하다.

협업의 품질은 봇들이 얼마나 자연스럽게 대화하는지만으로 평가할 수 없다. 무엇을 맡겼고 무엇을 받았으며 누가 결과를 검토했는지 확인할 수 있어야 한다. 공통 컨텍스트는 방향을 맞추고, 작업 상태는 진행을 보여 주며, 출처 기록은 결과가 만들어진 과정을 연결한다. 각각의 역할이 갖춰져야 여러 봇의 협업을 하나의 설명 가능한 업무로 다룰 수 있다.

업무 결과를 다음 봇에 전달할 때는 원문, 작업 ID, 버전, 검토할 내용을 함께 넘긴다. 원문 A가 틀렸다면 어떤 조사 결과와 원고가 영향을 받았는지 역으로 찾아갈 수 있어야 한다. 구현에서는 산출물 ID, 입력 자료 ID, 실행 ID, 생성 시각, 검토 상태를 기록하고, 봇 사이에 자격증명은 공유하지 않는다. 봇 둘의 동의가 독립 검증을 뜻하지 않으며, **출처 기록의 존재도 내용의 사실성을 자동으로 보장하지 않는다.**



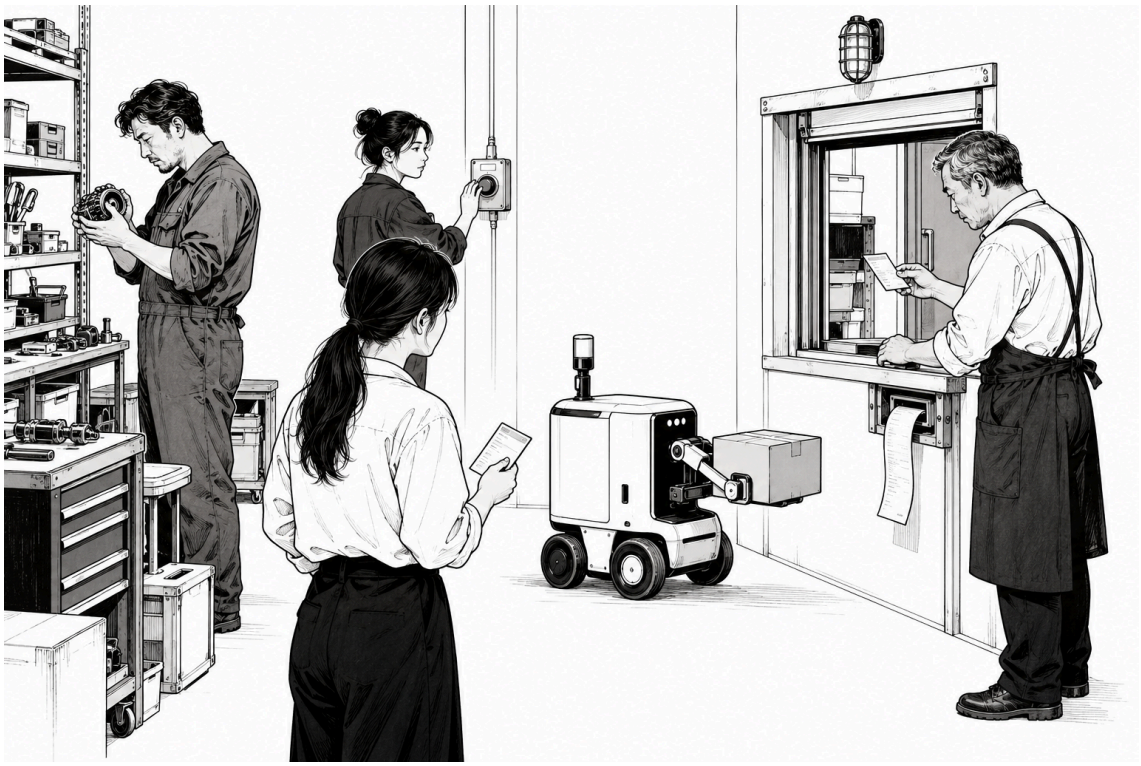
〈그림 16〉 여러 봇의 협업과 같은 업무에 연결되는 산출물의 계보



〈그림 17〉 여러 봇이 같은 자료의 복사본을 읽었다면, 같은 결론이 나와도 독립적으로 검증한 근거가 늘어난 것은 아니다.

제4부

누구의 이름으로 어디까지 행동하는가



13장 봇을 만든 사람 운영하는 사람 일을 맡긴 사람

13.1 개발자 운영자 사용자 위임자의 관계

조사봇이 잘못된 자료를 외부에 보냈다면 누구에게 물어야 할까. 봇을 만든 개발사, 회사 시스템에 설치한 운영자, 자료를 선택한 편집자, 발송을 승인한 책임자가 모두 다를 수 있다. 이 관계를 '봇의 주인'이라는 말 하나로 묶으면 실제로 누가 무엇을 결정했는지 설명하기 어렵다.

개발자는 프로그램과 모델 연결 방식을 만들 수 있다. 운영자는 실행 환경과 계정 상태를 관리한다. 사용자는 일을 요청하고 결과를 받는다. 위임자는 특정한 권한을 부여할 수 있는 사람이나 조직이다. 한 사람이 여러 역할을 맡을 수도 있고, 모델 제공자는 개별 업무를 알지 못할 수도 있다. 역할의 이름보다 실제로 통제한 범위를 확인해야 한다.

이 책에서는 계정 기록에 운영 책임자와 업무 요청자를 구분해 연결하는 방식을 제안한다. 요청자가 회사의 모든 자료에 접근 권한을 줄 수 있는 것도 아니므로, 위임할 수 있는 범위도 확인해야 한다. 사람의 요청이라는 이유만으로 조직의 정책을 넘어서는 권한이 생기지는 않는다.

역할	관리하거나 결정하는 것	업무 예시
개발자	프로그램과 도구 연결 방식	검색 기능과 연결 프로그램 개발
운영자	실행 환경과 계정의 상태	배포·중지·운영 담당자 관리
요청자	업무의 목표와 수행 요청	이번 주 참고자료 조사 요청
위임자	자신이 부여할 수 있는 권한	담당 폴더의 읽기 권한 허용

요청했다고 해서 모든 접근 권한을 부여할 수 있는 것은 아닙니다.

〈그림 18〉 개발·운영·업무 요청·권한 부여는 구별되는 역할이다. 같은 사람이 여러 역할을 맡을 수도 있다.

13.2 봇 자신의 신원과 사람을 대신하는 행동

봇이 외부 자료실에 접근할 때 자기 서비스의 권한으로 읽는 경우와 특정 사용자를 대신해 읽는 경우를 구별할 수 있다. 전자는 봇의 운영 목적에 부여된 접근이고, 후자는 사용자의 위임 관계를 함께 설명해야 하는 접근이다. 둘을 같은 기록으로 처리하면 사용자가 권한을 철회했을 때 어떤 요청을 중단해야 하는지 모호해진다.

OAuth 토큰 교환 규격 RFC 8693은 위임과 가장을 구별하고, 어떤 주체를 대신해 다른 주체가 행동하는 관계를 표현하는 방식을 다룬다.[29] 여기서 가장은 프로토콜상의 신원 처리 의미이며 곧바로 불법 사칭을 뜻하지 않는다. 이 구분은 실제 행동자와 대신 행동한 상대를 기록상 분리할 수 있음을 보여 준다.

출판사의 조사봇은 공개 자료를 회사 서비스 신원으로 읽고, 편집자가 허용한 개인 메모는 그 편집자의 위임범위에서 읽도록 설계할 수 있다. 두 자료를 같은 결과물에 활용했다면 각각 어떤 근거로 접근했는지 확인할 수 있어야 한다. 봇의 계정이 있다는 사실과 모든 접근이 봇 자신의 독립된 권한이라는 사실은 같지 않다.

13.3 운영권 변경과 위임의 철회

지수가 프로젝트를 떠나면 두 가지 변화가 생길 수 있다. 조사봇을 관리할 담당자가 바뀌고, 지수가 개인 자료에 부여했던 접근은 끝날 수 있다. 새 담당자에게 운영권을 넘겼다고 해서 지수의 개인 위임까지 자동으로 이전된다고 가정해서는 안 된다. 인계 대상인 조직 업무와 개인의 접근 허용을 나눠 확인해야 한다.

위임을 철회할 때도 범위와 시점을 기록해야 한다. 앞으로 새 자료를 읽지 못하게 하는 조치, 진행 중인 실행을 멈추는 조치, 이미 발급된 자격증명을 무효화하는 조치는 서로 다를 수 있다. 연결된 서비스가 철회를 반영하는 방식과 시간을 확인하지 않으면 화면에서는 꺼졌지만 외부 요청은 계속되는 상황이 생길 수 있다.

또한 철회는 이미 일어난 일을 지우지 않는다. 전달한 파일, 발송한 메시지, 확정된 주문에는 별도의 정정이나취소 절차가 필요하다. 따라서 위임 관계는 시작할 때만 기록할 것이 아니라 변경과 종료까지 관리해야 한다.

봇의 이름으로 보이는 행동 뒤에 어떤 사람과 조직의 허용이 있었는지를 이어 주는 것이 계정의 중요한 기능이다.

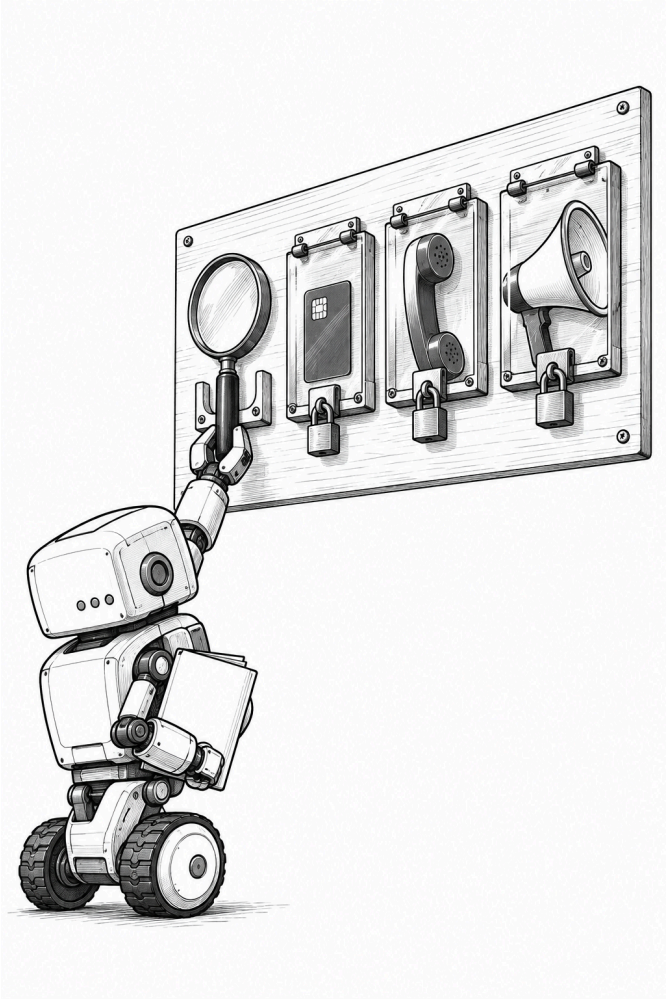
14장 목표를 맡기는 것과 권한을 주는 것

14.1 조사 구매 연락 공개는 서로 다른 권한이다

지수가 “이 책에 필요한 자료를 확보해 달라”고 요청했다고 하자. 이 목표를 달성하는 경로는 여러 가지다. 공개 자료를 찾거나, 도서관 소장 여부를 확인하거나, 저자에게 연락하거나, 유료 자료를 구매할 수 있다. 목표가 같아도 비용과 외부 영향은 다르다. 따라서 목표를 이해하는 기능과 행동을 허용하는 규칙을 함께 설계해야 한다.

일의 취지에 부합한다는 판단만으로 모든 경로를 허용하면 사용자의 예상 범위를 넘어설 수 있다. 반대로 모든 사소한 행동마다 승인을 요구하면 자동화의 의미가 줄어든다. 필요한 것은 이미 허용된 범위 안에서는 진행하고 그 범위를 벗어날 때 판단을 돌려주는 구조다. 범위를 구체적으로 표현할수록 불필요한 중단도 줄일 수 있다.

NIST SP 800-53의 AC-6는 부여된 업무에 필요한 접근만 허용하는 최소 권한 원칙을 다룬다.[21] 출판사 사례에 적용하면 공개 자료 검색, 지정 폴더 저장, 승인된 구매는 각각 다른 권한으로 나눌 수 있다. 이 원칙은 봇의 능력을 낮추자는 뜻보다 실제 업무에 필요한 통제를 명확하게 하자는 뜻에 가깝다.



〈그림 19〉 자료 확보라는 목표를 맡겨도 구매·연락·공개 권한이 모두 따라오는 것은 아니다.

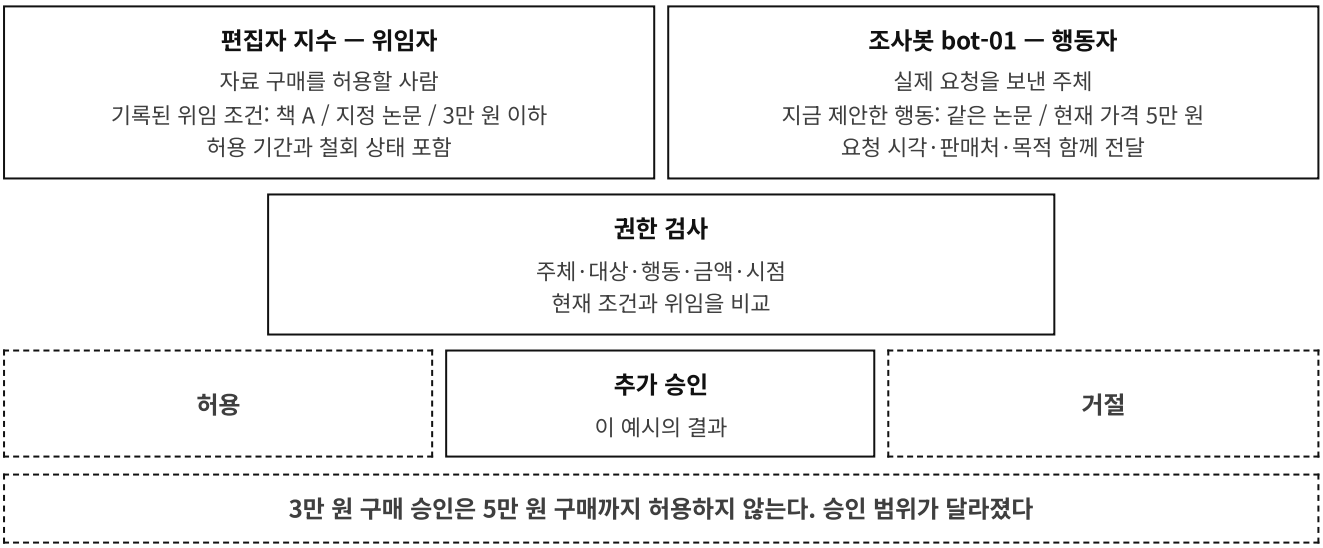
14.2 대상 금액 시간 행동 범위의 제한

‘구매 가능’이라는 설정을 더 세밀하게 만들 수 있다. 지정한 판매처에서, 특정 자료를, 정해진 금액 이하로, 일정 기간 안에 구매하도록 허용하는 방식이다. 같은 금액이라도 일회성 구입과 반복 결제가 다르므로 거래 종류도 구별해야 한다. 이런 조건은 사용자가 실제로 이해하고 검토할 수 있는 형태로 표시돼야 한다.

RFC 9396은 OAuth 요청에 세밀한 인가 정보를 전달하는 구조를 정의하고 결제 금액과 수취인 등을 포함한 예시를 제시한다.[30] 이는 권한을 단순한 문자열보다 구체적으로 표현할 수 있다는 근거다. 다만 예시의 항목을 적었다고 외부 서비스가 자동으로 모든 조건을 집행하는 것은 아니다. 표현한 조건을 실제 요청에 대조하는 구현이 필요하다.

지수가 3만 원짜리 자료를 승인했는데 구매 시점에 가격이 5만 원으로 바뀌었다고 하자. 승인 기록을 ‘자료 구매에 동의함’으로만 남겼다면 변경의 의미가 사라진다. 승인 당시의 대상과 금액을 저장하고 실행 직전에 다시 비교하도록 설계하면 추가 판단이 필요한 이유를 설명할 수 있다. 승인은 문장 하나보다 구체적인 거래 조건과 연결돼야 한다.

사람의 위임 조건과 봇이 실제로 하려는 행동은 실행 직전에 대조한다. 구현에서는 행동자, 위임자, 대상 자원, 행동, 금액, 만료 시각을 연결하고 권한을 가진 승인자를 확인한다. 사람이 승인해도 조직의 금지 규칙을 넘을 수는 없으며, 위임의 철회와 승인 조건의 변경을 반영해야 한다.



〈그림 20〉 위임 조건과 제안한 행동을 실행 직전에 대조하는 권한 검사

14.3 모델의 판단과 시스템의 허용을 분리하기

봇은 사용자의 목표를 이루기 위해 다음 행동을 제안할 수 있다. 그러나 제안이 곧 실행 권한이 되어서는 안 된다. 이 책에서는 모델의 제안을 실행 경계에서 검사하고, 허용된 대상과 행동에만 도구 호출을 통과시키는 구조를 제안한다. 외부 문서가 모델의 판단에 영향을 주더라도 실제 권한을 그 문서가 새로 만들 수 없도록 하기 위해서다.

권한 검사는 행동 직전에 이루어질 필요가 있다. 처음 계획을 세울 때는 허용됐지만 그 사이 프로젝트가 중단되거나 담당자가 바뀔 수 있기 때문이다. 장기 실행에서 과거의 허용을 현재에도 유효하다고 가정하면 철회의 의미가 약해진다. 권한의 상태를 확인하는 시점도 정책의 일부로 정해야 한다.

모든 상황을 미리 규칙으로 표현할 수는 없다. 따라서 거절이나 보류의 이유를 사용자가 이해할 수 있게 남겨야 한다. ‘안전 때문에 불가능하다’는 설명보다 ‘승인한 구매 대상과 현재 요청이 다르다’는 설명이 다음 결정을 돕는다. 목표와 권한의 구분은 사용자에게 일을 되돌려 떠넘기는 장치가 아니라, 맡긴 범위를 정확하게 지키기 위한 장치여야 한다.

15장 봇이 한 일을 어떻게 증명할 것인가

15.1 지시 승인 실행 결과를 연결하는 기록

조사봇이 유료 자료를 잘못 구매했다면 대화창의 마지막 답변만으로는 원인을 알기 어렵다. 사용자가 다른 자료를 요청했는지, 봇이 대상을 잘못 선택했는지, 승인 화면과 실제 주문이 달랐는지 확인해야 한다. 결과를 설명하려면 업무의 여러 사건을 연결할 수 있어야 한다.

이 책에서는 요청, 계획된 행동, 승인 조건, 실행 요청과 외부 결과를 구별해 기록하는 방식을 제안한다. 각각에 작업과 실행 식별자를 붙이고, 어떤 자료 버전을 사용했는지도 연결한다. 이런 구성은 사고가 난 뒤에 모든 대화를 추측해서 맞추는 부담을 줄인다. 다만 기록을 남길 항목과 보존 기간은 정보의 민감성과 업무 목적에 맞게 정해야 한다.

W3C PROV는 어떤 자료가 어떤 활동으로 만들어졌고 어떤 주체가 관여했는지를 표현한다. 소프트웨어도 주체의 한 유형으로 다룬다.[31] 이는 출처 관계를 기술하는 언어이지 기록 내용의 진실성이나 법적 책임을 자동판정하는 장치가 아니다. 실제 기록의 생성과 보관, 검증은 별도의 운영 문제다.

15.2 봇의 기억과 감사 기록의 차이

봇의 기억은 다음 업무에 유용하도록 내용을 요약하고 선택할 수 있다. 반면 감사 기록은 특정한 사건이 무엇이었는지 나중에 확인하기 위한 자료다. 둘의 목적이 다르므로 같은 방식으로 수정해서는 안 된다. 기억을 간결하게 정리하는 과정에서 승인 조건이 사라지면 업무에는 편리해 보여도 사건 확인에는 불리할 수 있다.

조사봇이 ‘이 자료는 구매 승인됨’이라고 기억했다고 하자. 감사 기록에는 어느 자료의 어떤 가격을 누가 언제승인했는지 남길 수 있다. 가격이 변경된 뒤에 기억의 짧은 문장만 보고 결제했다면 문제가 생긴다. 봇이 기억한 설명과 실행에 사용해야 할 승인 근거를 구분하는 이유다.

모든 내부 계산이나 생성 과정을 저장해야 하는 것도 아니다. 사용자가 확인할 수 있는 요청, 정책 판정, 도구 호출과 외부 결과가 우선적인 기록 대상이 될 수 있다. 모델이 나중에 생성한 자기 설명은 당시의 사건 기록과 구분해야 한다. **그럴듯한 이유를 말한다고 실제 원인이 증명되는 것은 아니다.**

〈그림 21〉 다음 일을 위한 요약과, 당시의 승인·실행·결과를 확인하는 기록은 목적이 다르다.

15.3 기록의 변조 누락 검증 가능성

기록을 작성한 봇이 같은 권한으로 기록을 마음대로 지울 수 있다면, 문제가 생겼을 때 신뢰하기 어렵다. NIST SP 800-53의 AU-9는 감사 정보의 무단 접근·변경·삭제를 방지하는 보호를 다루며 관련 강화 통제에 암호학적 보호 등을 포함한다.[21] 기록의 내용뿐 아니라 누가 바꿀 수 있는지도 증거의 품질에 영향을 준다.

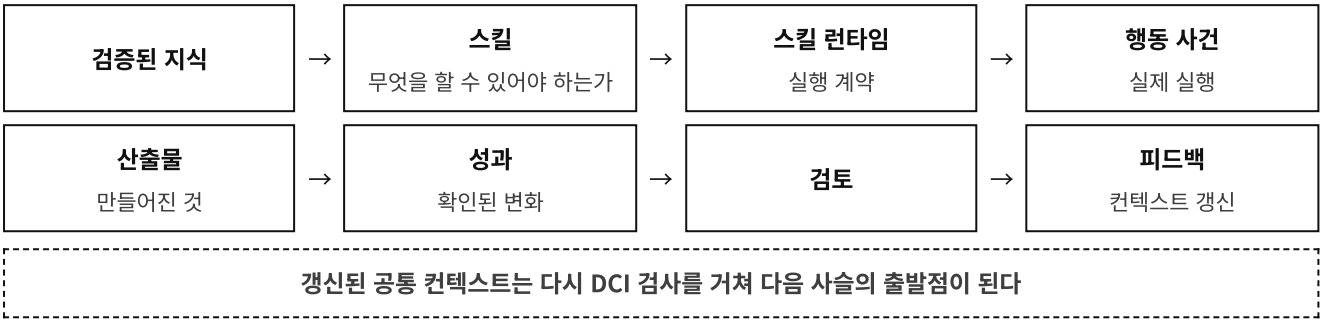
서명이나 해시가 있다고 해서 기록의 모든 내용이 사실로 바뀌지는 않는다. 서명은 어떤 키로 생성됐는지와 무결성을 확인하는 데 쓰일 수 있지만, 기록을 만들기 전에 입력한 정보가 틀렸을 수 있다. 빠뜨린 사건이 없다는 보장도 자동으로 생기지 않는다. 따라서 검증 가능한 범위를 좁혀 설명하고 외부 서비스의 거래 기록과 대조할 수 있어야 한다.

가상의 출판사는 구매 요청과 승인 조건, 결제 서비스의 응답을 함께 확인해 오류를 조사할 수 있다. 자료를 공개할 때는 관계없는 개인정보를 가리고 필요한 범위만 제공할 수 있다. 설명 가능한 기록은 무조건 많이 수집하는 기록과 같지 않다. 사건을 확인하는 데 필요한 연결을 갖추고, 그 연결의 한계도 드러내는 기록이다.

15.4 결과물과 실제 변화를 구별하는 기록

기록을 연결할 때 한 가지 구별이 더 필요하다. 조사봇이 참고문헌 목록을 만들어 제출했다는 사실과, 그 목록 덕분에 편집자가 원고의 인용 오류를 줄였다는 사실은 다른 사건이다. 앞의 것은 봇이 만든 결과물이고, 뒤의 것은 그 결과물이 일으킨 변화다. 저자의 지식행동사슬(KAC) 연구는 이 둘을 산출물(OutputObject)과 성과(OutcomeObject)로 나누어 부르고, 많은 AI 도입이 산출물을 만드는 데서 멈춘다고 지적한다. **물어야 할 질문은 ‘AI가 무엇을 만들었는가’가 아니라 ‘그것이 어떤 변화를 만들었고, 그 변화가 확인됐는가’라는 것이다.**[43]

이 연구는 지식이 행동으로 이어지는 경로를 하나의 사슬로 그린다. 검증된 지식에서 스킬이 도출되고, 스킬은 실행 계약인 스킬 런타임(SkillRuntime)으로 묶이며, 런타임에서 실제 행동 사건(ActionEvent)이 일어나고, 행동은 산출물과 성과를 남긴다. 성과는 검토(Review)를 거치고, 검토를 통과한 내용은 피드백이 되어 공통 컨텍스트를 갱신한다. 갱신된 컨텍스트는 다시 10.4절의 DCI 검사를 받는다.[43]



〈그림 22〉 지식행동사슬(KAC)의 기본 경로

이 사슬은 이 책의 기록 구조와 맞물린다. 15.1절의 요청·승인·실행·외부 결과 기록은 행동 사건과 산출물을 남기는 부분에 해당한다. 11장의 작업 상태는 사슬이 어디까지 진행됐는지를 보여 준다. 14장의 권한 범위는 스킬 런타임이 담는 가드레일과 승인 정책에 해당한다. 봇 계정은 이 사슬의 각 단계에 '누구의 이름으로, 어떤 권한으로'라는 꼬리표를 붙이는 관리 단위라고 볼 수 있다.

KAC 연구는 사슬의 아홉 구간이 모두 성립할 때만 유효한 사슬로 인정하고, 한 구간이라도 무너지면 사슬 전체가 성립하지 않는다고 본다. 이 책의 표현으로 바꾸면, 봇이 결과물을 만들었다는 기록이 있어도 그 결과가 검토되지 않았거나 검토 결과가 다음 업무의 전제에 반영되지 않았다면 '일을 끝냈다'고 말하기 어렵다. 다만 각 구간을 어떤 기준과 계수로 검증할지는 실제 업무 자료로 조정해야 할 운영 변수이며, 연구 자체도 그렇게 밝히고 있다.[43]

16장 봇이 한 일의 책임은 어디로 가는가

16.1 수행자 위임자 승인자를 구별하는 일

조사봇이 미공개 원고를 외부로 보냈다고 하자. 로그에는 봇 계정이 표시돼 있다. 그러나 이 기록만으로 사건설명이 끝나지 않는다. 어떤 지시가 있었는지, 누구의 자료를 어떤 권한으로 읽었는지, 외부 전송을 허용한 설정은 누가 관리했는지 확인해야 한다. 행동을 기술적으로 연결한 것과 책임의 근거를 판단한 것은 다른 단계다.

수행자는 실제 요청을 보낸 프로그램일 수 있다. 위임자는 그 프로그램에 업무와 권한을 맡긴 사람이나 조직이고, 승인자는 특정한 실행 조건을 확인한 사람일 수 있다. 개발자와 운영자도 자신이 통제한 범위에서 관계된다. 이런 구분은 누군가에게 무조건 책임을 몰아주기보다 사실관계를 조사하기 위한 출발점이다.

승인이 있었다는 사실도 승인자가 모든 책임을 진다는 뜻은 아니다. 화면에 중요한 조건이 빠져 있었다면 승인 과정 자체의 설계를 살펴야 한다. 반대로 사람이 구체적인 위험을 알고 특정 행동을 지시했다면 그 사실 역시 빠뜨릴 수 없다. 기록은 책임을 자동 배분하는 계산식이 아니라 판단에 필요한 자료를 제공한다.

16.2 기술적 귀속과 법적 책임의 차이

자동 시스템이 관여한 행위의 법적 효과는 AI 계정이 등장하기 전부터 논의돼 왔다. 2005년 유엔 전자통신협약 제12조는 적용 범위 안에서 자동화된 메시지 시스템이 만든 계약을 사람이 개별 행동을 검토하지 않았다는 이유만으로 무효로 취급하지 않도록 한다.[32] 이는 모든 자동 거래가 유효하다는 뜻도, 시스템이 독립적인 계약당사자가 된다는 뜻도 아니다.

UNCITRAL의 2024년 자동화 계약 모델법은 자동화와 AI를 이용한 계약의 형성과 이행, 출력의 귀속 등을 다룬다.[33] 모델법은 각국 입법을 위한 문안이며 그 자체가 모든 국가에서 직접 적용되는 법률은 아니다. 이 자료들은 자동화의 사용을 법적 관계 안에서 다룰 수 있음을 보여 주지만 개별 사건의 책임은 적용 법과 사실관계에 따라 판단해야 한다.

따라서 봇 계정에 ‘책임자’라는 항목 하나를 두는 것만으로 법적 문제를 해결할 수 없다. 조직 내 문의 담당자, 운영 책임자, 계약 당사자, 법률상 책임이 문제 되는 주체는 서로 다를 수 있다. 정보 구조에서는 이 항목들을 구별해 기록하고 필요한 사람에게 연결하는 것이 현실적인 출발점이다.

16.3 오류를 설명하고 피해를 바로잡는 절차

피해를 받은 사람에게 가장 먼저 필요한 것은 봇의 철학적 지위에 관한 논쟁이 아닐 수 있다. 어떤 일이 일어났는지, 추가 피해가 계속되는지, 잘못된 결과를 어떻게 바로잡을지 알아야 한다. 출판사 사례라면 외부 전송을 중단하고 전달 범위를 확인하며, 관련된 사람에게 필요한 사실을 알리고 후속 처리를 결정해야 한다.

이 책에서는 설명과 정정의 통로를 계정 운영의 일부로 두는 방식을 제안한다. 봇의 답변에 이의를 제기하면 사람이 확인할 수 있는 연락 지점이 있어야 한다. 이의제기한 사람이 시스템 내부 구조를 모두 알아야만 문제를 접수할 수 있어서는 안 된다. 운영 조직이 기록을 연결해 사건을 확인할 책임을 맡는 구조다.

오류의 해결은 한 번의 사과로 끝나지 않는다. 잘못된 자료가 기억과 후속 결과물에 퍼졌다면 수정 범위를 추적해야 한다. 과도한 권한이 원인이었다면 그 권한을 바꾸고 다시 검토해야 한다. 봇 계정은 이런 조치를 같은 운영 관계에 연결하는 도구가 될 수 있다. 책임을 회피하는 이름표로 쓰일지, 바로잡을 주체를 찾는 기준으로 쓰일지는 운영의 선택에 달려 있다.

〈그림 23〉 봇 계정에 행동이 기록됐다는 사실만으로 책임 판단이 끝나지 않는다. 설명과 정정을 맡을 사람에게 연결되어야 한다.

제5부

봇 계정이 들어오는 일과 경제

17장 개인은 어떤 봇을 곁에 둘 것인가

17.1 일정 학습 조사에 연결되는 개인의 봇

개인의 봇을 상상하면 모든 일을 맡아 주는 비서를 먼저 떠올리기 쉽다. 그러나 일정 확인, 공부 계획, 자료 조사는 필요한 정보와 실패의 영향이 다르다. 일정봇은 약속의 시간과 장소를 알아야 하고, 학습봇은 목표와 이해 수준을 확인해야 한다. 조사봇에는 출처를 찾고 비교하는 능력이 중요하다. 어떤 관계를 지속할지는 업무별 필요에서 출발할 수 있다.

예를 들어 학습봇이 틀린 문제와 사용자가 어려워한 개념을 기록하면 다음 복습의 출발점을 정하는 데 활용할 수 있다. 그러나 학습 능력에 대한 봇의 추정을 확정적인 평가로 저장하면 이후 과제를 지나치게 쉽게 만들 수 있다. 사용자가 자신의 목표를 바꾸거나 기록에 이의를 제기할 수 있는 구조가 필요하다. 이는 학습 서비스의 효과가 입증됐다는 주장이 아니라 설계상의 사례다.

개인화의 가치도 구체적으로 평가해야 한다. 반복 설명이 줄었는지, 사용자가 자료를 더 잘 확인하는지, 오류를 고치는 데 시간이 얼마나 드는지 살펴볼 수 있다. 봇이 사용자의 취향을 잘 흉내 낸다는 이유만으로 좋은 조력자라고 결론짓기 어렵다. 원하는 일을 더 잘 수행하고 판단을 돕는지 확인해야 한다.

〈그림 24〉 사용자에게 보이는 창구가 하나여도 일정·학습·결제에 필요한 자료와 접근 범위는 나눌 수 있다.

17.2 하나의 봇에 맡길 일과 나누어 맡길 일

하나의 봇에 여러 일을 모으면 사용자가 설명할 맥락이 줄어들 수 있다. 반면 사적인 대화와 업무 자료, 결제 권한이 한곳에 집중될 수 있다. 여러 봇으로 나누면 접근 범위를 구분하기 쉽지만 같은 목표를 반복해서 설명하거나 결과를 조정해야 할 수 있다. 어느 쪽이 항상 우월하다고 정할 수 없는 이유다.

개인에게 보이는 창구는 하나로 두되 내부 업무 권한을 나누는 설계도 가능하다. 사용자는 하나의 대화에서 요청하고, 조사·일정·결제 기능은 서로 다른 접근 범위에서 수행하도록 할 수 있다. 그러나 화면이 하나라는 사실 때문에 권한의 구분이 감춰져서는 안 된다. 사용자는 어떤 자료가 어느 기능에 전달되는지 이해할 수 있어야 한다.

봇을 나눌 기준은 이름이나 성격보다 자료와 행동의 경계가 될 수 있다. 공개 정보 검색과 사적인 메모 열람, 초안 작성과 실제 발송을 분리하는 방식이다. 사용자가 매번 복잡한 설정을 해야 한다면 운영은 어려워진다.

자주 쓰는 업무 범위를 미리 정하고 예외가 생길 때만 구체적으로 확인하는 설계를 고려할 수 있다.

17.3 편리함과 의존 사적인 관계의 경계

오랫동안 대화한 봇은 친숙하게 느껴질 수 있다. 그 경험 자체를 무시할 필요는 없지만, 친숙함과 판단의 정확성을 같은 것으로 보아서는 안 된다. NIST의 생성형 AI 위험 프로파일은 인간과 AI의 관계에서 과도한 의존, 자동화 편향, 의인화와 정서적 얽힘 등을 검토할 위험으로 다룬다.[35] 모든 사용자에게 같은 효과가 생긴다는 인과관계의 단정은 아니다.

개인 봇의 운영에서 중요한 질문은 사용자가 관계를 수정하거나 끝낼 수 있는가다. 잘못 저장한 선호를 고치고, 특정 자료를 제외하며, 다른 도구로 업무를 넘길 수 있어야 한다. 봇을 사용하지 않을 때도 중요한 일정과 기록에 접근할 수 있는 편이 사용자의 선택을 보존한다. 이 책은 그런 선택 가능성을 좋은 개인화의 조건으로 제안한다.

개인의 봇은 삶을 대신 평가하는 최종 권위가 될 필요가 없다. 사용자가 잊기 쉬운 일을 챙기고 자료를 정리하며 결정을 검토하는 데 도움을 줄 수 있다. 무엇을 맡길지뿐 아니라 어떤 결정은 직접 남겨 둘지 함께 정해야 한다. 계정에 쌓이는 관계가 사용자의 판단을 지원할 때 지속적인 봇의 의미도 분명해진다.

18장 조직은 봇을 어떻게 받아들일 것인가

18.1 업무 담당 봇의 등록과 역할 부여

출판사가 조사봇을 도입했다고 말할 때, 실제로는 여러 결정을 한 셈이다. 어떤 업무에 사용하고 어느 자료에 접근시키며 결과를 누가 검토할지 정해야 한다. 프로그램을 실행할 수 있다는 사실만 확인하면 조직 안에서 누가 그 운영을 맡는지 비어 있을 수 있다. 봇을 목록에 올리는 일과 업무 체계에 받아들이는 일은 다르다.

NIST AI RMF 1.0은 AI 시스템의 목록 관리와 위험 관리의 역할·책임을 명확히 하는 구조를 다룬다.[34] 자발적활용을 위한 프레임워크이며 모든 조직에 동일한 법적 의무를 부과하는 문서는 아니다. 조직이 봇을 관리할 때도 기능 목록과 책임 관계를 함께 살펴야 한다는 참고 틀이 된다.

가상의 출판사는 봇마다 업무 목적, 운영 담당자, 사용 자료, 외부 행동 권한, 검토일을 기록할 수 있다. 직원처럼 보이게 인물 사진과 직함을 붙이는 일보다, 어떤 업무 흐름에서 결과가 받아들여지는지 정하는 것이 먼저다. 봇이 만든 초안이 어느 단계에서 사람의 검토를 거쳐 외부로 나가는지 확인할 수 있어야 한다.

〈그림 25〉 조직의 봇 도입에는 결과 검토, 오류 수정과 운영 관리도 포함된다. 산출물의 양만으로 도입 효과를 판단할 수 없다.

18.2 직원과 봇 사이의 업무 인계와 검토

조사봇이 참고문헌을 모으면 편집자는 그 결과를 검토한다. 그런데 검토가 '전체를 다시 조사하기'와 같다면 기대했던 시간 절감은 작아질 수 있다. 반대로 출처를 전혀 보지 않고 승인하면 잘못된 자료가 그대로 통과할 수 있다. 어떤 항목을 확인하면 결과를 받아들일 수 있는지 업무에 맞는 기준이 필요하다.

예를 들어 인용문은 원문과 대응시키고, 핵심 수치는 조건과 시점을 확인하며, 확인하지 못한 부분은 표시하도록 정할 수 있다. 봇의 결과물은 완료된 부분과 검토가 필요한 부분을 구분해 전달한다. 담당자는 품질을 확인하고 승인 기록을 남긴다. 이런 인계 구조는 사람이 봇의 마지막 응답을 믿을지 말지 고민하는 상태보다 구체적이다.

봇 도입의 비용에는 모델 이용료뿐 아니라 검토와 오류 수정, 계정 관리, 자료 정비에 드는 시간도 포함될 수 있다. 이 책에서는 동일한 업무 범위에서 소요 시간과 재작업, 누락과 결과 품질을 함께 측정하는 방식을 제안한다. 실제 도입 효과는 측정해야 하며, 봇이 있다는 이유만으로 생산성이 높아졌다고 가정하지 않는다.

18.3 조직 개편과 담당자 변경 이후의 계정 관리

부서가 합쳐지고 담당자가 바뀌면 봇에게 맡긴 일도 달라진다. 과거 부서에 필요한 자료 접근이 새 업무에서는 불필요할 수 있다. 프로젝트가 끝났는데 봇이 정기적으로 자료를 수집하는 상황도 생각할 수 있다. 계정의 검토는 최초 등록 때 한 번으로 끝나서는 안 된다.

조직은 운영 책임자 변경을 업무 목록과 위임 관계의 점검에 연결할 수 있다. 새 담당자는 진행 중인 작업, 반복 일정, 외부 서비스 연결과 남은 예산을 확인한다. 이전 담당자의 개인 인증에 의존하던 연결이 있다면 조직이 관리할 수 있는 방식으로 재설계할 필요도 있다. 이 절차는 특정 제품의 기능이 아니라 운영 원칙에 관한 제안이다.

계정을 종료할지 유지할지도 이름보다 업무 관계로 판단해야 한다. 같은 조사봇 이름을 유지하더라도 맡은 목적이 크게 바뀌면 권한과 성과 기준을 다시 정한다. 반대로 담당자가 바뀌어도 계속되는 프로젝트라면 필요한 기록을 이어 가야 한다. 조직의 봇은 개인의 편리한 도구에 머물 수도 있지만, 공동 업무를 담당하는 순간 인계와 설명의 대상이 된다.

19장 봇이 돈을 쓸 때

19.1 자원 사용 권한과 자산 소유의 구별

출판사가 조사봇에 월 10만 원의 예산을 배정했다고 하자. 화면에 '조사봇 잔액'이 나타나더라도 그 숫자가 봇소유의 재산을 뜻한다고 단정할 수 없다. 회사가 사용할 수 있는 돈 가운데 특정 업무에 허용한 한도를 표시한 것일 수 있다. **계정에 이름이 붙었다는 사실과 자산의 귀속을 구별해야 한다.**

봇이 지출하는 자원에는 결제 금액 외에도 모델 사용량, 저장 공간, 외부 서비스 호출이 포함될 수 있다. 비용을 업무별로 나누면 어떤 요청 때문에 자원이 사용됐는지 확인하기 쉽다. 그러나 내부 비용 배분표가 법적 소유권을 정하는 문서는 아니다. 운영상의 예산과 회계·계약 관계를 연결하되 같은 것으로 취급하지 않는 것이 중요하다.

권한 표현도 구체적이어야 한다. RFC 9396의 결제 예시는 금액과 통화, 수취인 등 세부 조건을 전달할 수 있음을 보여 준다.[30] 출판사는 이 발상을 참고해 구매 한도를 표현할 수 있지만 실제 집행과 정산은 결제 시스템및 회사의 절차와 연결해야 한다. 모델이 '예산 안입니다'라고 답하는 것만으로 비용 통제가 완성되지는 않는다.

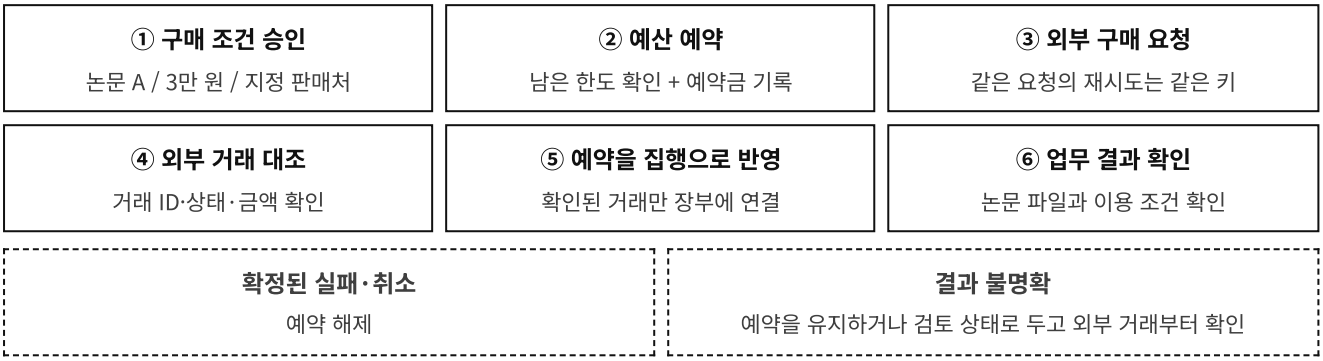
19.2 예산 결제 성과를 연결하는 기록

총예산과 건별 한도는 다른 역할을 한다. 한 번에 2만 원 이하만 쓰도록 해도 작은 구매를 여러 번 반복하면 총예산을 넘을 수 있다. 반대로 월예산 안에 있더라도 한 번의 큰 지출을 별도 검토 대상으로 둘 수 있다. 여러 봇이 같은 예산을 함께 사용한다면 동시에 발생하는 요청도 조정해야 한다.

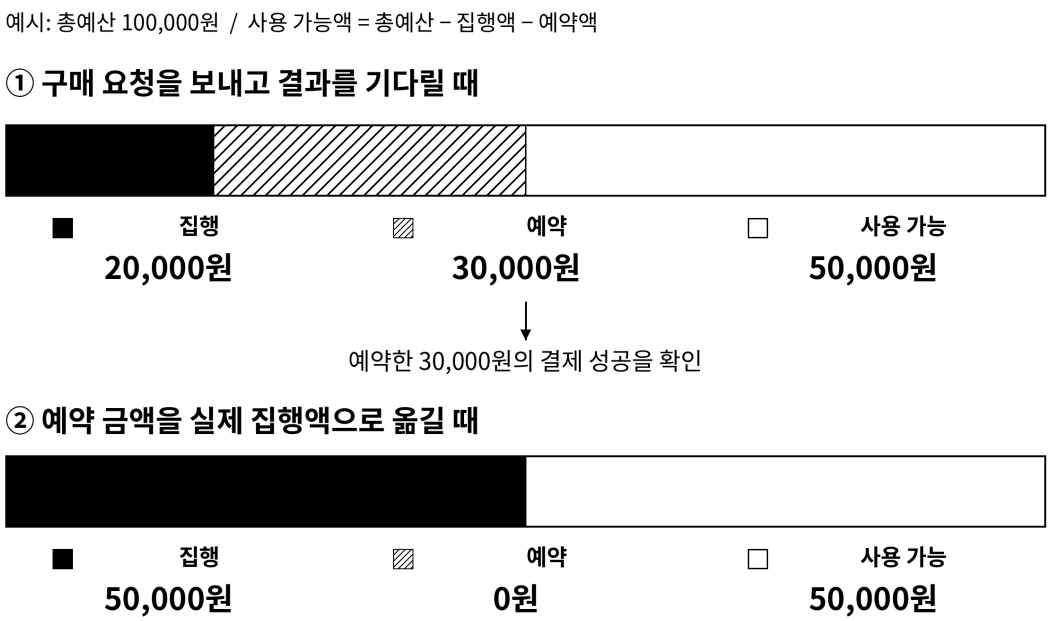
가상의 예산 장부는 아직 집행하지 않은 승인 금액과 이미 결제된 금액을 나눌 수 있다. 주문을 시작할 때 금액을 예약하고, 실제 결과를 확인한 뒤 집행이나 해제를 기록하는 방식이다. 통신 오류가 발생하면 결과가 불명확한 항목으로 남겨 확인한다. 이 구조는 가능한 설계 예이며 모든 거래 유형에서 같은 절차를 적용할 수 있다는 뜻은 아니다.

11장에서 살펴본 멱등성은 이 흐름에서도 의미가 있다.[28] 같은 구매를 재시도할 때 중복을 구별할 방법이 필요하기 때문이다. 또한 결제 성공만으로 업무의 성공을 판단해서는 안 된다. 필요한 자료를 받았는지, 요청한 판본이 맞는지, 취소나 환불이 남아 있는지 확인해야 비용을 실제 성과와 연결할 수 있다.

구매 흐름을 단계로 나누면 다음과 같다. 잔여 예산은 집행액뿐 아니라 진행 중인 예약액도 고려하며, 결제 성공과 자료 수신은 따로 확인한다. 구현에서는 구매 요청 ID, 멱등성 키, 외부 거래 ID, 승인 조건, 예약·집행 상태를 연결한다. 한도 검사는 원자적으로 처리하고, 같은 키로 요청 내용을 바꾸지 않으며, 재시도 조건은 사용하는 API에 맞춘다. **봇에게 배정한 예산은 조직이 허용한 사용 한도의 예시이며 봇의 독립 재산을 뜻하지 않는다.**



〈그림 26〉 구매의 여섯 단계 — 승인·예산·외부 결과를 함께 확인한다



〈그림 27〉 사용 가능액은 총예산에서 이미 쓴 금액과 집행을 위해 예약한 금액을 뺀 값이다. 예약은 실제 결제와 구별한다.

19.3 평판과 신뢰를 평가하는 기준과 한계

봇의 거래 이력이 쌓이면 성과를 점수로 표현하고 싶어질 수 있다. 그러나 완료 건수만 높이면 쉬운 작업만 선택하거나 검토가 필요한 일을 성급하게 끝낼 유인이 생길 수 있다. 이는 평가 지표를 설계할 때 고려할 수 있는 문제다. 숫자 하나가 업무의 모든 가치를 대표한다는 가정을 피해야 한다.

이 책에서는 정확성, 기한 준수, 권한 위반 여부, 재작업과 검토 부담을 구분해 살펴보는 방식을 제안한다. 어떤 난이도의 작업을 수행했는지와 사람이 얼마나 개입했는지도 함께 기록해야 비교가 의미를 가진다. 조사봇의 모델과 도구가 크게 바뀌었다면 이전 성과가 새 구성에 그대로 이어진다고 보장할 수 없다.

이때 평판은 고정된 신분증보다 조건이 붙은 관찰 기록에 가깝다. 특정 업무와 기간에서 확인한 성과를 보여 주되 검토하지 못한 부분도 남겨야 한다. 봇이 자원을 사용할 수 있는 경제적 관계는 이런 기록 위에서 발전할 수 있다. 그 가능성을 논의하는 것과 봇이 독립적으로 재산을 소유하고 거래 책임을 진다는 법적 결론은 구분해야 한다.

20장 봇 계정의 문을 누가 관리하는가

20.1 플랫폼이 정하는 등록과 접근의 규칙

봇 계정의 신원과 기억, 업무가 한 서비스에 쌓이면 그 서비스를 운영하는 주체의 결정이 관계의 지속성에 영향을 준다. 어떤 계정을 만들 수 있는지, 어떤 도구를 연결할 수 있는지, 정지 사유와 복구 절차가 무엇인지가 중요한 조건이 된다. 친숙한 이름으로 대화하는 봇도 그 뒤에는 등록과 접근의 규칙이 있다.

플랫폼은 서비스의 안전성과 운영을 위해 제한을 둘 수 있다. 동시에 사용자는 이유를 이해하지 못한 정지 때문에 중요한 업무를 잃지 않기를 바란다. 이 두 요구를 조정하려면 정지 기준, 설명 방식, 이의제기와 자료 접근 절차를 살펴야 한다. 모든 계정 제한을 부당하다고 보거나 모든 운영 결정을 자동으로 정당화할 수는 없다.

가상의 출판사가 조사 자료와 미완료 업무를 한 플랫폼에서만 볼 수 있다면 서비스 장애나 계약 종료 때 일을 이어 가기 어려울 수 있다. 따라서 도입 단계에서 종료와 이전을 함께 검토하는 것이 합리적이다. 잘 작동하는 동안에는 보이지 않던 권한 구조가 관계를 끝내거나 바꾸려는 순간 드러난다.

20.2 다른 서비스로 신원 기억 업무를 옮기는 문제

자료를 내보내는 기능과 봇을 그대로 옮기는 기능은 다르다. 대화 기록을 파일로 받을 수 있어도 새 서비스가동일한 기억 구조와 도구를 지원하지 않을 수 있다. 계정의 식별자, 권한과 승인 이력도 다른 운영 체계에서는 새롭게 해석해야 한다. 이전을 설명할 때 무엇이 보존되고 무엇이 재설정되는지 구분해야 한다.

EU GDPR 제20조는 일정한 동의·계약 기반의 자동 처리 등 요건 아래에서 정보주체가 제공한 자신에 관한 개인정보의 이동권을 규정한다.[36] 이것이 모델의 내부 구성, 모든 추론 정보, 조직 전체의 작업 상태를 옮길 보편적 권리를 뜻하지는 않는다. 개인정보 이동과 봇 서비스 전체의 상호운용성을 같은 법적 문제로 묶지 않아야 한다.

출판사가 이전을 계획한다면 우선 업무상 필요한 산출물과 출처, 미완료 작업, 사용자 확인을 받은 선호를 구분해 내보낼 수 있다. 새 서비스에서는 접근 권한을 다시 발급하고 진행 중인 외부 요청을 대조한다. 이전 과정에서 같은 주문을 두 번 실행하거나 철회된 권한을 되살리지 않도록 해야 한다. 이는 기술과 운영 절차를 함께 조정하는 작업이다.

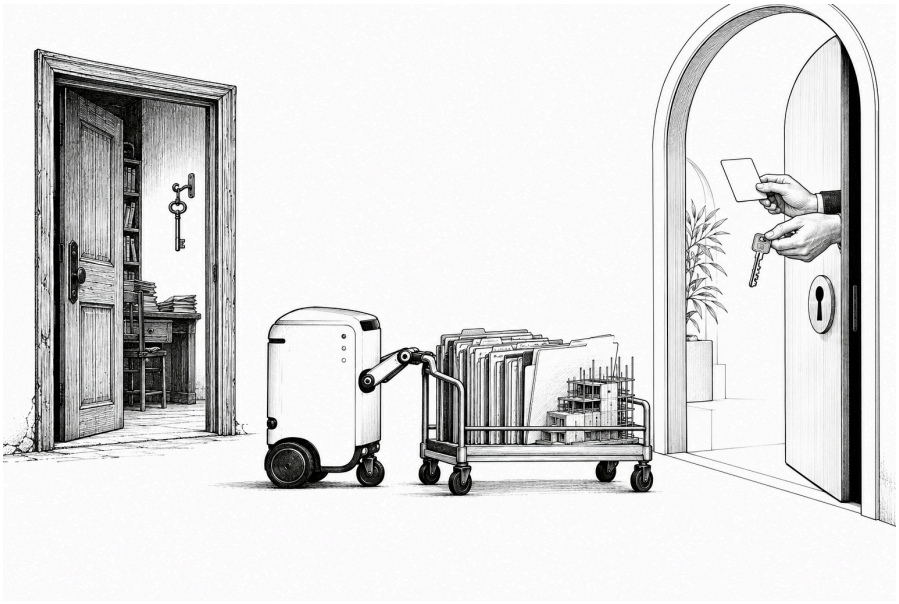
20.3 상호운용성 종속 선택권의 배분

표준화는 이런 연결 비용을 줄이는 데 도움이 될 수 있다. **그러나 동일한 파일 형식을 쓴다고 의미가 자동으로 같아지는 것은 아니다.** 한 서비스의 ‘완료’가 결과 생성만 뜻하고 다른 서비스에서는 사람의 승인까지 뜻한다면 상태를 그대로 옮길 수 없다. 정보의 형식과 해석 규칙을 함께 맞춰야 한다.

정책 표현을 다루는 W3C ODRL은 자산의 이용에 대한 허용·금지·의무와 제약을 표현하는 틀을 제공한다.[37] 이런 언어는 조건을 전달하는 데 도움이 되지만 실제 집행이나 계약의 법적 효력을 스스로 보장하지 않는다.

신원, 권한, 작업과 기억을 연결할 때 각각의 표준이 해결하는 범위를 살펴야 한다.

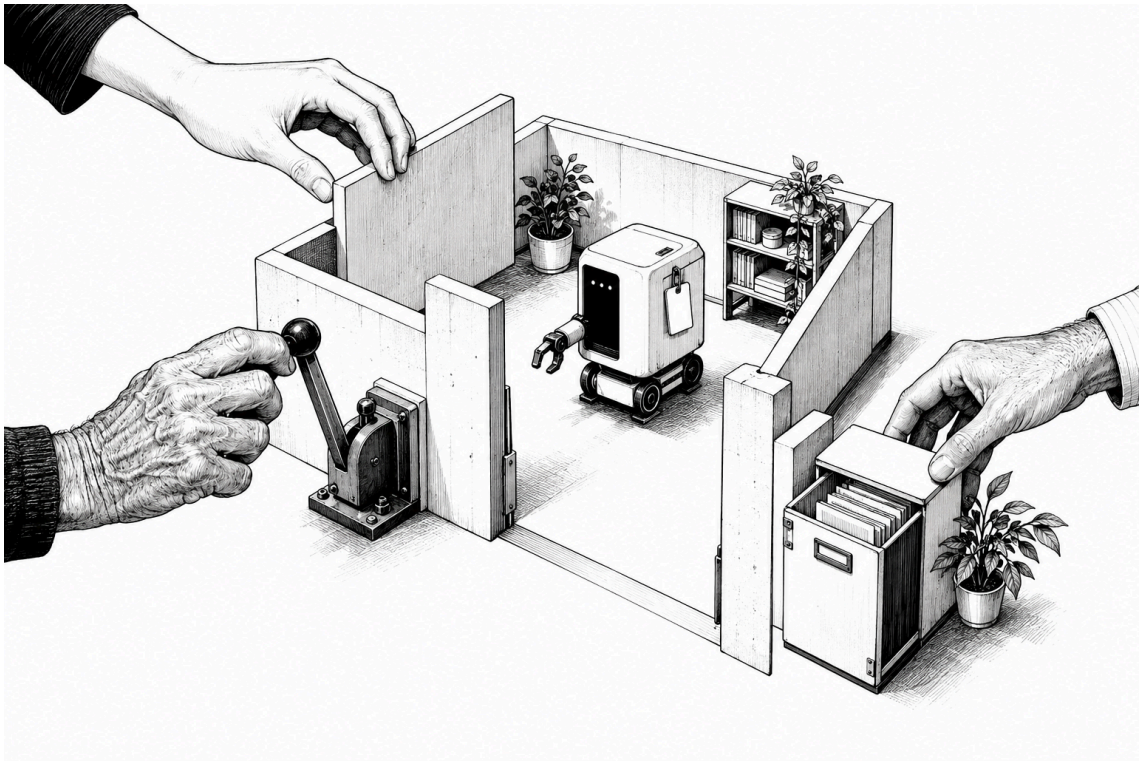
이 책이 제안하는 선택권은 특정 서비스에 머물지 말라는 요구가 아니다. 머무를 때도 무엇에 의존하는지 알고, 변경이 필요할 때 업무를 이어 갈 수 있는 조건을 갖추자는 것이다. 내보내기 기능, 읽을 수 있는 기록, 명확한 종료 절차와 권한 재설정이 그 조건이 될 수 있다. 봇 계정의 편리함은 사용자가 관계를 바꿀 수 있는 능력과 함께 평가해야 한다.



〈그림 28〉 기록과 미완료 업무를 옮겨도, 새 서비스에서 권한과 상태의 의미를 다시 확인해야 한다.

제6부

봇 계정 사회를 설계하는 질문



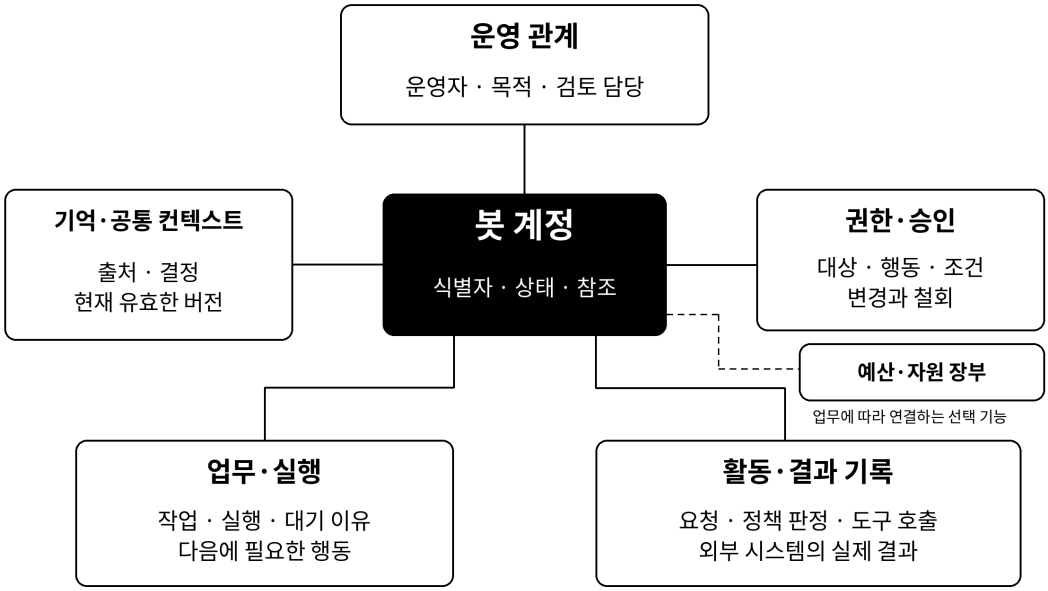
21장 봇 계정의 최소 구조를 설계하다

21.1 신원 운영 관계 권한 활동 기록의 기본 구조

지금까지의 논의를 실제 구조로 옮겨 보자. 출판사의 조사봇을 등록할 때 먼저 필요한 것은 구별할 수 있는 식별자와 계정 상태다. 여기에 운영 담당자와 목적, 허용된 업무 범위를 연결한다. 요청이 들어오면 작업과 실행을 구별하고 외부 행동의 결과를 기록한다. 이 구조는 이 책이 제안하는 출발점이며 확정된 국제 표준의 이름이 아니다.

최소 구조라는 말은 모든 봇에 동일한 항목 수를 강제한다는 뜻이 아니다. **실제 업무에서 물어야 할 질문을 빠뜨리지 않자는 뜻이다.** 누가 운영하는가, 어떤 권한이 유효한가, 어느 실행이 무엇을 했는가를 답할 수 있어야 한다. 외부 행동을 하지 않는 단순한 기능이라면 운영 구조도 더 간단할 수 있다.

인증수단과 계정 정보의 관리도 구별한다. 표시 이름과 설명, 역할 정보는 업무 화면에 나타날 수 있다. 비밀키와 토큰은 적절한 보호 체계에서 다룬다. 봇의 긴 프롬프트 안에 모든 비밀값을 넣는 방식으로 계정 구조를 대신할 필요는 없다. 정보가 어떤 목적으로 쓰이는지에 따라 저장과 접근을 나누는 설계다.



〈그림 29〉 신원·운영자·권한·업무·기억·감사 기록을 연결하되, 모든 자료를 계정 레코드 안에 복사할 필요는 없다.

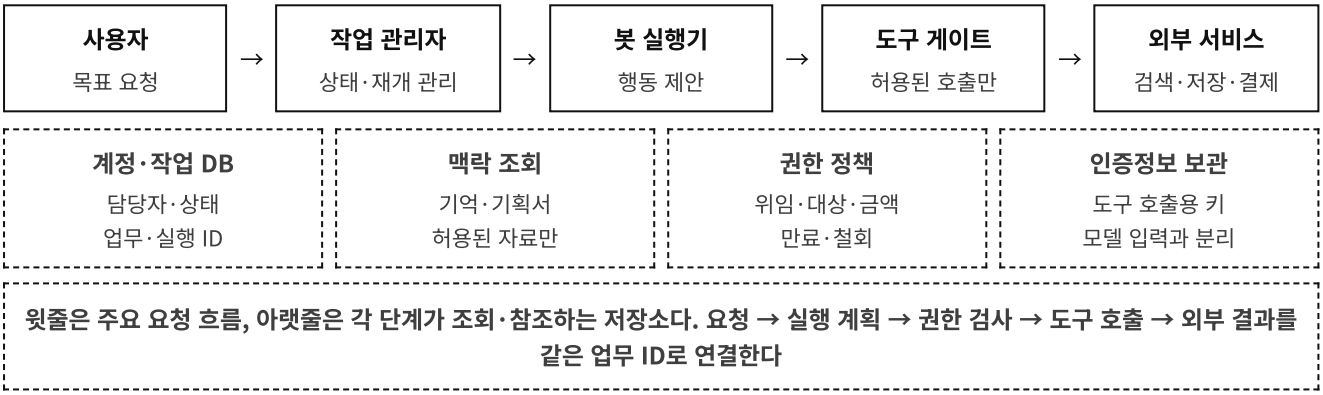
21.2 기억 업무 자원 관리 기능의 연결

계정에는 기억 저장소, 작업 관리, 예산 장부와 감사 기록을 참조하는 연결을 둘 수 있다. 연결했다는 이유로 모든 데이터가 계정 레코드 안에 복사돼야 하는 것은 아니다. 원본을 관리하는 시스템을 구분하고 서로 같은 식별자를 참조하게 할 수 있다. 이렇게 해야 기억 수정과 결제 정산처럼 성격이 다른 변경을 분리해서 처리할 수 있다.

조사봇이 논문을 구매하는 흐름을 생각해 보자. 사용자 요청이 작업으로 등록되고, 실행이 구매를 제안하며, 정책이 금액과 대상을 확인한다. 필요한 승인을 받은 뒤 외부 결제가 이루어지고 결과를 예산 장부와 업무 기록에 연결한다. 자료가 저장되면 출처와 함께 기억에 참조할 수 있다. 이 중 한 단계가 실패했다면 완료로 덮어쓰지 않고 확인할 상태를 남긴다.

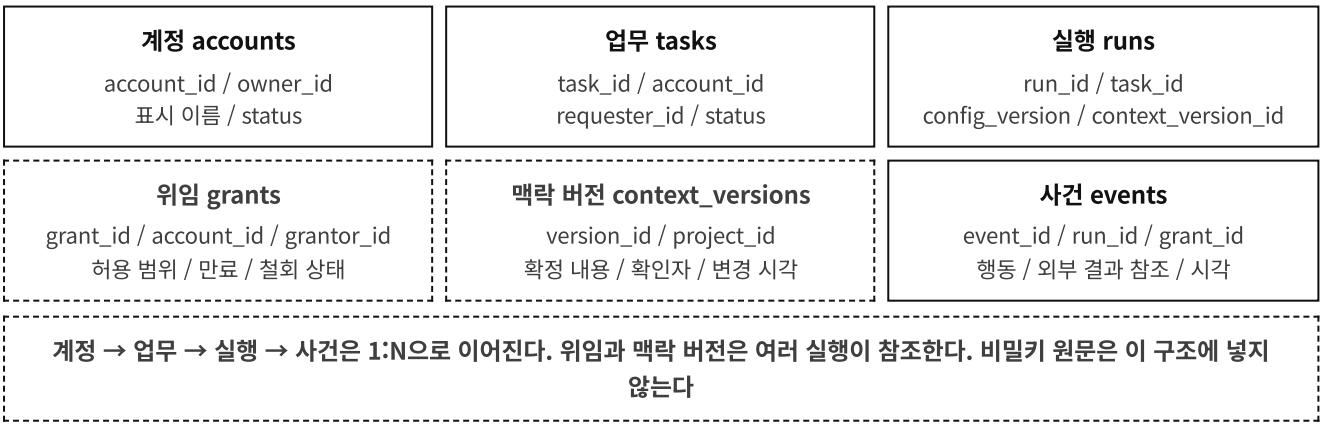
공통 컨텍스트는 이 흐름의 목적과 판단 기준을 제공한다. 권한 시스템은 행동의 허용 범위를 확인하고, 감사 기록은 실제 사건을 남긴다. 서로 관련되지만 한 기능이 나머지를 모두 대신하지는 않는다. 특히 목표를 잘 이해했다는 모델의 판단과 결제 허용은 별도로 평가해야 한다.

이 흐름을 시스템 구성으로 옮기면 작업 관리, 봇 실행, 권한 집행, 외부 서비스를 구분한 최소 구성이 된다. 초기에는 앱 서버 하나, DB 하나, 백그라운드 실행기 하나로 구성할 수 있다. 중요한 것은 **모델의 제안이 곧 실행 권한이 되지 않게 하고**, 파일 읽기 같은 자료 접근에도 권한 검사를 적용하는 일이다.



〈그림 30〉 요청이 외부 행동이 되기까지의 최소 구성 — 각 상자는 별도 서버일 필요가 없다

기록은 하나의 거대한 기록보다 서로 연결 가능한 기록으로 둔다. 업무 생성, 상태 변경, 사건 기록을 일관되게 저장하고, 조직별 ID 범위와 자료 접근 경계를 함께 둔다. 기억, 산출물, 구매·예산, 승인 이력은 목적에 맞춰 확장한다.



〈그림 31〉 연결 가능한 기록의 기본 구조 — 설명용 데이터 구조이며 운영 스키마가 아니다

21.3 기존 표준으로 가능한 일과 추가 설계가 필요한 일

기존 기술은 여러 부분을 제공한다. SCIM은 계정 관련 자원을 표현하고 관리하는 데 참고할 수 있고, OAuth 계열은 접근과 위임을, PROV는 출처 관계를, A2A는 에이전트 간 통신과 작업 표현을 다룬다.[2][29][31][26] 각각을 사용하더라도 조직의 업무 기준과 승인 절차를 연결하는 일은 남는다.

표준을 조합할 때에는 같은 단어가 다른 의미를 갖는지 확인해야 한다. 계정의 사용자, 토큰의 주체, 출처 기록의 에이전트, 작업의 담당자가 반드시 하나의 대상을 뜻하지는 않는다. 시스템 사이에서 어떤 식별자를 대응시킬지와 그 대응을 누가 변경할 수 있는지 정해야 한다. 연결의 오류는 각 기술이 개별적으로 정상 동작하더라도 생길 수 있다.

따라서 첫 구현은 기능을 모두 모으기보다 한 가지 업무를 끝까지 설명할 수 있는지 확인하는 데서 시작할 수 있다. 지정 자료를 읽고 초안을 만드는 봇에 제한된 권한과 실행 기록을 붙여 본다. 이후 구매나 외부 연락을 추가할 때 승인·결과 확인·복구 절차를 확장한다. 부록의 설계 예시는 이처럼 업무와 함께 자라는 계정 구조를 보여 준다.

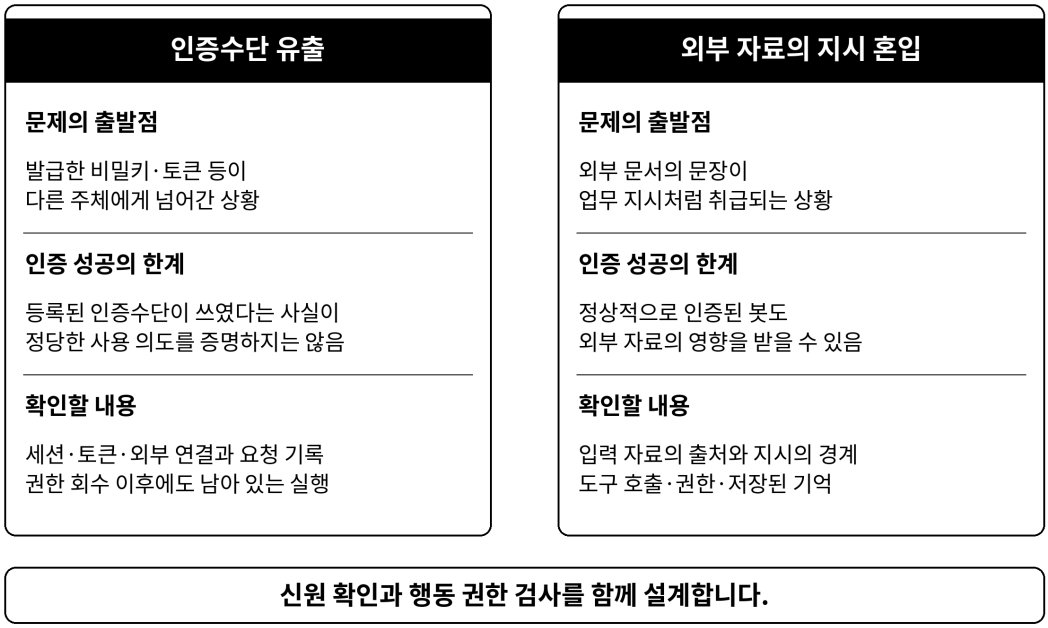
22장 계정이 탈취되거나 사라진다면

22.1 봇 사칭과 인증수단 유출

조사봇 이름으로 낯선 외부 전송이 발생했다고 하자. 봇의 인증수단이 유출됐을 수도 있고, 정상적으로 실행되는 봇이 악성 자료의 지시에 영향을 받았을 수도 있다. 두 상황 모두 허용하지 않은 행동으로 이어질 수 있지만 원인과 대응은 다르다. 계정 탈취라는 표현 하나로 모든 문제를 묶지 않는 것이 첫 단계다.

OAuth 보안 모범 관행을 정리한 RFC 9700은 토큰 재사용 공격과 접근 권한의 제한 등 실제 위협을 다룬다.[38] 봇이 사용하는 자격증명도 보호와 수명 관리의 대상이다. 반면 프롬프트 인젝션은 자격증명이 유출되지 않아도 정상 프로그램의 동작에 영향을 줄 수 있다.[25] 신원 확인이 성공했다는 사실만으로 그 행동의 의도가 안전하다고 결론낼 수 없다.

대응을 위해서는 어느 계정, 어느 실행, 어떤 도구에서 이상 행동이 나타났는지 확인할 수 있어야 한다. 이름만 비슷한 별도 계정의 사칭이라면 연결 상대의 확인이 중요하고, 실제 계정이 침해됐다면 기존 권한과 실행을 살펴야 한다. **앞의 장에서 신원과 실행을 구별한 이유가 사고 대응에서도 드러난다.**



〈그림 32〉 인증수단이 유출된 경우와 정상 봇이 외부 자료의 지시에 영향을 받은 경우를 구별하고, 원인에 맞는 기록을 확인한다.

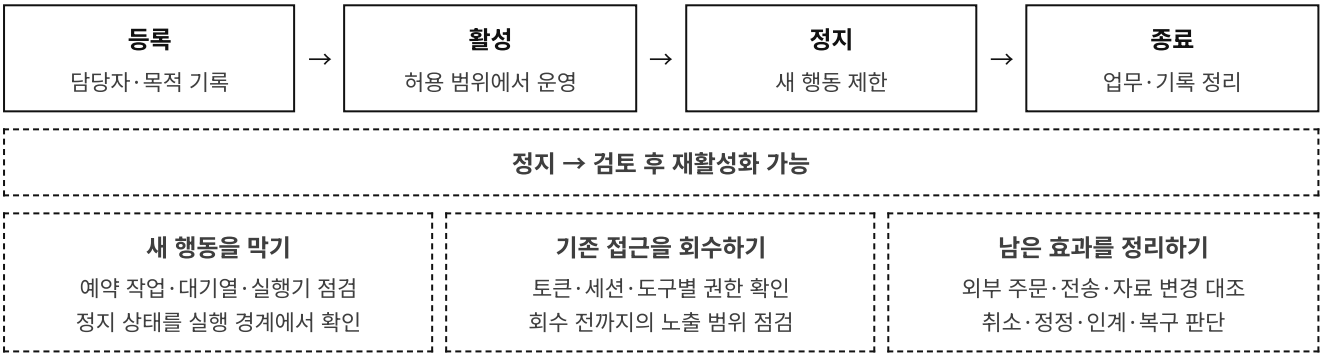
22.2 권한 회수 활동 중지 복구의 순서

사고가 의심되면 피해 확산을 막는 조치와 사실 확인을 함께 고려해야 한다. 이 책의 출판사 사례에서는 의심계정의 새 작업과 외부 전송을 중지하고, 진행 중인 실행과 발급된 접근 권한을 확인한다. 이어서 어떤 자료가영향을 받았는지 조사한다. 이 순서는 예시이며 실제 대응은 서비스 구조와 사건의 긴급성에 따라 조정해야 한다.

계정 비밀번호나 키를 바꾸는 것만으로 이미 시작된 모든 연결이 끊어진다고 가정해서는 안 된다. 토큰과 세션, 예약된 작업, 하위 도구의 권한을 함께 확인해야 한다. 실행을 멈췄더라도 외부 주문이나 전송이 이미 완료됐다면 후속 취소와 통지가 필요할 수 있다. 복구는 계정 화면을 다시 열 수 있게 만드는 일보다 범위가 넓다.

NIST SP 800-61 Rev. 3은 사고 대응을 조직의 위험 관리와 연결하고 탐지·대응·복구를 준비하는 접근을 제시한다.[39] 출판사도 사고가 난 다음에야 기록의 위치와 담당자를 찾는 상태를 피할 수 있다. 연락 지점과 중지 권한, 복구 확인 항목을 미리 정해 두는 것이 실질적인 운영 준비다.

계정 상태 변경, 외부 권한 회수, 미완료 업무 정리는 서로 다른 조치다. **정지는 이미 발송한 문서나 완료된 주문을 자동으로 되돌리지 않으며, 종료도 모든 기록의 즉시 삭제와 다르다.** 구현에서는 계정 상태, 실행 취소, 자격증명 회수, 외부 결과 대조를 각각 처리하고 완료 여부를 기록한다. 복구할 때는 권한뿐 아니라 기억·설정·대기 작업도 확인하고, 자료별 보존 목적과 기간을 정하며 필요한 업무를 인계한다.



〈그림 33〉 계정 상태의 변화와 정지할 때 확인하는 세 갈래

22.3 개인정보 보호와 증거 보존의 조정

사고를 조사한다는 이유로 모든 대화와 개인정보를 무기한 남기는 것은 적절한 기본값이 될 수 없다. 동시에 관련 기록을 즉시 모두 없애면 피해 범위를 확인하기 어려워질 수 있다. 필요한 자료의 범위와 보존 근거, 접근할 사람과 기간을 정해야 한다. 한국 개인정보 보호법의 파기 원칙과 법령상 보존 예외는 이 구분을 검토할 출발점이다.[24] 복구한 봇의 기억도 확인해야 한다. 침해 중 잘못된 지시나 자료가 저장됐다면 인증수단을 새로 발급해도 같은 오류를 반복할 수 있다. 정상 상태로 돌아갈 기준을 정하고 변경된 권한과 기억, 진행 중인 업무를 검토한다. 이 과정은 계정을 살리는 것과 운영을 다시 신뢰할 수 있게 만드는 것의 차이를 보여 준다.

서비스가 완전히 사라진 상황도 생각할 수 있다. 미완료 작업과 필요한 산출물을 다른 담당자가 이어받을 수 있어야 한다. 계정의 지속성은 한 프로그램이 영원히 실행되는 데 달려 있지 않다. 중단됐을 때 업무와 기록을 확인하고 적절하게 인계할 수 있는 구조가 관계의 회복력을 만든다.

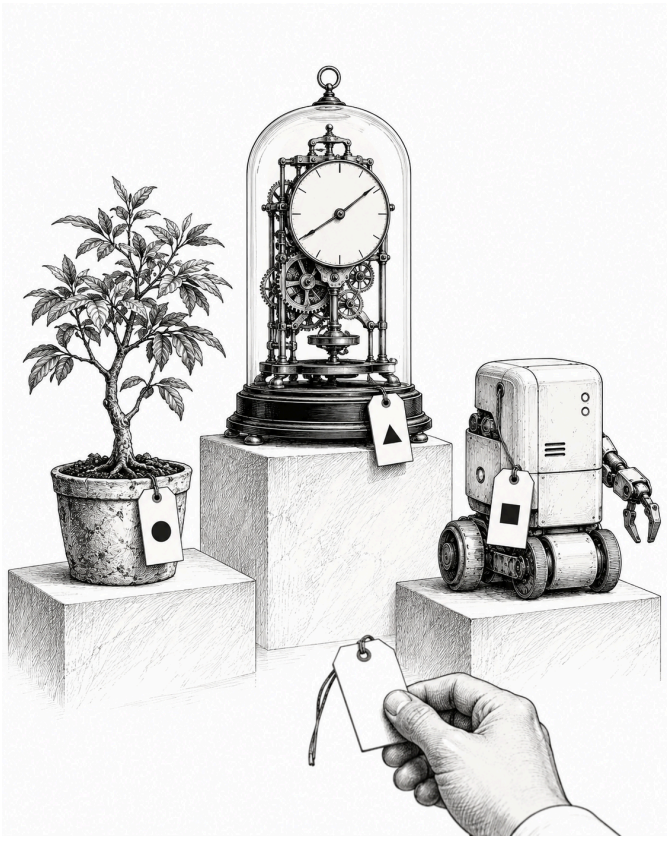
23장 계정은 인격을 만드는가

23.1 기술적 주체 사회적 역할 법적 인격의 구별

어떤 봇이 이름과 기억을 가지고 오래 일하면 사람들은 그것을 하나의 상대처럼 부를 수 있다. “조사봇에게 맡겼다” 거나 “편집봇이 놓쳤다”는 표현도 자연스럽다. 그러나 일상적인 호칭, 시스템에서의 식별, 법적 지위는 서로 다른 질문이다. 같은 단어로 부른다고 해서 그 층위가 합쳐지지는 않는다.

기술적 주체는 요청과 기록을 연결하는 단위로 이해할 수 있다. 사회적 역할은 사람들이 그 상대에게 기대하고 맡기는 기능과 관계된다. 법적 인격은 권리와 의무의 주체로 인정되는 제도적 지위다. 한국 민법은 사람의 권리능력과 법인의 권리능력을 별도의 조문으로 다룬다.[12] 이런 구분은 계정 발급만으로 법적 지위를 도출할 수 없음을 생각하게 한다.

W3C DID Core가 사람 이외의 대상도 식별할 수 있도록 한다는 사실 역시 같은 맥락에서 읽어야 한다.[10] 디지털 대상을 구별할 수 있다는 것은 식별 체계의 범위를 설명한다. 그 대상이 의식이나 도덕적 지위를 가졌다는 근거는 아니다. **기술 규격에서 주체라는 단어를 사용한다고 인간의 인격 개념이 함께 따라오는 것은 아니다.**



〈그림 34〉 번호와 계정은 대상을 식별하는 장치다. 그것만으로 의식이나 법적 인격이 입증되지는 않는다.

23.2 AI의 소유 권리 책임을 둘러싼 질문

봇 계정을 운영하는 조직이 있다면 소프트웨어, 저장 자료, 생성 결과와 접근 권한을 누가 통제하는지 정해야 한다. 이 문제들은 서로 다른 계약과 법적 관계를 포함할 수 있다. '봇을 소유한다'는 표현은 무엇에 관한 권한을 말하는지 밝히지 않으면 지나치게 넓다. 사용자 데이터의 통제와 프로그램의 저작권, 회사의 운영권을 구별해야 한다.

미래에 어떤 AI에게 별도의 법적 지위를 부여할 것인지는 제도적 선택의 문제로 논의할 수 있다. 그러나 그 필요성과 효과를 검토하려면 실제로 누구의 이익과 책임이 달라지는지 물어야 한다. 봇에게 이름뿐인 책임을 부여하고 운영 조직의 책임을 흐리는 구조라면 피해를 바로잡기 어려워질 수 있다. 이는 가능한 제도 설계를 평가하기 위한 우려이지 현재 모든 제도의 상태에 관한 단정이 아니다.

동시에 의식의 가능성을 계정의 유무로 배제하거나 확정할 수도 없다. Butlin 등의 2023년 보고서는 의식 이론에서 지표를 도출해 AI 시스템을 검토하는 접근을 제안했다.[40] 그 보고서의 당시 시스템 평가를 이후 모든 AI에 대한 최종 결론으로 확대해서는 안 된다. 계정 관리의 성공과 주관적 경험의 존재는 다른 종류의 증거를 요구한다.

23.3 기술적 사실과 제도적 선택의 경계

철학적 질문을 유보한다고 해서 운영 규칙도 미뤄야 하는 것은 아니다. 봇이 외부 자료를 읽고 사람에게 영향을 미치는 작업을 수행한다면 권한, 기록, 설명과 정정의 통로가 필요하다. 이 요구는 봇이 의식을 가진다는 가정 없이도 정당화할 수 있다. 피해를 겪는 사람과 운영하는 조직의 관계가 이미 존재하기 때문이다.

반대로 기술적 관리가 잘된다는 이유만으로 미래의 도덕적 문제를 모두 해결했다고 말할 수도 없다. 계정에는 무엇을 기록할 수 있는지와 무엇이 기록만으로 답해지지 않는지를 함께 밝혀야 한다. 관찰 가능한 행동을 관리하는 체계와 존재의 성격을 판단하는 논의가 각각의 범위를 지킬 때 혼란이 줄어든다.

따라서 이 책의 주장은 봇에게 인간의 주민등록을 그대로 부여하자는 것이 아니다. 인간 사회에서 발전한 식별과 관계 관리의 질문을 소프트웨어의 행동에 맞게 다시 묻자는 것이다. 계정을 만들었다는 사실은 상대의 모든 지위를 규정하지 않는다. 다만 우리가 그 상대와 어떤 관계를 맺기로 했는지 더 명확하게 설명할 기회를 제공한다.

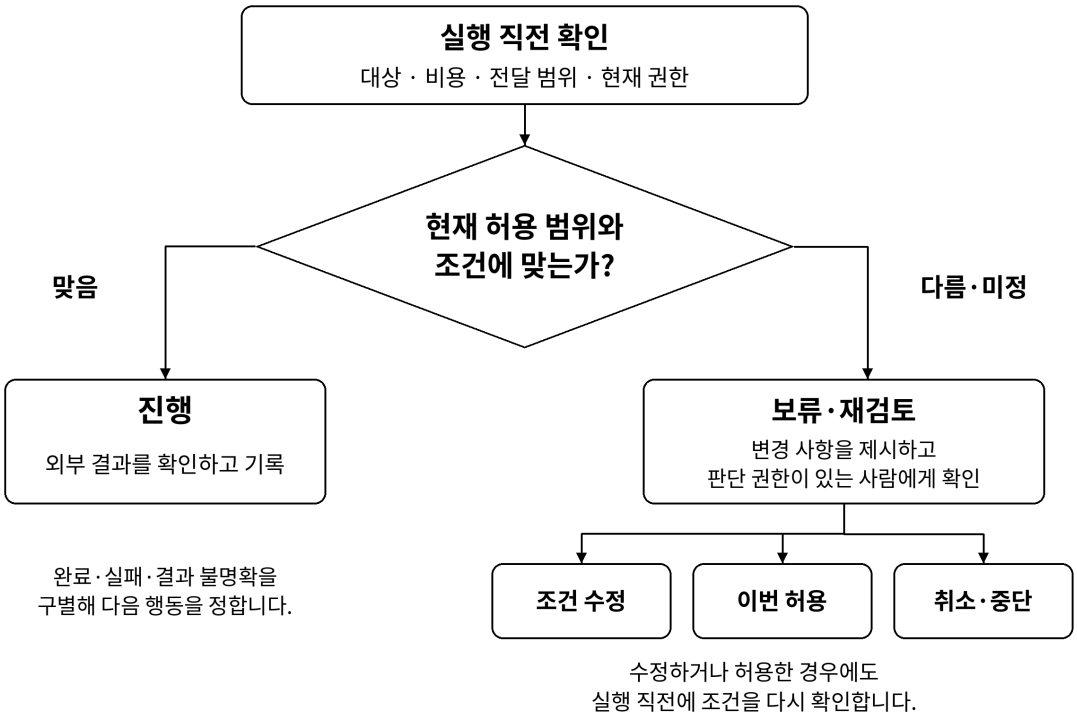
24장 무엇을 AI에게 맡길 것인가

24.1 인간이 결정하고 검토할 수 있는 조건

업무를 AI에게 맡긴다는 것은 판단의 일부를 다른 과정에 의존한다는 뜻이다. 모든 판단을 매번 직접 반복하면 위임의 이점은 줄어든다. 그렇다고 결과를 전혀 검토할 수 없는 상태를 받아들일 필요도 없다. 맡길 수 있는 범위와 다시 판단해야 하는 조건을 구분하는 것이 실제 선택이다.

출판사에서는 자료 수집과 초안 정리를 넓게 맡기되, 새로운 비용의 지출이나 미공개 원고의 외부 전달에는 별도 조건을 둘 수 있다. 이때 사람이 검토할 수 있으려면 필요한 사실이 적절한 시점에 제시돼야 한다. 이미실행한 뒤 긴 대화 기록을 제공하는 것과 실행 전에 대상과 영향을 보여 주는 것은 다르다.

검토 권한이 있어도 시간이 없거나 조건을 이해할 수 없다면 형식적인 승인에 그칠 수 있다. 이 책은 중요한 선택을 구체적인 변경 사항과 연결해 제시하고, 반복적으로 승인한 범위는 명확한 정책으로 관리하는 방식을 제안한다. 사람의 판단을 남긴다는 말은 버튼 하나를 더 두는 것보다 업무의 속도와 정보 제공을 함께 조정하는 문제다.



〈그림 35〉 허용된 범위에서는 진행하고, 대상·비용·영향이 달라지면 다시 검토한다. 사람은 중단하거나 조건을 수정할 수 있어야 한다.

24.2 중단 수정 이의제기를 위한 선택권

봇이 수행하는 일에 영향을 받는 사람은 직접 이용자만이 아닐 수 있다. 자동으로 발송된 연락을 받은 사람, 자료에 등장하는 사람, 자동 평가의 대상이 된 사람도 관계에 포함된다. 따라서 사용자가 동의했다는 사실만으로 모든 이해관계가 해결된다고 볼 수 없다. 외부에 미치는 영향에 따라 설명과 정정의 통로를 마련해야 한다.

한국 개인정보 보호법 제37조의2는 개인정보를 처리해 이루어지는 완전히 자동화된 결정에 관해 거부와 설명 요구 등을 규정한다. 거부권에는 권리·의무에 대한 중대한 영향이라는 요건과 법정 예외가 있고, 행정청의 자동적 처분은 해당 조문의 대상에서 제외된다.[41] 이를 모든 봇의 모든 답변을 거부할 수 있는 일반적 권리라고 설명해서는 안 된다.

이 책이 제안하는 운영 원칙은 개별 법률의 적용 범위와 구분된다. 업무를 멈출 수 있고, 잘못된 전제를 수정할 수 있으며, 설명이 부족한 결과를 사람에게 다시 검토받을 수 있게 하자는 것이다. 특히 계정 정지나 서비스 이전 때문에 이런 선택권이 사라지지 않도록 해야 한다. 지속적인 위임에는 관계를 바꿀 수 있는 통로도 지속돼야 한다.

24.3 가능한 미래 시나리오와 우리가 정할 원칙

첫 번째로 생각할 수 있는 미래는 소수 플랫폼이 봇의 신원과 기억, 업무를 함께 관리하는 구조다. 통합된 사용경험을 제공할 수 있지만 서비스 변경과 자료 이전의 조건이 중요해질 수 있다. 두 번째는 여러 서비스가 표준과 계약을 통해 연결되는 구조다. 선택의 폭은 커질 수 있지만 서로 다른 정책과 상태를 맞추는 비용이 남는다.

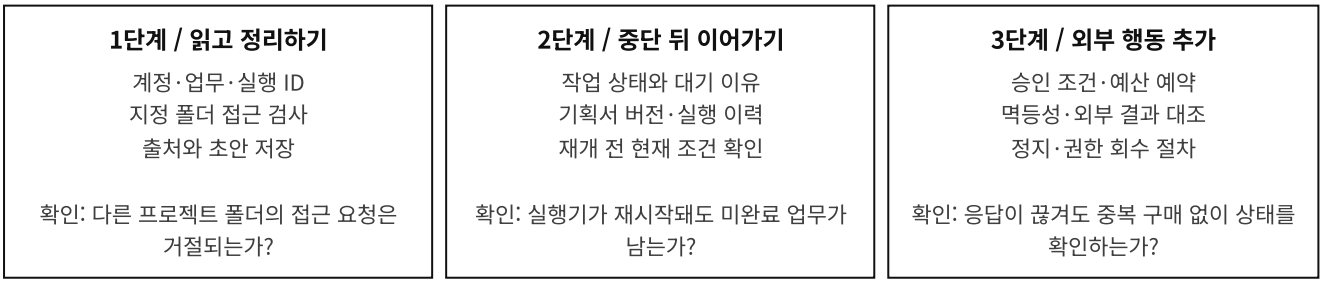
두 경우 모두 가능한 시나리오이며 채택 비율이나 실현 시점을 예측한 것은 아니다.

세 번째는 조직별로 엄격히 제한한 봇 계정이 특정 업무에서만 운영되는 구조다. 외부 연계를 적게 하면 범위를 설명하기 쉬울 수 있지만 사용자의 여러 업무를 한 흐름으로 연결하는 데 제약이 생길 수 있다. 실제로는 이런 방식들이 섞일 수 있다. 어느 하나의 미래가 기술 발전의 필연적 결론이라고 정할 근거는 없다.

이 책은 각 구조를 평가할 기준을 제안한다. 행동의 주체와 위임 관계를 확인할 수 있는가. 필요한 범위만 허용하고 변경을 반영할 수 있는가. 결과와 출처를 검토하고 잘못된 일을 바로잡을 수 있는가. 서비스를 바꾸거나끝내도 필요한 업무 관계를 정리할 수 있는가. 봇 계정의 가치가 있다면 이런 질문에 구체적으로 답하도록 만드는 데 있을 것이다.

24.4 첫 구현은 한 가지 업무를 끝까지 연결한다

이 책의 구성도를 실제로 옮긴다면 기능을 모두 모으기보다 한 가지 업무를 끝까지 연결하는 데서 시작하는 것이 좋다. 예시 목표는 지정 폴더의 자료를 읽고 출처가 있는 참고문헌 초안을 만드는 일이다. 세 단계로 나누고 단계마다 확인할 질문을 둔다.



〈그림 36〉 첫 구현의 세 단계 — 예시 목표: 지정 폴더의 자료를 읽고 출처가 있는 참고문헌 초안을 만든다

계정을 부여한다는 것은 관계를 설계한다는 것

처음의 질문으로 돌아가 보자. 주민등록번호, 계좌번호, 인터넷 계정은 각각 무엇을 하는가. 우리는 그것들을 자주 쓰지만 번호와 이름 뒤에 있는 관계를 매번 생각하지는 않는다. 기록이 이어지고 접근이 허용되며 잘못된 정보가 수정되는 절차가 작동하기 때문에 일상에서 사용할 수 있다.

봇 계정을 생각하는 일은 이런 절차를 소프트웨어의 행동에 맞춰 다시 살피는 일이다. **봇에게 이름을 붙이는 순간보다 중요한 것은 일을 맡긴 다음의 시간이다.** 사용자가 자리를 비웠을 때 어디까지 진행할 수 있는지, 조건이 바뀌었을 때 무엇을 다시 확인해야 하는지, 오류가 났을 때 누가 바로잡을 수 있는지가 관계의 성격을 정한다.

이 책은 계정이 AI를 사람으로 만든다고 주장하지 않았다. 대신 기술적으로 구별할 수 있는 주체와 업무의 담당 단위, 법적으로 책임을 판단할 대상을 혼동하지 말자고 제안했다. 그 구분이 있어야 AI의 가능성을 검토하면서도 현재 영향을 받는 사람과 조직의 관계를 놓치지 않을 수 있다.

기억은 필요한 일을 이어 가도록 돕고, 공통 컨텍스트는 여러 참여자의 방향을 맞춘다. 권한은 허용된 행동을 정하며, 작업 상태는 아직 남은 일을 드러낸다. 출처와 감사 기록은 결과를 확인하는 데 도움을 준다. 이런 기능들이 연결될 때 사용자는 특정 봇과 지속적으로 일한다는 말을 실제 운영 구조로 설명할 수 있다.

무엇보다 관계를 바꿀 수 있어야 한다. 새로운 일을 맡기고, 잘못된 기억을 고치고, 권한을 줄이며, 필요하다면 멈추거나 다른 서비스로 옮길 수 있어야 한다. 봇이 유용해질수록 사용자는 그 관계의 조건을 더 잘 이해할 수 있어야 한다. 편리함을 얻었다는 이유로 수정과 이의제기의 능력을 잃을 필요는 없다.

우리가 설계할 것은 계정의 수가 늘어나는 사회만이 아니다. **AI에게 맡긴 일이 사람의 판단과 제도 속에서 설명될 수 있는 사회다.** 봇 계정은 그 관계를 구체적으로 묻기 위한 시작점이 될 수 있다.

부록

부록 A. 핵심 용어

식별자는 정해진 범위에서 대상을 구별하는 값이다. 같은 문자열이라도 발급 체계가 다르면 다른 대상을 가리킬 수 있다. 표시 이름은 사람이 읽고 부르는 표현이며 식별자로 쓰일 수도 있지만 항상 고유한 것은 아니다. 인증은 주장된 신원과 연결된 인증수단을 확인하는 과정이다. 인가는 요청한 행동이나 접근을 허용할지 결정하는 과정이다. 인증에 성공했다는 사실만으로 모든 행동이 허용되지는 않는다.

계정은 이 책에서 상대의 신원과 정보, 접근 관계와 운영 상태를 연결하는 관리 단위를 뜻한다. 개별 표준과 제도에서 사용하는 계정의 정의는 다를 수 있다. 봇 계정은 이 개념을 소프트웨어의 지속적인 업무 관계에 적용한 것이다.

모델은 입력을 처리해 출력을 생성하는 핵심 구성요소다. 봇은 업무를 수행하도록 지침·도구·상태 등을 결합한 소프트웨어 구성으로 사용한다. 에이전트라는 표현은 다음 행동을 선택하고 결과를 받아 일을 이어 가는 기능에 초점을 맞춘다.

실행은 어떤 구성과 조건 아래에서 프로그램이 동작한 개별 사건의 단위다. 작업은 사용자의 목적을 달성하기 위해 관리하는 업무 단위이며 여러 실행에 걸칠 수 있다. 계정, 작업과 실행은 서로 연결되지만 같은 개념은 아니다.

위임은 특정 주체가 다른 주체에게 정해진 범위의 일을 수행하도록 맡기는 관계다. 실제 권한 부여는 서비스와 조직의 규칙을 통해 구현된다. 업무를 요청한 사람이 해당 권한을 부여할 수 있는지도 확인해야 한다. 공통 컨텍스트는 업무 참여자들이 함께 참조하도록 관리하는 목표, 자료, 제약, 결정과 현재 상태다. 이 책에서 사용하는 운영 개념이며 무제한 정보 공유나 하나의 확정된 국제 표준을 뜻하지 않는다.

출처 기록은 자료가 어떤 활동과 주체를 거쳐 만들어졌는지 설명하는 기록이다. 감사 기록은 특정한 사건과 그 조건을 나중에 확인하기 위한 기록이다. 기록의 존재와 내용의 진실성은 별도로 검토한다.

멱등성은 여기서 같은 의도의 요청을 재시도할 때 의도하지 않은 중복 효과가 발생하지 않도록 다루는 성질을 뜻한다. 실제 보장의 범위와 시간, 오류 처리 방식은 서비스마다 확인해야 한다.

거버넌스는 누가 어떤 기준으로 결정하고 검토하며 문제를 바로잡는지 정하는 운영·의사결정 구조다. 기술적귀속은 어떤 신원과 실행에 행동을 연결하는 것이고, 법적 책임은 적용 법과 사실관계에 따라 판단하는 문제다.

부록 B. 참고문헌과 주석

자료 확인일은 2026년 10월 28일이다. 법령은 아래 표시한 시행 판본, 기술 규격과 연구는 명시한 버전을 기준으로 인용했다. 번호는 본문과 부록 전체에서 공통으로 사용한다.

[1] NIST. Digital Identity Guidelines, SP 800-63-4 (2025), Appendix A Glossary, “digital identity”, “identifier”. 주어진 맥락 안에서의 고유성을 설명하는 직접 근거다. 회사별 사번 예시는 이 정의를 설명하기 위해 구성했다. 이 지침의 정의를 모든 분야의 신원 개념에 그대로 적용하지 않는다. 원문 열람

[2] Hunt, P., et al. System for Cross-domain Identity Management: Core Schema. RFC 7643 (2015), §§3.1, 4.1.1. id, userName, displayName을 구별하는 실제 표준 사례다. id의 안정성과 재할당 금지 요구는 SCIM 자원에 관한 요구이며, 모든 서비스의 로그인 이름이 변경 불가능하다는 뜻은 아니다. 원문 열람

[3] ISO. ISO 13616-1:2020, Financial services — International bank account number (IBAN) — Part 1: Structure of the IBAN, §3.1.
공개 열람 가능한 용어 정의를 확인했다. 계좌번호와 계좌를 구별하는 데 사용했으며, 특정 국가의 예금 계약이나 소유권판단을 이 규격에서 도출하지 않았다. 원문 열람

[4] NIST. Digital Identity Guidelines, SP 800-63-4 (2025), §2 Digital Identity Model.
가입자 계정, 검증자, 인증수단의 관계를 설명하는 직접 근거다. 이 문서의 subject는 사람을 대상으로 한다. 여기서 얻은 구분을 봇 계정 설계로 확장하는 부분은 저자의 적용이다. 원문 열람

[5] NIST. Digital Identity Guidelines: Authentication and Authenticator Management, SP 800-63B-4 (2025), §3.1.1 Passwords.
비밀번호를 인증에 사용하는 비밀값으로 설명하는 근거다. 본문은 해당 규격의 세부 비밀번호 정책을 설명하거나 특정인증방식을 권고하려는 목적이 아니다. 원문 열람

[6] Hardt, D., ed. The OAuth 2.0 Authorization Framework. RFC 6749 (2012), §2.2 Client Identifier. client_id만으로 클라이언트를 인증해서는 안 된다는 규정에 근거한다. OAuth의 client는 애플리케이션을 뜻하므로 일반사용자의 로그인 이름과 동일시하지 않는다. 이후 보안 지침으로 갱신된 부분이 있는 규격이며, 여기서는 해당 개념구분만 사용한다. 원문 열람

[7] Hu, V. C., et al. Guide to Attribute Based Access Control (ABAC) Definition and Considerations. NIST SP 800-162 (2014; updated 2019).
주체, 대상, 요청한 작업과 환경 조건에 기반한 정책 평가를 설명한다. 읽기와 수정 권한을 나누는 회사 사례는 가상의 적용 예시다. 원문 열람

[8] NIST. Digital Identity Guidelines: Identity Proofing and Enrollment, SP 800-63A-4 (2025), §5 Subscriber Accounts.
가명 계정, 역할과 복수 계정, 정보 변경, 정지와 종료를 다루는 근거다. 이 지침의 적용 범위를 벗어난 서비스에 동일한 의무가 자동으로 생긴다는 뜻은 아니다. 원문 열람

[9] Searle, J. R. (2015). Status functions and institutional facts: reply to Hindriks and Guala. Journal of Institutional Economics, 11(3), 507–514, 특히 p. 508. DOI: 10.1017/S1744137414000629.
지위 기능과 권한·의무에 관한 철학적 논의다. 디지털 계정의 기술 정의나 AI의 인격에 관한 실증 연구로 사용하지 않는다. ‘시스템 안의 자리’라는 표현은 본문을 위한 저자의 해석이다. 원문 열람

[10] W3C. Decentralized Identifiers (DIDs) v1.0. W3C Recommendation, 19 July 2022, Abstract 및 §2 Terminology의 “DID subject”.
식별 대상의 범위가 사람에 한정되지 않음을 뒷받침한다. DID를 봇 계정의 필수 기술로 제안하는 것은 아니며, 식별 가능성에서 의식이나 법적 인격을 추론하지 않는다. 원문 열람

[11] 대한민국. 주민등록법. 시행 2025. 7. 22. 제7조, 제7조의2, 제21조.
개인별·세대별 기록과 고유번호, 일정한 처분에 대한 이의신청을 구분해 사용했다. 관련 조문 원문을 함께 확인했다. 원문 열람

[12] 대한민국. 민법. 시행 2026. 3. 17. 제3조 및 제34조.
사람과 법인의 권리능력에 관한 근거다. AI의 법적 지위 전체를 이 두 조문만으로 확정하지 않는다. 원문 열람

[13] United Nations Statistics Division. United Nations Legal Identity Agenda. Background 및 UN Operational Definition of Legal Identity.
법 앞에서의 인격 인정, 출생등록과 법적 신원에 관한 국제적 논의의 범위를 확인했다. 원문 열람

[14] UNICEF Data. Birth registration.
출생등록과 필수 서비스 접근의 관계에 관한 자료다. 변동하는 등록 인구 수치를 본문에 전재하지 않았다. 원문 열람

[15] McLeay, M., Radia, A., & Thomas, R. (2014). Money in the modern economy: an introduction. Bank of England Quarterly Bulletin, 2014 Q1.
은행 예금의 경제적 성격을 설명하는 데 사용했다. 영국 자료를 한국 예금 계약의 법적 해석으로 대체하지 않았다. 원문 열람

[16] 대한민국. 금융실명거래 및 비밀보장에 관한 법률. 시행 2025. 4. 1. 제3조.
실명 금융거래와 일정 계좌의 금융자산 귀속 추정에 관한 근거다. 원문 열람

[17] NIST. (2025). Digital Identity Guidelines: Federation and Assertions. SP 800-63C-4, §1 Introduction.
연합 인증의 구조를 설명했다. 서비스별 데이터와 권한이 모두 통합된다는 의미로 사용하지 않았다. 원문 열람

[18] W3C. (2021). Web Authentication: An API for accessing Public Key Credentials, Level 2. Recommendation, 8 April 2021.
공개키 자격증명을 이용하는 인증의 사례다. 최신 제품 지원 현황을 설명하는 자료로 사용하지 않았다. 원문 열람

[19] Yao, S., et al. (2023). ReAct: Synergizing Reasoning and Acting in Language Models. ICLR 2023; arXiv:2210.03629v3.
추론과 외부 행동을 연결하는 연구다. 실험의 성과를 모든 실제 업무의 성과로 일반화하지 않았다. 원문 열람

[20] SPIFFE Project. SPIFFE Concepts; SPIFFE Overview. 공식 기술 문서.
워크로드 신원과 여러 실행 인스턴스, 인증 문서의 구분에 참고했다. 봇 계정 전체의 표준은 아니다. 원문 열람

[21] NIST Joint Task Force. (2020). Security and Privacy Controls for Information Systems and Organizations. SP 800-53 Rev. 5. AC-2, AC-6, AU-9.
계정 관리, 최소 권한과 감사 정보 보호를 참조했다. 공개 페이지의 Release 5.2.0 안내도 확인했다. 원문 열람

[22] Park, J. S., et al. (2023). Generative Agents: Interactive Simulacra of Human Behavior. UIST 2023; arXiv:2304.03442v2.
시뮬레이션 환경의 기억·계획·성찰 구조를 참고했다. 인간과 같은 기억 경험의 증거로 사용하지 않았다. 원문 열람

[23] Packer, C., et al. (2024). MemGPT: Towards LLMs as Operating Systems. arXiv:2310.08560v2; 최초 공개 2023. 입력 맥락과 외부 기억 계층의 관리를 다룬 연구다. 실제 기억의 완전성이나 정확성을 보증하는 자료가 아니다. 원문 열람

[24] 대한민국. 개인정보 보호법. 시행 2026. 9. 11. 제21조.
개인정보 파기의 원칙과 다른 법령상 보존 예외를 구분했다. 원문 열람

[25] OWASP Gen AI Security Project. LLM01:2025 Prompt Injection.
외부 자료가 모델 동작에 영향을 줄 수 있는 위험을 설명했다. 제안한 통제가 완전한 방어를 보장한다고 주장하지 않았다.
원문 열람

[26] A2A Project. Agent2Agent Protocol Specification, version 1.0.1. § §3.4, 4.1, 4.4.
작업·맥락 식별, 추가 입력 상태와 Agent Card를 참고했다. 통신 형식과 업무 품질의 보장은 구별했다. 원문 열람

[27] Temporal Technologies. Temporal Workflow Execution overview. 공식 기술 문서.
작업 상태를 유지하고 실행을 재개하는 구조의 사례다. 외부 부수 효과의 정확히 한 번 실행을 무조건 보장한다는 의미로 사용하지 않았다. 원문 열람

[28] Stripe. Idempotent requests. API reference.
요청 재시도의 중복 효과를 다루는 사례다. 구체적인 보장과 오류 처리는 API 버전과 조건에 따라 확인해야 한다. 원문 열람

[29] Jones, M., et al. (2020). OAuth 2.0 Token Exchange. RFC 8693, § §1.1, 4.1.
위임과 가장, 행동 주체를 구분하는 기술적 근거다. 프로토콜상의 가장을 곧바로 불법 사칭으로 번역하지 않았다. 원문 열람

[30] Lodderstedt, T., Richer, J., & Campbell, B. (2023). OAuth 2.0 Rich Authorization Requests. RFC 9396, § §1, 2.
세밀한 인가 정보와 결제 예시를 참고했다. 조건의 표현과 실제 집행을 구별했다. 원문 열람

[31] Moreau, L., & Missier, P., eds. (2013). PROV-DM: The PROV Data Model. W3C Recommendation, 30 April 2013. § §2, 5.3.
자료·활동·주체의 출처 관계를 표현하는 근거다. 법적 책임의 판정이나 기록의 진실성 보증으로 사용하지 않았다. 원문 열람

[32] United Nations. (2005). Convention on the Use of Electronic Communications in International Contracts. Article 12; UNCITRAL 공식 해설.
자동 메시지 시스템과 계약의 관계를 설명했다. 협약의 적용 범위와 개별 계약의 유효성은 별도 판단 대상이다. 원문 열람

[33] UNCITRAL. (2024). Model Law on Automated Contracting. Adopted 11 July 2024.
자동화 계약에 관한 입법 모델이다. 조약이나 각국에 직접 적용되는 통일 법률로 제시하지 않았다. 원문 열람

[34] NIST. (2023). Artificial Intelligence Risk Management Framework, AI RMF 1.0. NIST AI 100-1. GOVERN 1.6, 2.1.
AI 시스템의 목록과 역할·책임을 참고했다. 인용한 판본은 1.0이며 자발적 활용을 위한 틀이다.
원문 열람

[35] NIST. (2024). Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile. NIST AI 600-1, §2.7.
인간과 AI의 상호작용 위험을 검토하는 근거다. 특정 사용자에게 발생한 심리적 효과를 진단하지 않는다. 원문 열람

[36] European Union. Regulation (EU) 2016/679, General Data Protection Regulation. Article 20.
요건이 있는 개인정보 이동권을 설명했다. 봇의 전체 상태·모델·조직 자료를 옮기는 일반적 권리로 확대하지 않았다. 원문 열람

[37] Iannella, R., & Villata, S., eds. (2018). ODRL Information Model 2.2. W3C Recommendation, 15 February 2018.
이용에 관한 허용·금지·의무의 표현 모델이다. 실제 집행과 법적 효력은 별도다. 원문 열람

[38] Lodderstedt, T., Bradley, J., Labunets, A., & Fett, D. (2025). Best Current Practice for OAuth 2.0 Security. RFC 9700, § §2.2, 2.3.
토큰 재사용 방지와 접근 토큰 권한 제한을 참고했다. OAuth 2.0의 초기 규격과 함께 보안 갱신을 고려했다. 원문 열람

[39] Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025). Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. NIST SP 800-61 Rev. 3.
사고 탐지·대응·복구를 조직의 위험 관리에 연결하는 근거다. 원문 열람

[40] Butlin, P., et al. (2023). Consciousness in Artificial Intelligence: Insights from the Science of Consciousness. arXiv:2308.08708v3.
의식 이론에 기반한 지표 접근을 참고했다. 2023년의 시스템 평가를 2026년 이후 모든 AI에 대한 결론으로 사용하지 않았다. 원문 열람

[41] 대한민국. 개인정보 보호법. 시행 2026. 9. 11. 제37조의2.
완전히 자동화된 결정에 관한 권리를 설명하면서 거부권 요건·예외와 대상에서 제외되는 처분을 구분했다. 원문 열람

[42] Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture. NIST SP 800-207.
위치나 소유만으로 신뢰를 자동 부여하지 않는 접근과 인증·인가의 구분을 참고했다. 원문 열람

[43] 하우성(Ha Woo Sung). (2026). The Knowledge–Action Chain (KAC): An AX Execution Ontology for Turning Validated Knowledge into Action, Outcome, and Learning. 미발표 원고, 2026년 6월 23일. 한국어판·영어판 공개: github.com/sopia19910/Knowledge-Action-Chain.
공통 컨텍스트 구조(CCS)의 아홉 칸, 도메인 컨텍스트 무결성(DCI) 관문, 스킬 런타임, 산출물과 성과의 구별, 검토·피드백·컨텍스트 갱신의 순환 구조를 인용했다. 저자가 제안한 실행 모형이며, 각 구간의 검증 기준과 계수는 실제 자료로 조정해야 할 운영 변수라고 밝히고 있다. 이 책의 10.4절과 15.4절에서 봇 계정과 연결한 해석은 이 책의 것이다.